





AI Data Access Firewall: Preventing Unauthorised AI Access to Corporate Data

By

Vanshika Gangloo

TP067906

APD3F2511CS(CYB)

A report submitted in partial fulfillment of the requirements for the degree of Bachelor of Science (Honours) in Computer Science (Cyber Security) at Asia Pacific University of Technology and Innovation

Supervised by:

Dr. Seyedmostafa Safavi

Second Marker:

Mr. Shahab Alizadeh

2026

DECLARATION OF THESIS CONFIDENTIALITY

Author's full name: **VANSHIKA GANGLOO**

IC No./Passport No.: **1678957**

Thesis/Project title: **AI DATA ACCESS FIREWALL: PREVENTING UNAUTHORISED AI ACCESS TO CORPORATE DATA**

I declare that this thesis is classified as:

- ¨ CONFIDENTIAL
- ¨ RESTRICTED
- ☑ OPEN ACCESS

I acknowledged that Asia Pacific University of Technology & Innovation (APU) reserves the right as follows:

1. The thesis is the property of Asia Pacific University of Technology & Innovation (APU).
2. The Library of Asia Pacific University of Technology & Innovation (APU) has the right to make copies for the purpose of research only.
3. The Library has the right to make copies of the thesis for academic exchange.

Author's Signature: …V.Gangloo……

Date: 4 July 2026

Supervisor's Name: **Dr. Seyedmostafa Safavi**

Date: 4 July 2026

Signature: Dr. Seyed……

Please fill in **all** the following details for library cataloguing purposes.

First Name: Vanshika

Middle Name (only if applicable):

Last Name: Gangloo

Title of the Final Year Project / Dissertation / Thesis:
AI Data Access Firewall: Preventing Unauthorised AI Access to Corporate Data

Abstract:

Artificial intelligence (AI) technologies are increasingly integrated into organizational environments to support tasks such as information retrieval, document analysis, and automated decision support. While these systems improve operational efficiency, their integration with internal corporate data introduces new security risks, particularly when AI systems interact with sensitive organisational documents. Traditional security technologies primarily focus on managing human access and protecting network infrastructure, but they do not adequately regulate interactions between AI systems and corporate data repositories. This project proposes an AI Data Access Firewall, designed as an intermediary control layer positioned between an AI chatbot and corporate documents. The firewall evaluates AI-generated document requests using Role-Based Access Control (RBAC) policies and predefined document sensitivity classifications. Based on this evaluation, the system enforces deterministic access decisions including allow, deny, or allow with redaction, while logging all AI requests to support monitoring and auditing. The proposed architecture aims to reduce the risk of unauthorised document retrieval and improve accountability

in AI-assisted document access environments. The prototype demonstrates how policy-driven control mechanisms can regulate AI-to-data interactions within a controlled organisational setting suitable for prototype evaluation.
A few keywords associated with the work: Cybersecurity Artificial Intelligence Access Control Role-Based Access Control (RBAC) Information Security
General Subject: (e.g Management information systems, Organizational behaviour, Risk management, Computer Software) Computer Security
Date of Submission: 22 July 2026

Acknowledgment

I would like to express my sincere gratitude to my supervisor Dr. Seyedmostafa Safavi for the continuous guidance, support, and valuable feedback provided throughout the development of this project. Their constructive comments and direction have played an essential role in shaping the AI Data Access Firewall from its initial concept to its current form. I am truly thankful for their patience, encouragement, and commitment during this journey. I would also like to extend my appreciation to the second marker for taking the time to review my work and provide insightful comments that contributed to improving the quality of this research. Their feedback is highly valued and appreciated. In addition, I would like to thank all participants who contributed to the survey and shared their perspectives, which helped validate the research problem and strengthen the findings of this project. My appreciation also goes to friends, classmates, and anyone who provided support, advice, or motivation throughout this Final Year Project. Finally, I am grateful to my family for their constant encouragement and understanding during the completion of this project.

Abstract

Artificial intelligence (AI) technologies are increasingly integrated into organizational environments to support tasks such as information retrieval, document analysis, and automated decision support. While these systems improve operational efficiency, their integration with internal corporate data introduces new security risks, particularly when AI systems interact with sensitive organisational documents. Traditional security technologies primarily focus on managing human access and protecting network infrastructure, but they do not adequately regulate interactions between AI systems and corporate data repositories. This project proposes an AI Data Access Firewall, designed as an intermediary control layer positioned between an AI chatbot and corporate documents. The firewall evaluates AI-generated document requests using Role-Based Access Control (RBAC) policies and predefined document sensitivity classifications. Based on this evaluation, the system enforces deterministic access decisions including allow, deny, or allow with redaction, while logging all AI requests to support monitoring and auditing. The proposed architecture aims to reduce the risk of unauthorised document retrieval and improve accountability in AI-assisted document access environments. The prototype demonstrates how policy-driven control mechanisms can regulate AI-to-data interactions within a controlled organisational setting suitable for prototype evaluation.

Table of Contents

Acknowledgment 4

Abstract 5

List of Figures 11

List of Tables 13

Chapter 1: Introduction 14

1.1 Introduction 14

1.2 Problem Background 15

1.3 Project Aim 16

1.4 Objectives 16

1.5 Scope 16

1.6 Definition of Key Terms 17

1.7 Potential Benefits 18

1.8 Overview of the Investigation Report 18

1.9 Project Plan 19

Chapter 2 - Literature Review 20

2.0.1 Introduction 20

2.0.2 Existing studies 20

2.0.3 AI-Specific Threat Model 21

2.0.4 Identified gaps 22

2.0.5 Summary 23

2.1 Domain Research 23

2.2 Similar Systems / Related Work 26

2.2.1 System 1 – Role-Based Access Control (RBAC) 26

2.2.2 System 2 – Data Loss Prevention (DLP) 27
2.2.3 System 3 – AI Monitoring / AI Governance 28
2.2.4 Proposed system comparison 29
2.2.5 Comparative Analysis of Related Systems 30
2.2.6 Conclusion 30
2.3 Technical Research 31
2.3.1 System Requirement Analysis 31
2.3.2 Software Tools 31
2.3.3 Hardware requirements 33
2.3.4 Justification 33
Chapter 3: Methodology 34
3.1 System Development Methodology 34
3.1.1 Introduction 34
3.1.2 Methodology Selection and Justification 34
3.1.3 Requirement Analysis Phase 35
3.1.4 System Design Phase 36
3.1.5 Development Phase 37
3.1.6 Testing Phase 39
3.1.7 Evaluation and Refinement Phase 40
3.2 Data Gathering Design 41
3.2.1 Data Gathering Technique – Survey 41
3.2.2 Questionnaire Design 42
3.3 Analysis 43
3.3.1 Survey Response Overview 43

3.3.2 Analysis by Thematic Sections 44
3.3.3 Final User Requirements Derived from Analysis 46
3.4 Proposed System Architecture 47
3.4.1 Security Assumptions 49
3.5 System Request Flow 49
3.5.1 User Prompt Submission 49
3.5.2 AI Request Generation 49
3.5.3 Policy Evaluation (Policy Decision Point) 50
3.5.4 Access Decision 50
3.5.5 Document Retrieval and Enforcement 50
3.5.6 Logging and Monitoring 51
3.5.7 Response to User 51
3.6 Policy Engine Design 51
3.6.1 Role-Based Access Control Model 52
3.6.2 Document Sensitivity Classification 52
3.6.3 Policy Evaluation Logic 52
3.7 Enforcement Mechanism 53
3.7.1 Allow 53
3.7.2 Deny 53
3.7.3 Allow with Redaction 54
3.7.4 Deterministic Policy Enforcement 55
3.8 Justification for Simulated AI 55
Chapter 4: Design and Implementation 57
4.1 Introduction 57

4.2 System Design 57
4.2.1 Overall System Architecture 58
4.2.2 Use Case Diagram 61
4.2.3 Activity Diagram 63
4.2.4 Sequence Diagram 65
4.2.5 Class Diagram 66
4.3 System Implementation 68
4.3.1 Development Environment 68
4.3.2 Project Structure 69
4.3.3 User Authentication Module 71
4.3.4 AI Security Assistant Module 75
4.3.5 RBAC Policy Engine 79
4.3.6 Document Repository and Sensitivity Classification 83
4.3.7 Audit Logging Module 85
4.3.8 Admin Dashboard 88
4.4 User Interface Design 91
4.4.1 Login Interface 91
4.4.3 AI Security Assistant Interface 94
4.5 Chapter Summary 97
Chapter 5: System Testing and Evaluation 99
5.1 Introduction 99
5.2 Testing Methodology 100
5.2.1 Testing Environment 101
5.2.2 Test Cases 102

5.2.3 Evaluation Metrics 104
5.3 Evaluation Results 105
5.3.1 Functional Testing Results 105
5.3.2 Confusion Matrix Analysis 107
5.3.3 Block Rate Analysis 108
5.3.4 Leakage Prevention Rate Analysis 109
5.3.5 Redaction Accuracy Analysis 110
5.3.6 Response Latency Analysis 111
5.4 Discussion 111
5.5 Chapter Summary 113
Chapter 6: Conclusion 115
6.1 Introduction 115
6.2 Achievement of Project Objectives 115
6.3 Project Contributions 116
6.4 Limitations 117
6.5 Future Work 118
6.6 Chapter Summary 119
Appendix 120
REFERENCES 141

List of Figures

Figure 1: Gantt Chart 19
Figure 2: Proposed AI Data Access Firewall System Architecture 47
Figure 3: Overall System Architecture of the Proposed AI Data Access Firewall 59
Figure 4: Use Case Diagram of the Proposed AI Data Access Firewall 61
Figure 5: Activity Diagram of the Proposed AI Data Access Firewall 63
Figure 6: Sequence Diagram of the Proposed AI Data Access Firewall 65
Figure 7: Class Diagram of the Proposed AI Data Access Firewall 66
Figure 8: Project Structure of the Proposed AI Data Access Firewall 70
Figure 9: Login Interface of the AI Data Access Firewall 72
Figure 10: User Credentials Stored in users.json 73
Figure 11: User Authentication Implementation in app.py 74
Figure 12: AI Security Assistant Interface 76
Figure 13: Document Request Processed by the AI Security Assistant 77
Figure 14: AI Security Assistant Request Processing in app.py 78
Figure 15: RBAC Policy Evaluation Implementation 80
Figure 16: RBAC Policy Definitions Stored in policies.json 81
Figure 17: Example of an RBAC Policy Decision 82
Figure 18: Document Repository Organised by Sensitivity Classification 84
Figure 19: Document Retrieval and Validation in app.py 84
Figure 20: Audit Logging Implementation in logger.py 86
Figure 21: Sample Audit Log Entries 87
Figure 22: Audit Centre Interface 88
Figure 23: Admin Dashboard Interface 1 89
Figure 24: Admin Dashboard Interface 2 90
Figure 25: Dashboard Statistics Generation in app.py 91
Figure 26: Login Interface 92
Figure 27: Dashboard Interface 93
Figure 28: AI Security Assistant Interface 95

Figure 29: Audit Log Interface..... 96

List of Tables

Table 1: Comparative Analysis of Related Systems 30
Table 2: Development Environment of the Proposed AI Data Access Firewall 68
Table 3: Testing environment specifications 101
Table 4: Functional test cases conducted during the system evaluation 102
Table 5: Evaluation Scenarios and Results 106
Table 6: Confusion Matrix Results 108
Table 7: Block Rate Calculation 108
Table 8: Leakage Prevention Rate Calculation 109
Table 9: Redaction Accuracy Calculation 110
Table 10: Response Latency Results 111

Chapter 1: Introduction

1.1 Introduction

Artificial Intelligence (AI) has significantly transformed modern organisations by improving information accessibility and supporting the automation of operational processes. AI technologies are increasingly integrated into corporate environments to automate document processing, assist in decision-making, and improve operational efficiency. As a result, AI systems are becoming an important component of contemporary business operations. However, as organisations integrate these technologies with internal corporate systems, new security challenges emerge, particularly in controlling access to sensitive organizational information.

Unlike human employees who can understand organisational context and confidentiality requirements, AI systems operate primarily through statistical pattern recognition and do not inherently recognise organisational access policies or data sensitivity (National Institute of Standards and Technology [NIST], 2023; European Union Agency for Cybersecurity [ENISA], 2023). When AI tools are granted access to internal document repositories, they may retrieve information without distinguishing between publicly accessible data and confidential organisational records. This creates a potential security risk in which sensitive information—such as financial records, employee data, or proprietary business information—may be retrieved by users without appropriate authorisation.

Traditional security mechanisms, including network firewalls and authentication systems, are primarily designed to regulate human access and protect network infrastructure from external threats. However, these mechanisms are not designed to evaluate AI-generated document retrieval requests or enforce fine-grained access control over AI-to-data interactions. This limitation highlights the need for a specialised security mechanism capable of regulating how AI systems access organisational data. To address this challenge, this project proposes an AI Data Access Firewall, which functions as an intermediary control layer between an AI chatbot and corporate document repositories. The firewall evaluates AI-generated document requests based on predefined access policies before any document retrieval occurs, thereby reducing the risk of unauthorised data access and improving accountability in AI-assisted information systems. This study therefore investigates the security challenges associated with AI-driven document access and

proposes a policy-based AI Data Access Firewall architecture designed to enforce controlled and auditable AI-to-data interactions within organisational environments.

1.2 Problem Background

In modern organisations, traditional security technologies such as network firewalls and authentication systems are designed to control user access and protect infrastructure from external threats (ENISA, 2023; OWASP, 2023). While these technologies are effective in managing human access, they are not designed to monitor or control interactions between AI systems and corporate data. Organisations store a large number of sensitive documents on a daily basis, including financial records, employee information, strategic planning documents, and customer data. At the same time, organisations are increasingly integrating AI tools into internal systems to improve operational efficiency, where AI assists with tasks such as document retrieval, summarisation, and information analysis.

However, the technologies currently used to protect this data are becoming less suitable for this evolving environment. Organisations continue to rely on traditional network firewalls, authentication systems, and standard access controls, which function effectively for human users but are not designed for AI-driven interactions. These technologies primarily regulate who can log into a system, which folders a user can access, and whether an employee has the correct permissions or credentials. If an employee does not have the required access rights, they are prevented from opening the file.

However, these traditional controls are insufficient when AI systems are integrated into document retrieval workflows, as they were not originally designed to manage AI-to-data interactions. Traditional access control systems do not evaluate the semantic intent of natural-language prompts submitted to AI systems. They are also unable to detect indirect misuse, such as when a user asks an AI system to summarise a restricted document instead of directly requesting access to it. As a result, existing technologies fail to control what information the AI retrieves and what should be visible to the user, creating a significant gap in organisational data security.

1.3 Project Aim

To design and implement an AI Data Access Firewall that enforces Role-Based Access Control (RBAC) and document sensitivity policies to prevent unauthorised document retrieval and data leakage in AI-driven document access scenarios.

1.4 Objectives

1. To define four document sensitivity levels (Public, Internal, Confidential, Restricted) with explicit access criteria.
2. To implement a Role-Based Access Control (RBAC) policy engine for evaluating AI Requests.
3. To enforce deterministic access decisions (Allow, Deny, Allow with Redaction) based on role clearance and document sensitivity.
4. To log 100% of AI Requests for auditing and traceability.
5. To evaluate the system against predefined attack scenarios, including unauthorised access attempts and over-broad retrieval queries.

1.5 Scope

This project focuses on the development of an AI Data Access Firewall that operates as a control layer between an AI chatbot and corporate documents. The system will evaluate AI access requests based on predefined access control rules, user roles, and data sensitivity levels. Corporate documents will be classified according to their confidentiality, and the firewall will allow and deny access accordingly. This project also includes logging and recording AI access attempts to support monitoring and auditing within a simulated corporate environment.

This project is limited to a software-based implementation and does not include real-world deployment in live organisational systems. Network-level firewall configuration, infrastructure security, and AI model training, fine-tuning, and integration of external Large Language Models (LLMs) are excluded from this study. The system will not perform advanced threat detection, malware analysis, or regulatory compliance enforcement. User authentication is assumed to be handled externally, and the project will focus only on controlling AI access to documents rather than managing user identities. The system boundaries are defined in a way where the firewall operates strictly between the AI chatbot and the document storage layer. The project will be implemented using Python and the Flask framework in a local development environment. A

simulated document repository and logging mechanism will be used to demonstrate the system's functionality. These constraints ensure that the project remains achievable within the given timeframe while maintaining a clear focus on AI-specific access control.

1.6 Definition of Key Terms

AI Request

AI Request is defined as a structured document retrieval query generated from a user prompt submitted through a simulated AI chatbot interface.

Unauthorised Access

Unauthorised access refers to any attempt to retrieve a document or document content beyond the permissions assigned to a user's role under the defined RBAC policy.

Data Leakage

Data leakage is defined as the exposure of Confidential or Restricted information to a user without explicit authorization under the enforced access control policy.

Sensitivity Levels

In this study, corporate documents are classified into four predefined **sensitivity levels**. These levels determine access permissions under the RBAC policy implemented in the AI Data Access Firewall.

Public Information that can be accessed by all authenticated users without restriction.
Example documents include company announcements or publicly available policies.

Internal Information intended for general employees but not for external distribution.
Example internal memos, operational guidelines.

Confidential Information restricted to specific departments or managerial roles due to business sensitivity.
Example financial reports, project plans, internal performance data.

Restricted Highly sensitive information accessible only to senior management or authorised executives.

Example salary records, strategic acquisition plans, proprietary trade secrets.

Access to these sensitivity levels is enforced through predefined role-to-clearance mappings within the policy engine.

1.7 Potential Benefits

The system aims to reduce unauthorised access, thereby lowering the risk of data leakage and improving monitoring and auditing of AI interactions with corporate documents. By controlling AI Requests and maintaining detailed access logs, organisations gain improved visibility into how sensitive information is accessed and used within AI-assisted workflows. As an additional benefit, the system contributes to increased awareness of AI-related security risks and supports more informed decision-making when deploying AI tools within organisational environments. These improvements may enhance organizational confidence in AI-enabled document access systems for handling corporate information. The primary stakeholders of this system include organisations, particularly small and medium-sized enterprises (SMEs). In addition, the system also benefits IT and security teams, cybersecurity students and researchers, and developers who work with AI-based systems.

1.8 Overview of the Investigation Report

Chapter 1 introduces the project by describing the background of the study, the problem addressed, the project aim, objectives, scope, and potential benefits.

Chapter 2 discusses the problem in detail through domain research, literature review, and an analysis of similar existing systems, highlighting their limitations and how they relate to this project.

Chapter 3 explains the proposed system design and methodology, including the overall architecture, system components, and the approach used to implement the AI Data Access Firewall.

Chapter 4 presents the implementation and evaluation of the system, including testing scenarios and an assessment of the system's effectiveness in meeting the project objectives.

1.9 Project Plan

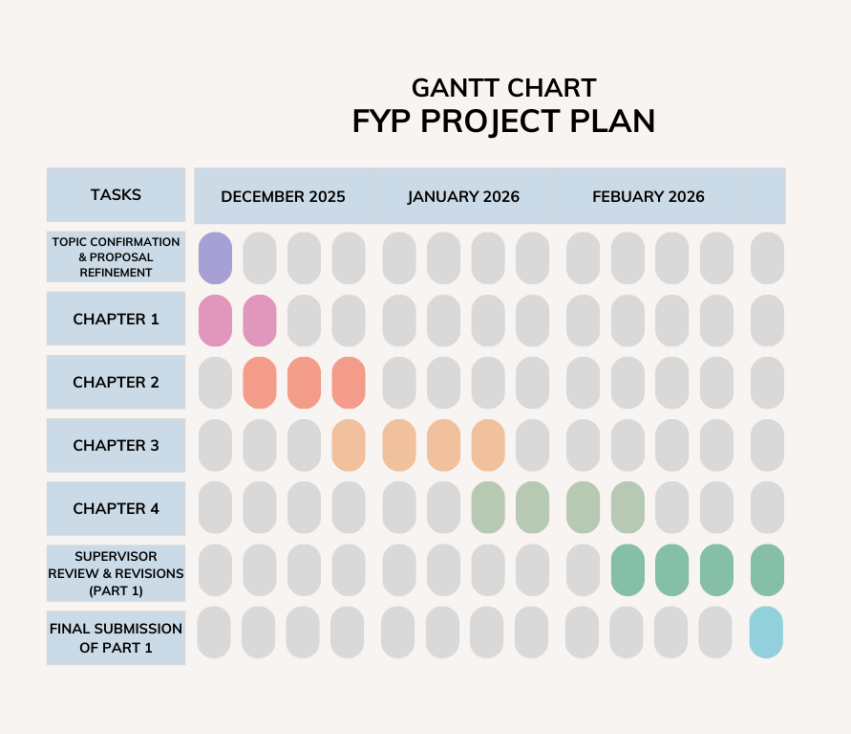


Figure 1: Gantt Chart

The project timeline is illustrated in Figure 1. The development process begins with topic confirmation and literature review, followed by system design and implementation. Testing, evaluation, and supervisor revisions are scheduled prior to final submission to ensure the project objectives are achieved within the allocated timeframe.

Chapter 2 - Literature Review

2.0.1 Introduction

This literature review examines existing academic studies, senior and Final Year Project works, and industry reports related to the security challenges introduced by artificial intelligence in organisational environments. The review focuses on key areas including AI security, data leakage, and access control mechanisms used to protect sensitive corporate information. As AI systems are increasingly integrated into business operations, researchers and industry practitioners have highlighted various risks associated with unauthorised data access and the improper handling of confidential information. The purpose of this literature review is to analyse prior work in these areas in order to provide supporting evidence for the problem identified in Chapter 1 and to establish a clear understanding of the limitations present in current approaches to securing AI interactions with corporate data.

2.0.2 Existing studies

Existing studies and industry reports highlight the growing security risks associated with the use of artificial intelligence in organisational environments. As AI systems are increasingly integrated with internal databases and document repositories, researchers have identified unauthorised access and data leakage as significant concerns (ENISA, 2023; IBM Security, 2022).

AI-powered tools, including chatbots and automated assistants, can retrieve, summarise, and generate information, which increases the risk of sensitive corporate data being unintentionally exposed when access controls are weak or incorrectly configured (NIST, 2023; ENISA, 2023). Several incidents have demonstrated that AI systems may expose confidential information through indirect interactions, even when direct access to restricted documents is not permitted. Research indicates that AI systems lack intrinsic awareness of data sensitivity because they operate based on probabilistic pattern recognition rather than policy-aware reasoning (NIST, 2023).

Furthermore, existing literature shows that traditional security mechanisms, such as network firewalls, authentication systems, and Role-Based Access Control (RBAC), are primarily designed to manage human access and network traffic. These mechanisms cannot analyse natural language queries or effectively monitor interactions between AI systems and data, which limits their

effectiveness in AI-driven environments (ENISA, 2023). Studies highlight the need for monitoring, logging, and auditing AI activities to enhance transparency and accountability.

However, many existing solutions focus mainly on governance and compliance rather than real-time access control (IBM Security, 2022). These findings demonstrate a structural gap between documented AI-related security risks and the availability of real-time access control mechanisms specifically designed to regulate AI-to-data interactions (OWASP, 2023; MITRE, 2023).

2.0.3 AI-Specific Threat Model

Based on existing literature and reported incidents, several AI-specific attack patterns are relevant to corporate document access environments.

1. Prompt Injection

Prompt injection refers to malicious or manipulated user inputs designed to override system instructions or bypass intended restrictions in AI applications (OWASP, 2023; Greshake et al., 2023). In AI-integrated systems, attackers may craft prompts that attempt to manipulate the AI into retrieving restricted information (OWASP, 2023; MITRE, 2023). Research on black-box attacks demonstrates that machine learning systems can be influenced even when the internal models are not directly accessible (Papernot et al., 2016)

2. Indirect Prompt Injection

Indirect prompt injections occur when malicious instructions are embedded within stored documents. When the AI processes such document, it may follow embedded instructions that result in unintended disclosure of sensitive content (OWASP, 2023).

3. Over-Broad Retrieval

Over-broad retrieval involves requesting excessive or vague information (e.g., “Provide all salary data”), which may result in exposure of documents beyond the user's intended access scope (ENISA, 2023).

4. Role Confusion / Privilege Escalation

Role confusion occurs when an AI system retrieves information beyond the clearance level of the requesting user due to inadequate role validation mechanisms. In such situations, the AI system may unintentionally access documents that exceed the authorised privileges of the user who initiated the request. These threats highlight the necessity for deterministic policy enforcement mechanisms positioned between AI systems and corporate data repositories. In this study, these

threats are addressed through the implementation of a Policy Decision Point (PDP) that evaluates AI Requests prior to document retrieval (Sandhu et al., 1996). The threat model considered in this study focuses primarily on risks that can be mitigated through deterministic access control mechanisms. While existing literature frequently discusses threats such as prompt injection and indirect prompt injection in large language model applications, the proposed AI Data Access Firewall prototype does not analyse the natural language content of prompts. Instead, the system mitigates risks related to unauthorised document retrieval, role confusion, excessive data exposure, and lack of accountability in AI-driven data access environments.

By enforcing Role-Based Access Control (RBAC) combined with predefined document sensitivity classifications, the firewall ensures that AI requests cannot retrieve documents beyond the permitted clearance level of the requesting role. In addition, the logging mechanism provides traceability for all AI access attempts, allowing organisations to investigate potential misuse or policy violations. This alignment ensures that the evaluation focuses on security controls that the prototype can deterministically enforce within the defined system boundary.

2.0.4 Identified gaps

Although existing studies and industry reports clearly highlight the security risks associated with AI systems in organisational environments, several gaps remain in current approaches to protecting corporate data. Most existing security mechanisms are designed primarily for human users and network-level threats, with limited consideration of how AI systems access and process sensitive information. As a result, traditional access control models and security tools are not well suited to managing AI-to-data interactions.

One major gap identified in the literature is the lack of AI-specific access control mechanisms. While role-based and policy-based controls are effective for regulating user access, they do not inspect or evaluate natural-language queries generated by AI systems. This allows AI tools to retrieve or summarise restricted information indirectly, which increases the risk of unauthorised information flowing across sensitivity boundaries. Research in information-flow security highlights how improper control of data flow can lead to unintended disclosure of sensitive information (Sabelfeld & Myers, 2003).

In addition, many current solutions focus primarily on governance, compliance, and post-incident monitoring rather than real-time prevention. Although logging and auditing are frequently recommended, they are not consistently integrated into access control processes for AI systems. Furthermore, existing AI security and governance tools are often complex, expensive, and primarily designed for large enterprises, making them less suitable for small and medium-sized organisations or educational environments. These limitations highlight the need for a simple, transparent, and AI-focused access control approach to better protect sensitive corporate data. The literature therefore suggests the need for a Policy Decision Point (PDP) capable of evaluating AI Requests prior to document retrieval, enforcing role-based restrictions, and preventing content-level leakage in real time.

2.0.5 Summary

This literature review examined existing academic studies, senior projects, and industry reports related to the security challenges introduced by artificial intelligence in organizational environments. The review highlights that when AI systems interact with corporate data, the risk of unauthorised access and data leakage increases, particularly when traditional security mechanisms are applied without AI-specific controls. It was also identified that many existing solutions primarily focus on human users, network security, and governance, resulting in limited real-time control and monitoring of AI-to-data interactions. These findings confirm the need for further research into AI-focused access control mechanisms. This need is addressed in the following sections through domain research and the analysis of related systems.

2.1 Domain Research

Cybersecurity refers to the protection of digital systems, networks, and data from unauthorised access, misuse, damage, or disruption. In organisational environments, cybersecurity is essential for protecting sensitive information such as financial records, employee details, intellectual property, and important business documents. The core objective of cybersecurity is commonly described through the Confidentiality, Integrity, and Availability (CIA) triad, which ensures that information is accessible only to authorised users, remains accurate and unaltered, and is available when required (ISO/IEC 27001, 2013).

In the context of this study, confidentiality is the primary security objective, as the AI Data Access Firewall is specifically designed to prevent the unauthorised disclosure of sensitive corporate

documents during AI-driven retrieval processes. Traditional cybersecurity in organisations typically relies on tools such as network firewalls, authentication mechanisms, intrusion detection systems, and Role-Based Access Control (RBAC).

The main objective of these mechanisms is to prevent external attacks and regulate human access to internal systems. They control who can log into the system, what resources a user can access, and how network traffic is monitored. While these mechanisms are effective in protecting against external threats and unauthorised users, they were originally designed to manage human access and network-level threats rather than automated AI interactions with organisational data. Understanding the fundamental principles of cybersecurity is important for this project because the proposed system aims to protect corporate data while maintaining confidentiality, integrity, and availability. These principles provide the foundation upon which the AI Data Access Firewall is conceptually built. AI security refers to the protection of artificial intelligence from misuse, manipulation, unauthorised access, and exploitation.

The main focus is to make sure that the AI models operate safely, reliably, and within defined security boundaries. Traditional cybersecurity primarily protects networks, devices, and human users, whereas AI security addresses risks arising from AI-driven data processing and prompt-based interactions. Because AI systems learn from data and generate outputs based on patterns rather than human judgment, they are vulnerable to prompt manipulation and indirect misuse. Therefore, they require additional security considerations beyond standard network protection. This observation reinforces the need for intermediary control mechanisms capable of evaluating AI Requests before sensitive documents are retrieved.

In modern organisations, AI systems are increasingly used to automate tasks such as document summarisation, information retrieval, data analysis, and customer interaction. Many organisations are integrating AI chatbots and intelligent assistants directly with internal databases and document repositories to improve efficiency and productivity. While this integration improves operational performance, it also introduces new security risks. AI systems can process large volumes of sensitive corporate data quickly and may retrieve or generate information without fully understanding its confidentiality level. Risks such as data leakage, prompt manipulation, indirect

access to restricted information, and system misconfiguration become more common when AI tools are connected to internal systems without appropriate safeguards. As AI systems respond to natural-language inputs, even carefully crafted prompts may result in unintended exposure of sensitive information. This concept is directly relevant to the project because the identified risks of AI misuse and unintended data exposure highlight the need for additional security controls specifically designed for AI-to-data interactions.

Access control is a security mechanism that determines who is permitted to access specific information within a system. It ensures that only authorised users can view, modify, or manage sensitive information. Common models such as Role-Based Access Control (RBAC) assign permissions based on organisational roles, while Attribute-Based Access Control (ABAC) evaluates attributes such as department, clearance level, or job function. Access control systems have evolved to address different organisational requirements and risk environments (Hu, Ferraiolo, & Kuhn, 2006). These mechanisms are effective in managing human access to corporate systems and documents. However, traditional RBAC models assume human-initiated access and do not evaluate AI-generated document retrieval workflows, which creates a gap when AI systems interact directly with document repositories. This limitation motivates the need for an AI-specific enforcement mechanism.

Document security refers to the protection of digital documents from unauthorised access, modification, or disclosure. In corporate environments, documents often contain highly sensitive information, including financial statements, employee records, customer data, business strategies, and legal agreements. Organisations typically implement security measures such as encryption, access permissions, password protection, and document classification to protect these files. While these mechanisms are effective in regulating human access, challenges arise when AI systems are integrated with document repositories.

AI tools can retrieve, summarise, and generate content based on stored documents, potentially exposing restricted information indirectly. As traditional document security frameworks were initially designed for human users, they may not fully address the risks introduced by AI-driven document processing. Since this project focuses on controlling AI access to corporate documents,

understanding document security mechanisms is important for identifying how AI integration creates new vulnerabilities that existing protections may not fully address.

2.2 Similar Systems / Related Work

2.2.1 System 1 – Role-Based Access Control (RBAC)

Role-Based Access Control (RBAC) is one of the most used approaches for managing access to organisational systems. RBAC regulates user permissions by assigning access rights based on predefined roles within an organisation, such as employee, manager, or administrator. Each role is associated with specific permissions that define which documents, databases, or systems a user is authorised to access when logging into the system. When a user logs in, their assigned role automatically determines the level of access they are granted (Sandhu et al., 1996).

Characteristics

- Access permissions based on organisational roles
- Centralised permission management
- Widely implemented in enterprise systems
- Effective for document and database access control

Strengths

- Clear and structured permission hierarchy
- Reduces unauthorised human access
- Easy to manage in large organisations
- Supports accountability through defined roles

Weaknesses

- Designed primarily for human users
- Does not analyse natural-language AI queries
- Cannot evaluate AI-generated summaries
- Cannot detect indirect document exposure
- Does not monitor AI-to-data interaction

2.2.2 System 2 – Data Loss Prevention (DLP)

Data Loss Prevention (DLP) refers to security technologies used to monitor, detect, and prevent the unauthorised transmission of confidential information. DLP technologies are designed to protect sensitive data by identifying and controlling how information is stored, processed, and transmitted within an organisation. These systems can analyse data in motion (data being transmitted across networks), data at rest (data stored in systems or repositories), and sometimes data in use (data actively being processed) to determine whether sensitive information is present based on predefined security policies.

DLP technologies apply rule-based mechanisms to classify sensitive data such as financial records, personal information, or intellectual property. Once identified, these systems can prevent the unauthorised sharing of such information outside the corporate environment. In addition, DLP technologies help reduce the risk of employees unintentionally or intentionally exposing confidential information, for example through email communication, cloud storage services, or external storage devices. These mechanisms support organisational information security practices aimed at protecting sensitive corporate data (ISO/IEC 27001, 2013).

Characteristics

- Monitors data in motion, at rest, and in use
- Uses predefined security policies
- Classifies sensitive information
- Prevents unauthorised data transmission

Strengths

- Effective in preventing external data leakage
- Automated detection of sensitive information
- Works across multiple communication channels
- Enhances compliance and monitoring

Weaknesses

- Primarily focused on human-generated actions
- Does not analyse AI-generated outputs
- Cannot interpret natural-language AI prompts

- Limited control over AI-to-database interactions
- May generate false positives

2.2.3 System 3 – AI Monitoring / AI Governance

AI Monitoring and AI Governance platforms are systems designed to oversee and manage the behaviour of artificial intelligence models within organisational environments. These platforms track AI activities, log user interactions, and monitor how AI systems process and generate information. Their primary purpose is to ensure compliance with organisational policies, ethical guidelines, and regulatory requirements.

AI governance tools often include features such as usage logging, model performance tracking, risk assessment, and policy enforcement alerts. Governance frameworks further emphasise transparency, accountability, and structured risk management as key principles for responsible AI deployment (Floridi & Cowls, 2019). In corporate environments, these systems help organisations maintain oversight and control when implementing AI solutions.

Characteristics

- Tracks AI usage and interactions
- Maintains activity logs and audit trails
- Supports compliance and governance policies
- Provides monitoring dashboards

Strengths

- Improves AI transparency
- Enhances accountability
- Supports regulatory compliance
- Provides monitoring and reporting tools

Weaknesses

- Focusing mainly on monitoring rather than real-time prevention
- Does not always enforce document-level access control
- May rely heavily on policy configuration
- Limited capability to block AI retrieval before data exposure

2.2.4 Proposed system comparison

Role-Based Access Control (RBAC), Data Loss Prevention (DLP), and AI Monitoring systems contribute significantly to organisational security; however, they do not adequately address the problem of controlling AI-to-data interactions. For example, although RBAC effectively manages human access by assigning permissions based on predefined roles, it does not evaluate how an AI system generates queries or summarises information after access has been granted. Similarly, DLP systems primarily focus on detecting the leakage of data across communication channels and do not assess whether AI systems retrieving and processing internal documents may expose information inappropriately.

Furthermore, AI governance platforms facilitate transparency and accountability by tracking and monitoring AI system activities. However, most of these platforms focus mainly on compliance and post-incident analysis rather than proactively preventing unauthorised access to sensitive data through real-time enforcement mechanisms (NIST, 2023; OWASP, 2023; ENISA, 2023). In contrast, the proposed AI Data Access Firewall is designed to operate as an intermediary control layer between an AI chatbot and the documents stored within an organisation's document repositories. Unlike traditional RBAC systems, the AI Data Access Firewall evaluates AI-generated requests before any document retrieval occurs (Sandhu et al., 1996). Compared to DLP systems, the proposed firewall controls access at the point of interaction between the AI system and the data repository, rather than simply monitoring outgoing information.

Additionally, while many AI governance platforms focus primarily on oversight and monitoring, the AI Data Access Firewall enforces real-time access control over corporate data accessed by AI systems. Table 1 summarises the comparison between existing security systems and the proposed AI Data Access Firewall.

2.2.5 Comparative Analysis of Related Systems

Table 1: Comparative Analysis of Related Systems

Criteria	RBAC	DLP	AI Governance	Proposed AI Data Access Firewall
Real-time enforcement	Yes	Partial	Limited	Yes
Document-level control	No	Yes	Limited	Yes
Output filtering / redaction	No	Limited	No	Yes
AI prompt evaluation	No	No	Limited	No (request metadata only)
Audit logging	Yes	Yes	Yes	Yes
Designed for AI-to-data control	No	No	No	Yes

Table 1 illustrates that existing systems provide partial protection but do not offer a unified, AI-specific real-time control mechanism positioned directly between AI systems and document repositories.

2.2.6 Conclusion

Research shows that Role-Based Access Control (RBAC), Data Loss Prevention (DLP) systems, and AI Monitoring platforms provide important layers of security within organisational environments. RBAC controls human access to computer systems and documents by assigning permissions based on predefined organisational roles. DLP systems help ensure that sensitive data is not unintentionally transmitted or exposed through communication channels. AI governance platforms further support transparency and accountability in the deployment and management of AI systems. However, while each of these systems provides valuable security capabilities, they do not offer a comprehensive

solution for controlling real-time interactions between AI systems and sensitive corporate data.

This review confirms that although RBAC, DLP, and AI governance platforms contribute important security controls, none are specifically designed to evaluate AI Requests before document retrieval occurs. This structural limitation supports the development of a dedicated AI Data Access Firewall positioned as a Policy Decision Point (PDP) to enforce deterministic access control within AI-driven environments

2.3 Technical Research

2.3.1 System Requirement Analysis

The AI Data Access Firewall is implemented as a locally deployed prototype designed to validate AI-specific access control mechanisms. The system requires backend processing logic capable of validating AI-generated requests according to predefined access control rules. As a result, the prototype provides functionality that supports role-based access decisions, document classification based on sensitivity levels, and logging of all access activities for monitoring and auditing purposes.

The system also includes the capability to retrieve documents from a simulated repository in order to demonstrate how controlled document access and retrieval can be enforced through policy evaluation. Since this project focuses on prototype implementation rather than enterprise deployment, large-scale infrastructure or cloud-based architecture is not required. The prototype environment is therefore designed to demonstrate the feasibility of the proposed access control mechanism within a controlled development setting.

2.3.2 Software Tools

Python

Python will be used as the primary programming language for the development of the AI Data Access Firewall. The selection of Python is based on its ease of use, readability, availability of extensive backend development libraries, and its capability to support security-related functionality. Python also provides strong support for data processing, file handling, and rule-based logic, which are necessary for evaluating AI-generated requests and implementing access control mechanisms within the firewall process.

Additionally, Python is widely used in the fields of cybersecurity and artificial intelligence, making it suitable for developing prototype systems that involve security enforcement and automated decision-making processes.

Flask Framework

Flask is used as the web framework for implementing the AI Data Access Firewall. It provides essential functionalities such as routing, which enables the definition of interactions between different components of the web application, as well as request handling and response management. These features make Flask suitable for implementing the intermediary control layer that operates between the AI chatbot and the document repository.

Furthermore, Flask is a lightweight framework that is well suited for prototype development and small-to-medium-scale applications. For these reasons, Flask was selected as the primary framework for developing this system.

Text Files File-Based Storage

The system stores information in the form of structured text files, which are used as file-based storage to represent the document repository and maintain records of system activities. This approach was selected to keep the implementation lightweight while still supporting controlled document access and logging functionality. The repository of classified documents and access logs can therefore be represented using text files within the prototype environment. A full database management system is not required because the objective of this project is to validate the concept of the proposed access control mechanism rather than to process data within a large-scale enterprise environment.

Visual Studio Code

The development environment used for writing, testing, and debugging the project code is Visual Studio Code (VS Code). It provides features such as syntax highlighting, extension support, and an integrated terminal, which make it efficient for software development and code management.

Web Browser

The Flask-based web interface is tested and accessed using a standard web browser. This allows the simulation of interactions between users and the AI system during the development and evaluation phases of the project.

2.3.3 Hardware requirements

The AI Data Access Firewall prototype can be configured to run on standard personal computing hardware. The system requires a computer with a minimum of 8 GB of RAM, a dual-core processor or higher, and sufficient storage capacity to run the development environment and store project files. As the system is developed using Python and Flask, it does not require specialised hardware such as dedicated servers, GPUs, or enterprise-level infrastructure.

A stable internet connection may be required to download the necessary software libraries and development tools. However, once the system is installed, it can operate in an offline environment. These hardware requirements are sufficient to support the backend processing, file-based storage, and logging mechanisms required for the implementation of the prototype.

2.3.4 Justification

The choice of Python, Flask, and file-based storage can be justified by the scope and objectives of the project. Since the AI Data Access Firewall is intended to function as a prototype for testing AI-specific access control principles rather than a full enterprise implementation, a simplified and manageable technology stack is appropriate. Python provides strong support for implementing rule-based access control logic and file-processing operations, while Flask enables the development of a basic web-based interface to simulate interactions between the AI system and the document repository.

File-based storage, implemented through structured text files, is sufficient to demonstrate document classification and logging mechanisms without introducing the additional complexity of a database management system. The selected tools allow the system to focus on evaluating AI-generated requests, enforcing access control policies, and recording system interactions. These capabilities directly support the primary objective of the project, which is to prevent unauthorised AI access to sensitive corporate data. Furthermore, the selected hardware and software environment ensures that the system remains feasible within the time and technical constraints of an undergraduate Final Year Project.

Chapter 3: Methodology

3.1 System Development Methodology

3.1.1 Introduction

A system development methodology provides a structured framework for planning, designing, implementing, and evaluating a software system. Selecting an appropriate methodology ensures that the development process remains organised, controlled, and aligned with the project objectives.

For the AI Data Access Firewall prototype, a structured yet flexible methodology is required due to the security-focused and rule-based nature of the system. The development process must support iterative refinement of access control policies, document classification mechanisms, and enforcement logic, while maintaining consistency and predictability in system behaviour.

3.1.2 Methodology Selection and Justification

For the development of the AI Data Access Firewall prototype, the Agile methodology was selected. Agile is an iterative and incremental approach to software development that allows systems to be developed and improved in smaller stages rather than completing the entire process in a single sequence. This approach is suitable for the nature of this project, which involves refining access control logic and security mechanisms through repeated testing and adjustments. During the planning stage, other methodologies such as the Waterfall model were also considered. The Waterfall approach follows a linear structure in which each phase must be completed before moving to the next stage. While this model provides clear documentation and structured development phases, it offers limited flexibility once development has begun. For a security-focused prototype such as the AI Data Access Firewall, requirements such as role mappings, document sensitivity levels, and enforcement rules may need to be refined after testing different scenarios. A rigid sequential model would make such refinements more difficult to implement. Agile, on the other hand, allows development to take place in cycles. Individual components of the system can be implemented and tested separately before being integrated into the full architecture. This is particularly useful in this project because:

- Access control rules may need to be modified after evaluating different security test cases.
- Document classification levels may require refinement during implementation.

- The enforcement logic must be tested against simulated unauthorised access attempts.
- Logging mechanisms must be verified to ensure all AI Requests are properly recorded.

Another important consideration is the limited timeframe of an undergraduate Final Year Project. Agile supports manageable development stages, which help reduce development risks and allow problems to be identified and resolved earlier in the development process. By applying Agile principles, the core modules of the system, including the RBAC policy engine, AI Request evaluation logic, logging component, and optional redaction mechanisms—were developed incrementally and validated step by step. This approach improves system stability and ensures that security controls function consistently.

3.1.3 Requirement Analysis Phase

The Requirement Analysis phase focused on identifying and defining the functional and non-functional requirements of the AI Data Access Firewall. This phase ensured that the system design was directly aligned with the security challenges and objectives identified in the earlier chapters. Functional requirements were derived from the literature review, the identified threat model, and the data gathering activities. The system was required to evaluate AI Requests before document retrieval, enforce Role-Based Access Control (RBAC), classify documents according to sensitivity levels, apply deterministic access decisions (Allow, Deny, Allow with Redaction), and maintain comprehensive logging of all access attempts.

In addition to functional requirements, non-functional requirements were also considered. These include system reliability, consistency of access decisions, security integrity, usability within a prototype environment, and traceability through logging mechanisms. The system was designed to operate predictably and independently of AI-generated variability, ensuring that enforcement decisions remain rule-based and transparent.

During this phase, key system elements were formally defined, including:

- User roles and associated clearance levels
- Document sensitivity classifications (Public, Internal, Confidential, Restricted)
- Policy evaluation logic
- Logging and monitoring requirements

By clearly defining these requirements before system design and implementation, the project ensured that the resulting architecture directly addresses the identified security gap in AI-to-data interactions. This structured approach supports both technical validity and alignment with the overall project objectives.

3.1.4 System Design Phase

The System Design phase focuses on outlining the overall architecture and structure of the AI Data Access Firewall before implementation begins. The aim of this phase is to translate the previously identified functional and non-functional requirements into a practical system structure capable of securely managing AI-to-data interactions.

During this phase, the system was intentionally designed to operate as an intermediary control layer between a simulated AI chatbot and a corporate document repository. The core concept of this architecture is that no document should be accessed directly by the AI component without first passing through a dedicated evaluation mechanism. In other words, every AI Request must be inspected and validated before any document retrieval action takes place.

The system flow was therefore organised in the following sequence:

User Prompt → Simulated AI Chatbot → AI Request → AI Data Access Firewall (Policy Decision Point) → Document Repository → Logging Module → Response to User

This structured flow ensures that document access is never immediate or automatic. Instead, access decisions are made prior to retrieval, and all AI Requests are consistently recorded for monitoring and auditing purposes. This approach reinforces controlled access and supports accountability.

Several essential components were defined as part of the system architecture:

Role-Based Access Control (RBAC) Policy Engine

This component evaluates whether the requesting user's role provides sufficient clearance to access a specific document.

Document Sensitivity Classification Model

Corporate documents are categorised into predefined sensitivity levels (Public, Internal, Confidential, and Restricted). These classifications determine which roles are permitted access.

Enforcement Mechanism

The enforcement logic applies deterministic decisions based on predefined rules. Depending on the evaluation outcome, the system may Allow, Deny, or Allow with Redaction.

Logging and Monitoring Module

All AI Requests, access decisions, user roles, and timestamps are recorded to maintain traceability and support auditing.

File-Based Document Repository

A structured file-based storage model is used to simulate a corporate document environment within the prototype implementation. An important design consideration during this phase was the separation of responsibilities. The simulated AI chatbot is responsible only for generating structured AI Requests derived from user prompts. It does not have direct authority to retrieve documents. The firewall, acting as the Policy Decision Point, is the only component permitted to make access decisions. This separation ensures that security enforcement remains independent from AI-generated outputs and reduces the risk of uncontrolled data exposure.

Overall, the System Design phase establishes a clear and controlled architecture that directly addresses the AI-specific access control challenges identified in earlier chapters. By defining component responsibilities and request flow prior to implementation, the system is structured to maintain transparency, enforce security policies consistently, and support secure AI-driven document retrieval.

3.1.5 Development Phase

The Development phase focuses on transforming the planned system architecture into a functional prototype of the AI Data Access Firewall. At this stage, the theoretical design and defined requirements are translated into actual system functionality using the selected development tools. The prototype was developed using Python to implement the backend logic, while the Flask framework was used to manage routing, request processing, and communication between system components. In accordance with the Agile methodology selected earlier, development was carried out in small and manageable stages. Rather than building the entire system at once, each component was implemented individually, tested, and gradually integrated into the overall system structure.

The implementation began with the document classification structure. Corporate documents were organised according to predefined sensitivity levels: Public, Internal, Confidential, and Restricted. Each document was assigned a classification label to enable consistent rule-based access evaluation later in the process.

Once the classification model was established, the Role-Based Access Control (RBAC) policy engine was developed. This module compares the requesting user's role with the sensitivity level of the requested document to determine whether access should be granted. The decision-making logic was implemented using deterministic rules to ensure that outcomes remain consistent and predictable, without being influenced by AI-generated variability.

After the policy engine was operational, the enforcement mechanism was integrated into the system. Based on the evaluation result, the firewall generates one of three possible outcomes:

- Allow access
- Deny access
- Allow access with redaction

The redaction functionality was implemented to mask sensitive sections of a document when partial access is permitted under predefined conditions. This mechanism provides an additional layer of control, particularly in situations where limited information sharing is permitted. A logging module was also developed during this phase. This component records key details of every AI Request, including the user role, requested document identifier, access decision, and timestamp. The purpose of this module is to ensure traceability and support monitoring and auditing within the prototype environment.

Both the document repository and access logs were implemented using structured file-based storage. This approach keeps the system lightweight and manageable while still demonstrating the intended access control and monitoring capabilities. Since this project focuses on prototype validation rather than enterprise deployment, a complex database management system was not required.

Throughout development, each module was tested individually before being integrated into the full system workflow. This incremental implementation approach helped reduce errors and allowed early detection of inconsistencies in policy evaluation and enforcement logic.

By the conclusion of this phase, the conceptual system design had been successfully implemented as a functional prototype capable of evaluating AI Requests and enforcing Role-Based Access Control within a controlled testing environment.

3.1.6 Testing Phase

The Testing phase was conducted to verify that the AI Data Access Firewall operates in accordance with the defined functional and security requirements. The main objective of this stage was to ensure that AI Requests are evaluated correctly and that access control decisions remain consistent and reliable across different scenarios.

To achieve this, a set of predefined test cases was created to simulate both expected user behaviour and potential misuse. These test scenarios were derived from the AI-specific threats discussed in Chapter 2 and were designed to examine how the system responds under different access conditions.

The first group of tests focused on authorised access. Users with appropriate role clearance attempted to retrieve documents within their permitted sensitivity levels. In these situations, the system was expected to grant access and accurately record the interaction in the log file.

The second group of tests involved unauthorised access attempts. Users with insufficient clearance attempted to access documents classified above their permitted sensitivity level. The firewall was expected to deny these requests and ensure that each denied attempt was properly recorded in the system logs.

Further testing examined over-broad retrieval attempts. These scenarios involved vague or excessive document requests that could potentially lead to unintended data exposure. The system was evaluated to confirm that access decisions remained strictly aligned with predefined role and sensitivity rules without expanding beyond permitted boundaries. Although the prototype does not integrate a live Large Language Model (LLM), prompt manipulation scenarios were simulated by modifying structured AI Requests. This approach was used to represent attempts to bypass policy rules through crafted inputs. The results confirmed that access decisions were determined solely by deterministic role-to-sensitivity mappings rather than by the textual content of the prompt. The redaction mechanism was also tested in situations where partial access was permitted. In these cases, restricted sections of documents were expected to be masked appropriately before being returned to the user. Finally, the logging component was reviewed to ensure that every AI

Request—whether approved or denied—was recorded with complete details, including user role, document identifier, decision outcome, and timestamp.

Overall, the testing phase demonstrated that the system consistently enforces access control rules and prevents unauthorised document retrieval within the controlled prototype environment.

3.1.7 Evaluation and Refinement Phase

After completing the testing activities, an evaluation phase was conducted to assess how effectively the AI Data Access Firewall prototype performs within its defined scope. The main objective at this stage was to determine whether the system meets the goals outlined in Chapter 1, particularly with respect to preventing unauthorised AI access to sensitive corporate documents. The evaluation involved reviewing the results of the previously defined test scenarios. Particular attention was given to the consistency of access decisions across different combinations of user roles and document sensitivity levels. The system was assessed to confirm that unauthorised requests were reliably denied, authorised requests were handled correctly, and logging records were generated accurately in each case.

The Role-Based Access Control (RBAC) mappings were carefully reviewed to ensure that role clearance levels were correctly aligned with document classifications. During this review, minor refinements were introduced to improve clarity within the rule definitions and eliminate potential ambiguities. These adjustments were necessary to maintain a strictly deterministic decision-making process and ensure that outcomes remained predictable.

The redaction mechanism was also re-evaluated to verify that restricted information was consistently masked without affecting sections of content that users were authorised to access. In addition, the logging component was examined to confirm that all AI Requests—whether approved or denied—were fully recorded with accurate details, thereby supporting traceability and accountability.

Overall, the evaluation confirmed that the prototype operates as intended within the controlled development environment. Where minor inconsistencies were identified, they were addressed through incremental refinements in line with the Agile methodology adopted for the project. This

final review stage strengthened the overall stability of the system and reinforced its ability to enforce AI-specific access control in a structured and policy-driven manner.

3.2 Data Gathering Design

The data gathering stage was conducted to support the identification and validation of system requirements for the AI Data Access Firewall. Although the project focuses on developing a technical security prototype, understanding user awareness, organisational concerns, and existing perceptions regarding AI-related security risks is important for defining practical and relevant system requirements.

To achieve this, a quantitative survey method was selected as the primary data gathering technique. The survey was designed to collect measurable data regarding participants' understanding of AI security risks and their perceptions of AI-specific access control mechanisms. All data collection activities were conducted in alignment with the project objectives and received the required ethical approval prior to distribution.

3.2.1 Data Gathering Technique – Survey

A structured online questionnaire was used as the primary quantitative data gathering tool. The survey was designed to measure awareness of AI-related security risks, perceptions of data leakage threats, and acceptance of AI-specific access control mechanisms.

A minimum of thirty (30) participants was targeted in accordance with the university requirement. The survey was distributed to individuals with basic knowledge of organisational systems and AI technologies, including students enrolled in computing-related programmes and individuals working in IT or administrative roles.

The questionnaire consisted of twenty (20) closed-ended questions measured using a five-point Likert scale:

- Strongly Agree
- Agree
- Neutral
- Disagree
- Strongly Disagree

The questions were divided into five thematic sections, each aligned with one project objective:

1. Awareness of corporate data sensitivity and document classification
2. Limitations of traditional security mechanisms

3. AI-specific security risks (e.g., prompt manipulation, indirect access)
4. Importance of monitoring and logging AI interactions
5. Acceptance of an AI Data Access Firewall solution

Each objective was supported by four questions, resulting in a total of twenty questions. Demographic information such as age group, occupation, and familiarity with AI systems was also collected and is presented in the appendix.

3.2.2 Questionnaire Design

The questionnaire was designed to align directly with the objectives of the AI Data Access Firewall project. A structured format was adopted to ensure clarity, consistency, and ease of analysis. The instrument consists of twenty (20) closed-ended questions measured using a five-point Likert scale: Strongly Agree, Agree, Neutral, Disagree, and Strongly Disagree.

The Likert scale format was selected because it allows participants to express varying levels of agreement while enabling quantitative analysis of responses. This structure supports statistical summarisation of results and facilitates comparison across thematic sections.

The questionnaire was organised into five thematic sections, each corresponding to a specific objective of the AI Data Access Firewall project. Each section contains four questions, resulting in a total of twenty questions. This structure ensures balanced and systematic coverage of all research objectives.

Section A: Corporate Data Sensitivity and AI Access Awareness

This section evaluates participants' understanding that AI systems can access large volumes of organisational data and that corporate documents should be classified based on sensitivity levels. It also examines whether AI systems should have unrestricted access to all company documents and whether sensitive documents require additional protection before being accessed by AI tools.

Section B: Traditional Security Mechanisms and Their Limitations

This section assesses perceptions regarding traditional security mechanisms such as authentication systems and network firewalls. It examines whether these mechanisms are primarily designed to control human access and whether they are sufficient to regulate AI-driven data access.

Section C: AI-Specific Security Risks

This section focuses on awareness of risks associated with AI systems, including the possibility of unintentional exposure of confidential information and the use of natural language prompts to indirectly retrieve restricted data. It evaluates participants' understanding of how AI behaviour differs from human-controlled access.

Section D: Monitoring, Logging, and Real-Time Control

Questions in this section measure whether participants believe that organisations should monitor AI interactions with internal documents. It also evaluates support for logging AI access attempts, maintaining audit trails, and implementing real-time control mechanisms to prevent data leakage.

Section E: Acceptance of AI Data Access Firewall Solution

This final section measures participant support for implementing a system that evaluates AI Requests before accessing data. It assesses perceptions regarding the effectiveness of an AI-specific firewall in reducing data leakage risks and its suitability, particularly for small and medium-sized enterprises.

The questionnaire was reviewed to ensure clarity, relevance, and alignment with the project objectives prior to distribution. Ethical approval was obtained prior to data collection, and participants were informed that their responses would remain anonymous and used solely for academic research purposes.

The complete list of questionnaire items is provided in Appendix B and participant demographic information, and detailed survey response distributions are presented in Appendix C.

3.3 Analysis

3.3.1 Survey Response Overview

A total of 31 responses were collected from participants with varying levels of experience in computing, cybersecurity, and related fields. The demographic results indicate that the majority of respondents were within the 18–25 age group (82.8%), followed by those aged 26–35 years (13.8%), while a small proportion belonged to the 36–45 age group (3.4%). No participants were recorded in the 46 and above age category.

In terms of professional roles, 57.1% of respondents were students enrolled in cybersecurity or IT-related programmes. The remaining participants included IT professionals, security professionals, software developers, and students from other disciplines such as accounting and fintech. Regarding experience in IT or cybersecurity, 50% of respondents reported having less than one year of experience, while 39.3% indicated between one and three years of experience. A smaller proportion reported four to six years of experience (7.1%), and 3.6% reported more than six years of experience. Participants were also asked whether their organisations use AI tools such as chatbots or AI assistants. The results showed that 71.4% confirmed that AI tools are used within their organisations, 25% responded "Maybe," and 3.6% indicated that their organisation does not currently use AI tools.

These findings suggest that the majority of respondents have at least basic exposure to AI technologies and computing environments, making them suitable participants for evaluating awareness of AI-related security risks. Summary charts illustrating the distribution of responses for each questionnaire item are provided
in **Appendix C**.

3.3.2 Analysis by Thematic Sections

Section A: Corporate Data Sensitivity and AI Access Awareness

The results indicate a strong level of awareness among participants regarding the sensitivity of corporate data and the potential risks associated with AI access. For the statement that AI systems can access and process large volumes of organisational data, 53.6% of respondents strongly agreed and 42.9% agreed, while only a small proportion disagreed.

Similarly, when asked whether corporate documents should be classified according to sensitivity levels such as public, confidential, or restricted, 57.1% of respondents strongly agreed and 21.4% agreed, demonstrating broad support for structured document classification.

Participants also recognised the risks associated with unrestricted AI access. For the statement that AI systems should not have unrestricted access to all company documents, 51.9% strongly agreed and 22.2% agreed.

In addition, the majority of respondents believed that sensitive documents require additional protection before being accessed by AI systems. A total of 67.9% strongly agreed and 25% agreed, indicating strong support for implementing protective controls around AI-driven document access.

Section B: Limitations of Traditional Security Mechanisms

Participants generally recognised that traditional security systems are primarily designed to manage human access rather than AI interactions. For the statement that traditional security systems such as firewalls and authentication mechanisms mainly control human access, 40.7% strongly agreed and 40.7% agreed.

Similarly, when asked whether traditional access control systems evaluate AI-generated requests, responses indicated awareness of a limitation. 29.6% strongly agreed and 44.4% agreed that existing systems do not properly evaluate AI-generated requests. These findings suggest that respondents recognise the limitations of traditional security mechanisms in AI-driven environments.

Section C: AI-Specific Security Risks

Responses in this section highlight an increasing awareness of AI-related security risks among participants. For the statement that AI systems can unintentionally expose confidential information, 46.4% of respondents strongly agreed and 25% agreed. Participants also acknowledged the possibility of indirect data exposure through natural language interactions. For the statement that natural language prompts can be used to retrieve restricted information through AI systems, 38.5% strongly agreed and 38.5% agreed, while 23.1% remained neutral. These results indicate that respondents recognise the potential for AI systems to expose sensitive information even without direct access to restricted documents.

Section D: Monitoring, Logging, and Real-Time Control

Participants expressed strong support for monitoring and accountability mechanisms related to AI interactions with corporate data. For the statement that organisations should monitor AI interactions with internal documents, 50% of respondents strongly agreed and 34.6% agreed. Similarly, respondents supported the importance of logging and auditing mechanisms. For example, 46.4% strongly agreed and 39.3% agreed that logging AI access attempts improves transparency and accountability.

Participants also agreed that real-time control mechanisms are necessary to prevent data leakage. A total of 51.9% strongly agreed and 29.6% agreed that organisations should implement real-time control over AI data access. These results highlight strong support for monitoring, logging, and controlling mechanisms within AI-driven environments.

Section E: Acceptance of AI Data Access Firewall Solution

The final section measured participant acceptance of the proposed AI Data Access Firewall concept. The results showed strong support for implementing a system that evaluates AI requests before data retrieval. A total of 50% of respondents strongly agreed and 46.2% agreed that such a system would improve organisational security.

Participants also supported the idea that an AI-specific firewall could reduce the risk of data leakage. In this case, 44.4% strongly agreed and 40.7% agreed, indicating a strong perception of the system's potential effectiveness.

In addition, respondents recognised the importance of affordable security solutions for smaller organisations. A total of 33.3% strongly agreed and 37% agreed that small and medium-sized enterprises require accessible AI security solutions.

Finally, when asked whether they would support implementing an AI Data Access Firewall within their organisation, 48.1% strongly agreed and 40.7% agreed, demonstrating strong acceptance of the proposed system concept.

3.3.3 Final User Requirements Derived from Analysis

Based on the survey findings, several user requirements were identified to guide the design of the AI Data Access Firewall prototype. First, respondents demonstrated strong awareness of the importance of document sensitivity classification, indicating that corporate data should be organised according to clearly defined sensitivity levels.

Second, participants recognised that traditional security mechanisms are insufficient for regulating AI-generated requests. This finding suggests the need for an additional control layer capable of evaluating AI-to-data interactions before information is retrieved. Third, the results highlight the importance of monitoring and accountability mechanisms. Participants strongly supported the use of logging and audit trails to track AI access attempts and

improve transparency.

Finally, respondents expressed strong support for implementing a dedicated AI-specific access control solution. This feedback supports the development of the proposed AI Data Access Firewall as a mechanism for controlling AI-driven document access within organisational environments.

3.4 Proposed System Architecture

The overall architecture of the proposed system is illustrated in **Figure 2**. The architecture positions the AI Data Access Firewall as a mandatory control point between the AI chatbot interface and the organisational document repository. This design ensures that all AI-generated document requests pass through the firewall before any retrieval operation is permitted. By enforcing policy evaluation at this stage, the system prevents direct interaction between the AI component and sensitive corporate data.

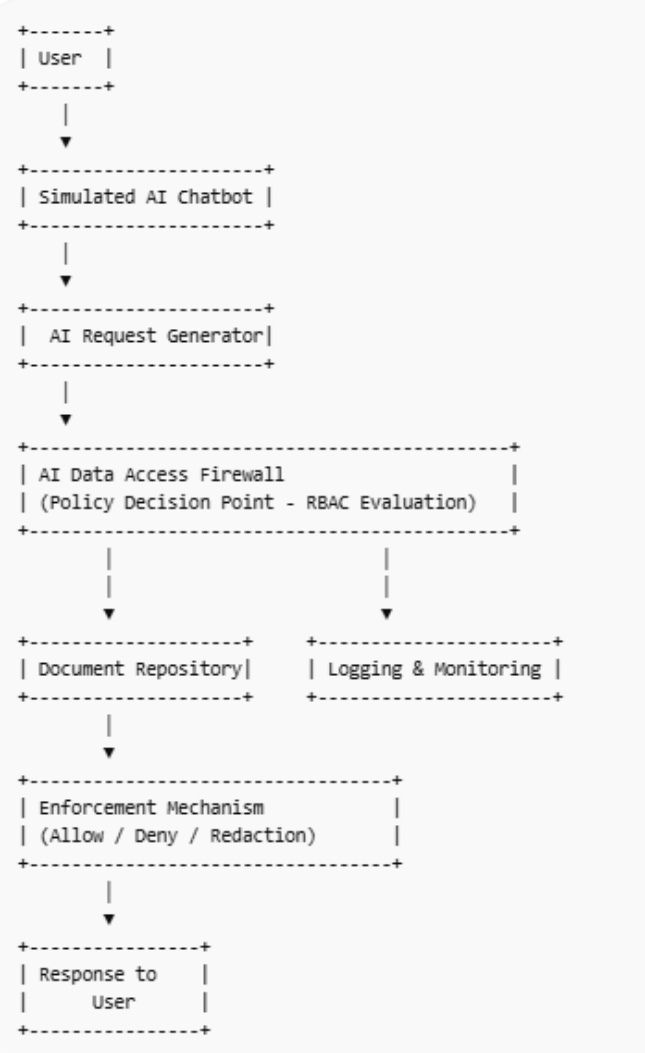


Figure 2: Proposed AI Data Access Firewall System Architecture

The system boundary is strictly defined. The firewall operates only between the AI component and the document storage layer. User authentication and identity verification are assumed to be handled externally and are therefore outside the scope of this project.

The overall architecture consists of the following core components:

- User Interface (Simulated AI Chatbot)
- AI Request Generator
- AI Data Access Firewall (Policy Decision Point)
- Document Repository
- Enforcement Mechanism
- Logging and Monitoring Module

The architecture ensures a clear separation of responsibilities between system components. The simulated AI chatbot is responsible only for receiving user prompts and generating structured AI Requests. It does not perform any access control decisions.

All access control logic is handled exclusively by the AI Data Access Firewall, which functions as the Policy Decision Point (PDP) (OASIS, 2013). The firewall evaluates each AI Request against predefined Role-Based Access Control (RBAC) policies and document sensitivity classifications. Only after a policy decision is made does the system proceed to retrieve a document from the repository. If access is denied, no document retrieval occurs. If access is partially permitted, redaction rules are applied before the response is returned to the user.

This architecture ensures that:

- No document can be accessed without policy evaluation
- Access control decisions are deterministic and rule-based
- Logging occurs regardless of the access outcome
- AI-generated requests cannot bypass the enforcement layer

By positioning the firewall as a mandatory checkpoint between AI systems and corporate data, the architecture enforces controlled and auditable AI-to-data interactions within the simulated environment. This design ensures that all AI-to-data interactions are subject to deterministic policy enforcement, thereby reducing the risk of unauthorised document retrieval and improving organisational visibility through comprehensive access logging. The overall architecture of the proposed AI Data Access Firewall is illustrated in **Figure 2**.

3.4.1 Security Assumptions

The proposed AI Data Access Firewall operates under several defined security assumptions within the prototype environment. First, user authentication and identity verification are assumed to be handled by an external system. The firewall receives structured AI Requests that already contain verified user role information. Second, the document repository is assumed to contain correctly classified documents with predefined sensitivity labels. Incorrect classification could result in inappropriate access decisions, which is outside the scope of this prototype. Third, the simulated AI chatbot is assumed to generate structured AI Requests without bypassing the firewall interface. Direct access to the document repository by the AI component is not permitted within the system architecture.

These assumptions allow the study to focus specifically on evaluating deterministic policy enforcement between AI systems and corporate data.

3.5 System Request Flow

The system request flow defines how an AI Request is processed within the AI Data Access Firewall architecture. The purpose of this flow is to ensure that every interaction between the AI component and the document repository follows a controlled and secure sequence. The request flow operates in the following stages:

3.5.1 User Prompt Submission

The process begins when a user submits a prompt through the simulated AI chatbot interface. The prompt may request access to specific organisational information or documents.

Example: A user with the role *Employee* submits the prompt:

"*Show me the company salary records*."

3.5.2 AI Request Generation

The simulated AI chatbot converts the user prompt into a structured AI Request. In this prototype, the AI does not directly retrieve documents. Instead, it generates a request containing key elements such as:

- User role
- Requested document identifier
- Intended action (e.g., retrieve or summarise)

Example AI Request Structure:

User Role: Employee

Requested Document: Salary_Records.txt

Action: Retrieve

This structured request is then forwarded to the AI Data Access Firewall for evaluation.

3.5.3 Policy Evaluation (Policy Decision Point)

Upon receiving the AI Request, the firewall evaluates it using predefined Role-Based Access Control (RBAC) rules and document sensitivity classifications. During this stage, the system verifies:

- Whether the user's role has sufficient clearance
- Whether the requested document's sensitivity level matches the role's permissions

Example Evaluation:

Employee role clearance: Internal

Salary_Records.txt sensitivity: Restricted

No document retrieval occurs before this evaluation is completed.

3.5.4 Access Decision

Based on policy evaluation, the system generates one of three deterministic outcomes:

- **Allow** – Access is granted
- **Deny** – Access is rejected
- **Allow with Redaction** – Partial access is granted with restricted content masked

Example Outcome:

Decision = Deny

The decision is generated strictly according to predefined rules, ensuring consistent and predictable behaviour.

3.5.5 Document Retrieval and Enforcement

If access is allowed, the document is retrieved from the file-based repository. If redaction is required, restricted portions are masked before the content is returned.

If access is denied, no retrieval occurs.

Example Redaction Case:

Document contains:

- *Employee Names*
- *Salary Amounts*

- *Bank Details*

System returns:

- *Employee Names*
- *Salary Amounts*
- *Bank Details: [REDACTED]*

3.5.6 Logging and Monitoring

Regardless of the outcome, the system records the AI Request in the logging module. The log includes:

- Timestamp
- User role
- Document ID
- Decision outcome

Example Log Entry:

Timestamp: 03-03-2026 14:22

User Role: Employee

Document ID: Salary_Records.txt

Decision: Denied

This ensures traceability and supports auditing within the prototype.

3.5.7 Response to User

Finally, the processed result is returned to the user through the simulated AI chatbot interface. The response reflects the access decision enforced by the firewall.

Example:

The user receives:

If Denied:

"Access denied. You do not have sufficient clearance."

If Allowed:

Document content (with or without redaction).

3.6 Policy Engine Design

The Policy Engine forms the core decision-making component of the AI Data Access Firewall. It is responsible for evaluating every AI Request and determining whether access to a document should be granted, denied, or partially allowed. The policy engine design follows a deterministic

Role-Based Access Control (RBAC) model combined with predefined document sensitivity classifications. This approach ensures that access decisions are rule-driven and not influenced by AI-generated variability (Sandhu et al., 1996).

3.6.1 Role-Based Access Control Model

In this system, access permissions are assigned based on organisational roles. Each role is mapped to a specific clearance level.

Example role mapping:

- Employee → Internal clearance
- Manager → Confidential clearance
- HR Manager → Restricted clearance
- Administrator → Restricted clearance

Each user is assigned a role before submitting a request. The role determines the maximum sensitivity level that can be accessed.

3.6.2 Document Sensitivity Classification

All documents within the repository are classified into four predefined sensitivity levels:

- Public
- Internal
- Confidential
- Restricted

Each document stored in the repository includes a sensitivity label. This label is used by the policy engine during evaluation.

Example document classification:

- *Company_Announcement.txt → Public*
- *Internal_Memo.txt → Internal*
- *Financial_Report.txt → Confidential*
- *Salary_Records.txt → Restricted*

3.6.3 Policy Evaluation Logic

When an AI Request is received, the policy engine performs a structured comparison between:

- The user's clearance level
- The requested document's sensitivity level

The evaluation follows a simple rule:

Access is permitted only if:

User Clearance Level ≥ Document Sensitivity Level

If the document sensitivity exceeds the user's clearance, access is denied. This evaluation is fully deterministic. It does not rely on natural language interpretation or heuristic analysis. Instead, decisions are based strictly on predefined mappings and logical comparison.

This deterministic approach ensures:

- Predictable behaviour
- Elimination of ambiguity
- Prevention of policy bypass through prompt manipulation

By separating role validation from AI-generated output, the policy engine maintains independent and consistent enforcement of access control rules.

3.7 Enforcement Mechanism

The Enforcement Mechanism is responsible for executing the decision generated by the Policy Engine. While the Policy Engine determines whether access should be granted or denied, the enforcement component ensures that the decision is correctly applied before any information is returned to the user.

In the AI Data Access Firewall prototype, enforcement is deterministic and rule based. This means that once a decision is made, the system strictly follows predefined rules without deviation or interpretation. The enforcement mechanism produces one of three possible outcomes:

3.7.1 Allow

If the user's clearance level is equal to or higher than the document's sensitivity level, access is granted. The document is retrieved from the repository and returned to the user through the simulated AI chatbot interface.

Example: *A Manager (Confidential clearance) requests access to Financial_Report.txt (Confidential). Since the clearance level matches the document classification, the system allows full access.*

3.7.2 Deny

If the document's sensitivity level exceeds the user's clearance level, access is denied. In this case, the document is not retrieved from the repository. Instead, the user receives access denied message.

Example: *An Employee (Internal clearance) requests Salary_Records.txt (Restricted).*

Since Restricted is higher than Internal, the request is denied.

This ensures that no sensitive data is exposed beyond authorised boundaries.

3.7.3 Allow with Redaction

In certain cases, partial access may be permitted. When predefined policy rules allow limited visibility, sensitive sections of a document are masked before being returned to the user. The redaction mechanism replaces restricted content with a placeholder such as "[REDACTED]" while preserving permitted information.

Example: *A Manager requests a document containing:*

- *Employee Names*
- *Salary Amounts*
- *Bank Account Details*

If bank details are classified as Restricted while salary amounts are Confidential, the system may return:

- *Employee Names*
- *Salary Amounts*
- *Bank Account Details: [REDACTED]*

This approach ensures that only authorised portions of a document are visible. In this prototype, redaction rules are defined using predefined sensitivity labels assigned to specific fields within a document. For example, salary documents may contain multiple data fields such as employee names, salary amounts, and bank account details. While salary information may be classified as **Confidential**, bank account details may be classified as **Restricted**.

When a user with **Confidential** clearance requests access to such a document, the system allows retrieval but automatically masks fields classified above the user's clearance level. The identification of sensitive fields is performed through predefined keyword patterns within the document structure (e.g., "Bank Account Number", "Account Details", or "Personal Identification"). When these fields are detected and their classification exceeds the requesting role's clearance level, the enforcement mechanism replaces the content with a placeholder label such as **[REDACTED]**.

This rule-based redaction mechanism ensures that only authorised portions of the document are visible while restricted information remains protected. However, because the prototype relies on deterministic keyword-based detection rather than semantic understanding, variations in field

naming or document formatting may lead to false negatives where sensitive information is not detected by the predefined patterns.

3.7.4 Deterministic Policy Enforcement

It is important to note that enforcement decisions are not influenced by the textual content of the user's prompt. The system does not attempt to interpret intent or analyse semantic meaning. Instead, enforcement is strictly based on structured request data, predefined RBAC mappings, and document sensitivity labels.

This deterministic enforcement model prevents:

- Policy bypass through prompt manipulation
- Role confusion or privilege escalation
- Over-broad document exposure

By separating policy evaluation from enforcement and ensuring that document retrieval only occurs after a valid decision, the system maintains a secure and controlled AI-to-data interaction process.

3.8 Justification for Simulated AI

The AI Data Access Firewall prototype utilises a simulated AI chatbot rather than integrating a live Large Language Model (LLM). This design choice was made deliberately in order to maintain a clear system boundary and ensure controlled evaluation of the access control mechanism. The primary objective of this project is to design and validate an AI-specific access control layer positioned between an AI system and corporate documents. The focus is therefore on policy evaluation, enforcement logic, and prevention of unauthorised data retrieval, rather than on natural language processing or model training.

Integrating a real LLM would introduce additional complexity, including external API dependencies, unpredictable model outputs, and potential variability in request interpretation. Such factors could interfere with the controlled testing of deterministic policy enforcement. Since the purpose of this prototype is to evaluate the effectiveness of the firewall mechanism, the use of a simulated AI ensures that requests are structured and predictable during testing.

In this implementation, the simulated AI component is responsible only for converting user prompts into structured AI Requests. It does not perform independent document retrieval or access

control decisions. All security-related evaluations are handled exclusively by the AI Data Access Firewall, which functions as the Policy Decision Point.

This separation of responsibilities strengthens the validity of the evaluation. By isolating the access control mechanism from AI model variability, the prototype ensures that observed outcomes are directly attributable to the enforcement logic rather than to AI behaviour.

Furthermore, the use of a simulated AI aligns with the project scope and resource constraints of an undergraduate Final Year Project. It allows the study to focus on architectural design and security validation without requiring large-scale infrastructure or cloud-based model integration. Therefore, the simulated AI approach is both methodologically justified and appropriate for demonstrating the feasibility of an AI Data Access Firewall within a controlled experimental environment.

Chapter 4: Design and Implementation

4.1 Introduction

This chapter discusses the design and implementation of the proposed AI Data Access Firewall for Secure AI-to-Document Interaction with a focus on the use of Deterministic Role-Based Access Control (RBAC) Policies. The development of the proposed solution was based on the previously discussed system requirements and architecture, and a web-based prototype was developed to show the secure interaction among the user, AI assistant, and protected document repository.

This chapter introduces the system's approach to the overall design of the system, such as the system architecture, use case diagram, activity diagram, sequence diagram, and class diagram. The following design artefacts depict the proposed system before implementation and the relationships between key elements of the system. The system's implementation is then introduced, detailing each module of the system, such as the user authentication module, AI Security Assistant, RBAC policy engine, document repository and sensitivity classification, audit logging module, and system dashboard. Technology and development environment used to develop the prototype are also discussed.

Finally, it outlines the user interface implementation, showcasing the key interfaces created for the system: login page, dashboard, AI Security Assistant, Protected Documents interface, and audit centre. The interfaces show how the user interacts with the implemented security mechanisms requesting, evaluating, and accessing protected documents in a secure manner.

4.2 System Design

The system design phase outlines the blueprint of the proposed AI Data Access Firewall system. It defines the system architecture, user-system interfaces, and interconnections between the core modules prior to implementation. A well-defined system design ensures that the implemented prototype meets the functional and security requirements identified during the analysis phase.

To illustrate the proposed system, several Unified Modelling Language (UML) diagrams are presented in this section. These include the overall system architecture, use case diagram, activity diagram, sequence diagram, and class diagram. Together, these design artefacts provide a representation of the structure, behaviour, and interactions of the system, forming the basis for the

implementation presented in the following sections.

4.2.1 Overall System Architecture

The overall system architecture illustrates the major components of the proposed AI Data Access Firewall and the interactions between users, the AI Security Assistant, the firewall modules, and the protected document repository. The architecture was designed using a modular approach, allowing each component to perform a specific security function while working together to provide secure AI-to-document interaction.

The system begins with an authenticated user accessing the web application through the login interface. User credentials are verified by the authentication module before access to the system is granted. Once authenticated, users are directed to the system dashboard, where they can navigate to the AI Security Assistant to submit document requests.

When a document request is submitted, the AI Security Assistant forwards the request to the request parser. The request parser analyses the user's input, extracts the requested document name, validates the request, and blocks malicious inputs such as invalid filenames or path traversal attempts. This validation process ensures that only recognised document requests proceed to the next stage of evaluation.

After the request has been validated, it is passed to the Role-Based Access Control (RBAC) policy engine. The RBAC policy engine determines whether the requesting user's role has sufficient privileges to access the requested document according to the predefined security policies. Each document is assigned a sensitivity classification consisting of Public, Internal, Confidential, or Restricted, and the access decision is made based on both the user's role and the document's classification.

If access is authorised, the document is retrieved from the protected document repository. Depending on the RBAC decision, the requested document is either returned without modification, processed by the keyword-based redaction module before being returned, or completely denied if the user does not have the required permissions. This layered security approach prevents

unauthorised disclosure of sensitive information while allowing legitimate users to access information according to their assigned roles.

Regardless of the access decision, every document request is recorded by the audit logging module. Each audit record includes the request timestamp, username, user role, requested document, and the final security decision. These records provide accountability, support security monitoring, and enable administrators to review previous access events through the Audit Centre interface. Finally, the processed response is returned to the AI Security Assistant, where the user is presented with the access decision and the corresponding document content or security message. This architecture ensures that every document request passes through multiple security controls before any information is disclosed, thereby supporting the project's objective of preventing unauthorised AI access to organisational documents.

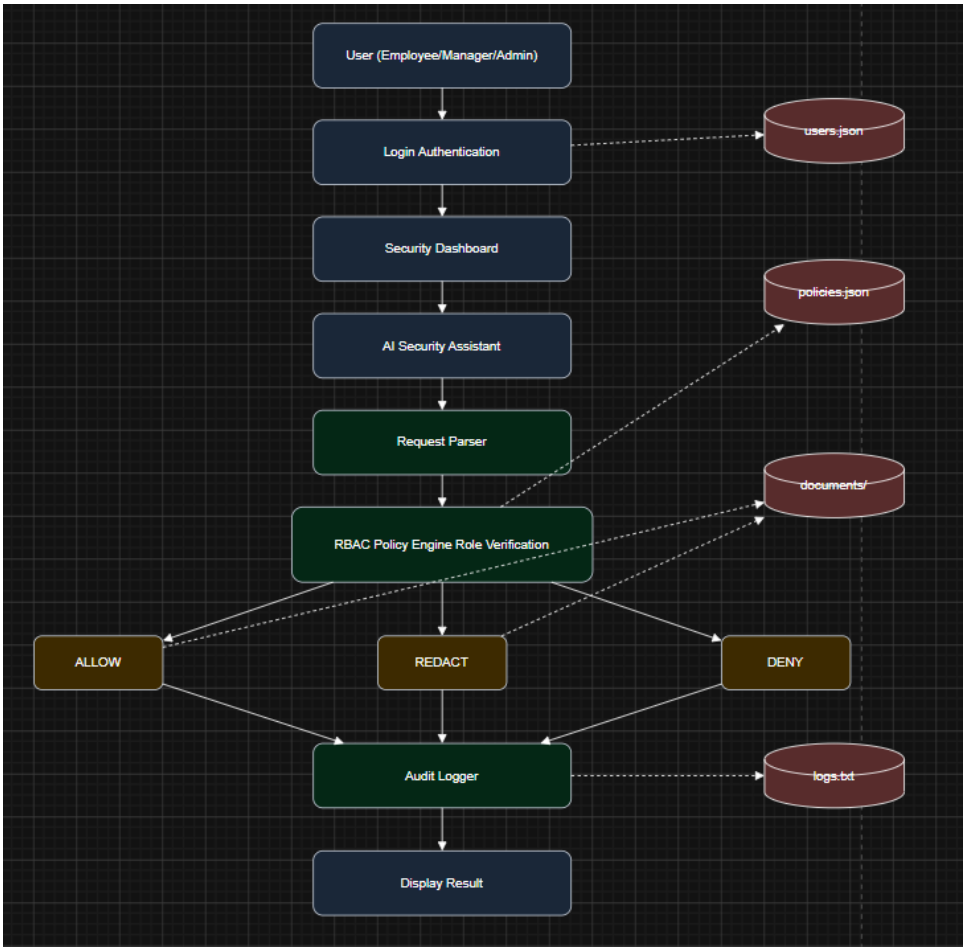


Figure 3: Overall System Architecture of the Proposed AI Data Access Firewall

Figure 3 illustrates the overall architecture of the proposed AI Data Access Firewall. The architecture consists of several interconnected modules that work together to provide secure AI-to-document interaction while enforcing deterministic Role-Based Access Control (RBAC) policies. The modular design enables each component to perform a specific security function, ensuring that every document request is evaluated before access is granted.

The process begins when a user, either an Employee, Manager, or Admin, accesses the system through the **Login Authentication** module. During authentication, the user's credentials are verified against the **users.json** file. Upon successful authentication, the user is granted access to the **Security Dashboard**, which serves as the central navigation interface for accessing the system's features.

When the user submits a document request through the **AI Security Assistant**, the request is forwarded to the **Request Parser**. This module analyses the user's input, identifies the requested document, and validates the request before forwarding it to the RBAC module for further processing. The Request Parser ensures that only recognised document requests are processed by the system.

After the request has been successfully parsed, it is passed to the **RBAC Policy Engine Role Verification** module. This component evaluates the user's access privileges by comparing the user's assigned role with the predefined security policies stored in the **policies.json** file. The requested document is then matched with its corresponding sensitivity classification within the protected **documents** repository to determine whether access should be permitted.

Based on the RBAC evaluation, the system produces one of three possible security decisions: **ALLOW**, **REDACT**, or **DENY**. An **ALLOW** decision permits the user to access the requested document without modification. A **REDACT** decision grants partial access by automatically removing predefined sensitive information before the document is returned to the user. A **DENY** decision blocks access when the user's role does not satisfy the required access permissions for the requested document.

Regardless of the access decision, every request is forwarded to the **Audit Logger**, where the request details, user information, timestamp, requested document, and security decision are recorded in the **logs.txt** file. This provides a permanent audit trail that supports accountability, monitoring, and future security investigations.

Finally, the processed result is returned to the user through the **Display Result** module. By ensuring that every document request passes through authentication, request parsing, RBAC policy verification, document classification, and audit logging, the proposed architecture provides a secure and controlled environment for AI-assisted document retrieval while reducing the risk of unauthorised access to sensitive organisational information.

4.2.2 Use Case Diagram

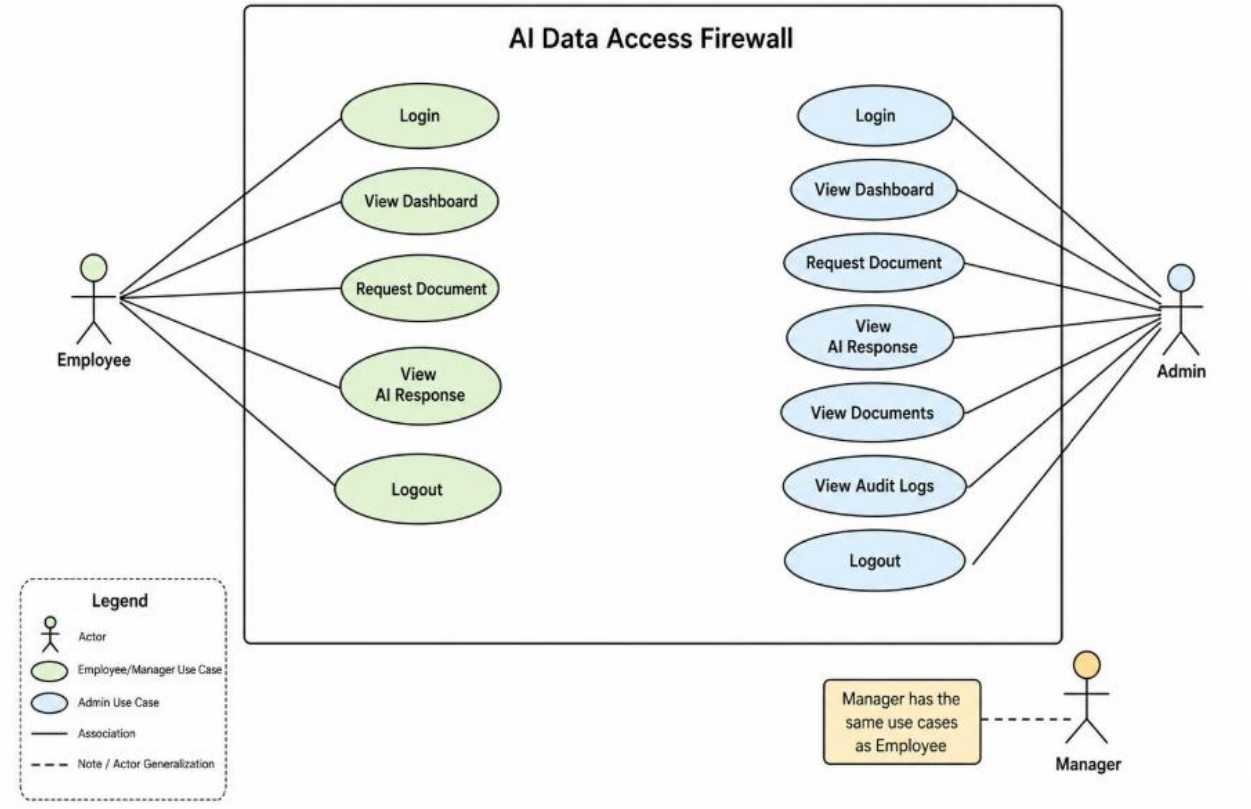


Figure 4: Use Case Diagram of the Proposed AI Data Access Firewall

Figure 4 illustrates the use case diagram of the proposed AI Data Access Firewall. The diagram identifies the interactions between the system and its three user roles: Employee, Manager, and Admin. Each actor is assigned a set of use cases based on their authorised responsibilities within the system.

The Employee represents a standard user who interacts with the system to securely access organisational documents through the AI Security Assistant. The employee is able to log into the system, view the dashboard, submit document requests, view the AI-generated response, and log out of the system. These functions provide employees with controlled access to organisational documents while ensuring that every request is evaluated according to predefined security policies.

The Manager performs the same use cases as the Employee. However, managers are assigned a higher privilege level within the Role-Based Access Control (RBAC) policy, allowing them to access additional documents or receive less restrictive responses when requesting confidential information. Although the available system functions remain the same, the RBAC policy engine determines the final access decision according to the manager's assigned role.

The Admin possesses all standard user functions in addition to administrative capabilities. Besides logging into the system, viewing the dashboard, requesting documents, viewing AI responses, and logging out, the administrator is authorised to access the Protected Documents interface and the Audit Centre. These additional functions enable administrators to review the protected document repository and monitor security events recorded by the audit logging module.

Overall, the use case diagram provides a high-level representation of the interactions between the system and its users. It demonstrates how different user roles are granted different levels of functionality while maintaining secure AI-assisted access to protected organisational documents through deterministic RBAC policy enforcement.

4.2.3 Activity Diagram

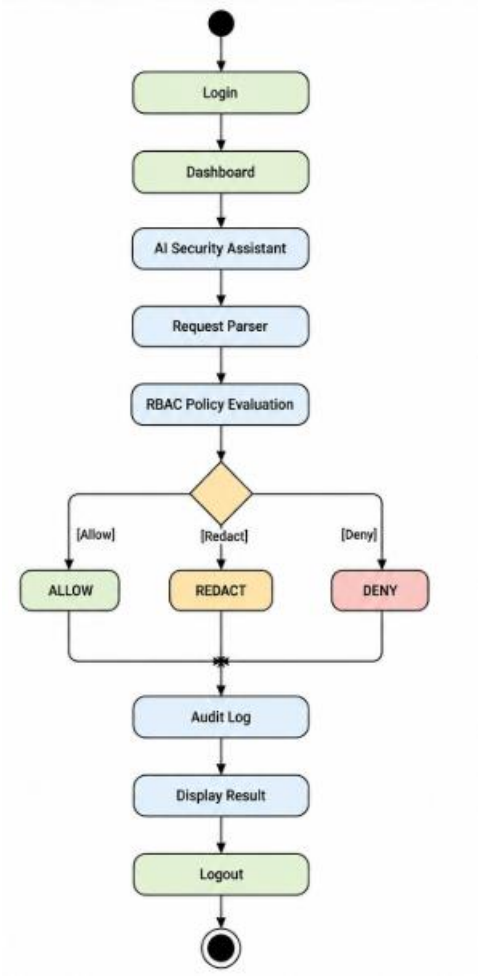


Figure 5: Activity Diagram of the Proposed AI Data Access Firewall

Figure 5 illustrates the activity flow of the proposed AI Data Access Firewall from user authentication to the completion of a document access request. The activity diagram represents the sequence of operations performed by the system and demonstrates how document requests are securely processed using deterministic Role-Based Access Control (RBAC) policies before a response is returned to the user.

The process begins when the user logs into the system using the **Login** module. Upon successful authentication, the user is redirected to the **Dashboard**, where the available system functions can be accessed. To retrieve organisational information, the user submits a document request through the **AI Security Assistant**.

The submitted request is forwarded to the **Request Parser**, which analyses the user's input and identifies the requested document. After the request has been successfully parsed, it is passed to the **RBAC Policy Evaluation** module. At this stage, the user's assigned role is compared with the predefined access control policies to determine whether the requested document can be accessed. Based on the RBAC policy evaluation, the system produces one of three possible security decisions: **ALLOW**, **REDACT**, or **DENY**. An **ALLOW** decision grants the user full access to the requested document. A **REDACT** decision returns the requested document after sensitive information has been automatically removed using the keyword-based redaction mechanism. A **DENY** decision prevents unauthorised users from accessing the requested document and returns an appropriate access denial message.

Regardless of the security decision, all document requests are recorded in the **Audit Log**. The audit log stores relevant information, including the user identity, user role, requested document, timestamp, and access decision, providing accountability and supporting future security monitoring and forensic analysis. Finally, the processed result is displayed to the user, after which the user may log out of the system, completing the activity flow.

4.2.4 Sequence Diagram

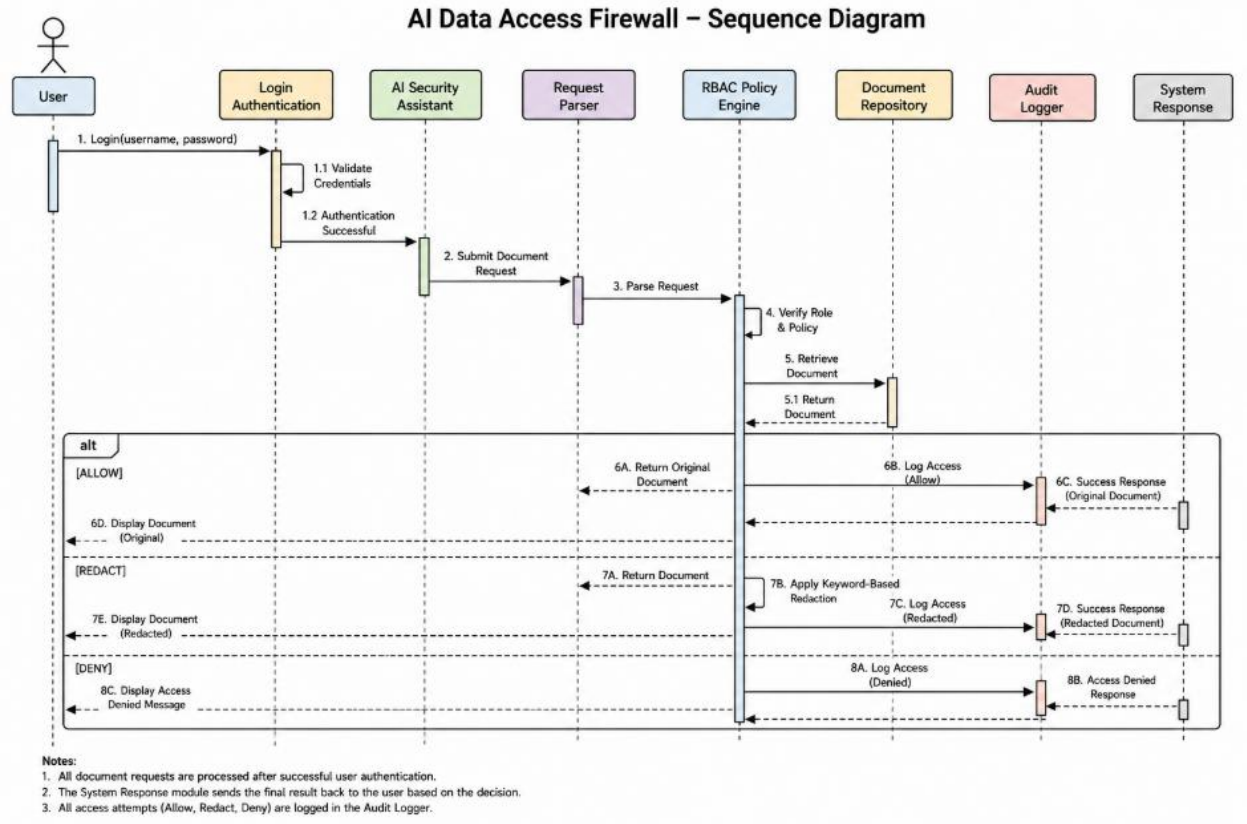


Figure 6: Sequence Diagram of the Proposed AI Data Access Firewall

The sequence diagram shown in Figure 6 illustrates the chronological interactions between the user and the major components of the proposed AI Data Access Firewall during the processing of a document access request. It demonstrates how the system coordinates authentication, request processing, access control enforcement, document retrieval, audit logging, and response generation to provide secure AI-assisted document access.

The interaction begins when the user submits login credentials through the **Login Authentication** module. The module validates the supplied username and password before granting access to the system. Once authentication is successful, the user interacts with the **AI Security Assistant** to submit a document request. The submitted request is forwarded to the **Request Parser**, which analyses the user's input to identify the requested document. The parsed request is then sent to the **RBAC Policy Engine**, where the user's assigned role is verified against the predefined access control policies. The RBAC Policy Engine subsequently retrieves the requested document from the **Document Repository** for further processing.

Following policy verification, the system enters one of three alternative execution paths. If the user satisfies the required access permission, the original document is returned without modification. If partial access is permitted, the retrieved document undergoes keyword-based redaction to remove predefined sensitive information before being returned. If the user does not possess sufficient privileges, the request is denied and an access denied response is generated.

Regardless of the final access decision, all document requests are recorded by the **Audit Logger**. The audit record includes information such as the user identity, requested document, access decision, and timestamp, ensuring that every access attempt can be monitored and reviewed. Finally, the **System Response** module returns the appropriate document or security message to the user, completing the interaction sequence.

4.2.5 Class Diagram

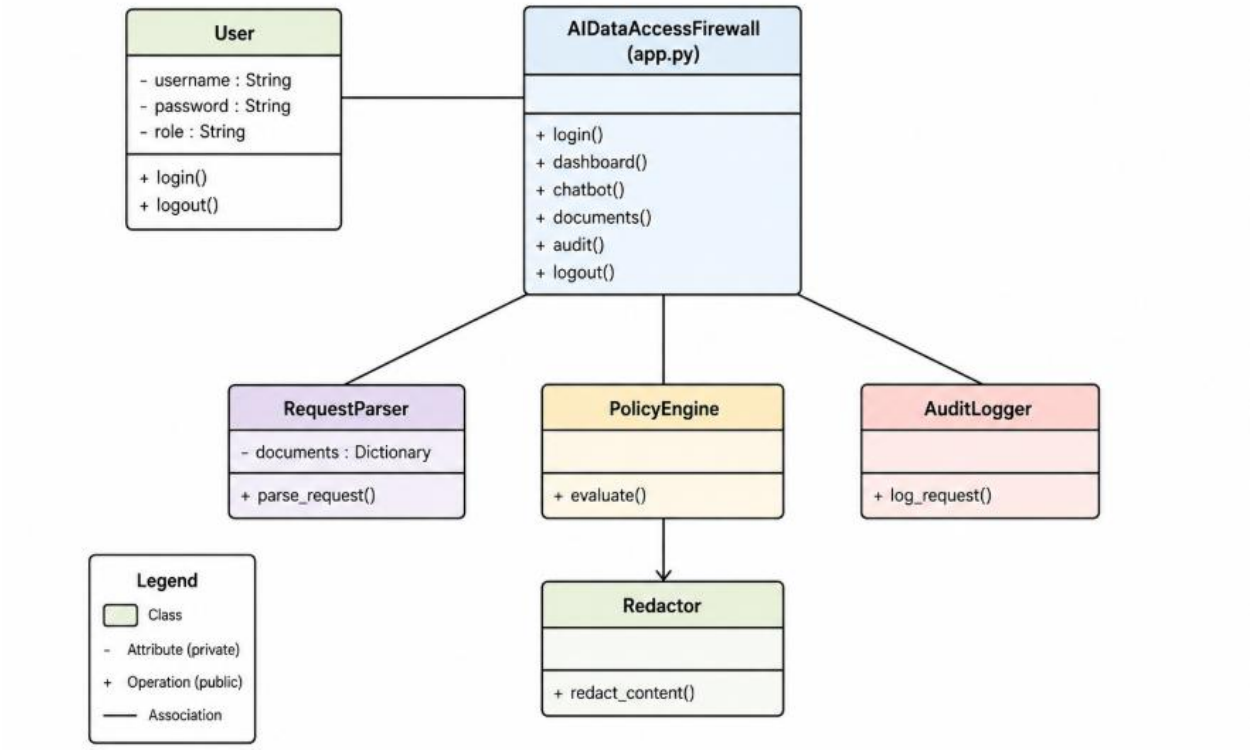


Figure 7: Class Diagram of the Proposed AI Data Access Firewall

The class diagram shown in Figure 7 illustrates the static structure of the proposed AI Data Access Firewall by presenting the principal classes and their relationships. The diagram provides an overview of the major software components responsible for user authentication, request processing, policy evaluation, content redaction, and audit logging.

The **User** class represents authenticated users of the system and stores the user's username, password, and assigned role. It also provides login and logout operations, which enable users to establish and terminate authenticated sessions.

The **AIDataAccessFirewall** class serves as the central controller of the application. It coordinates the primary system functions, including user authentication, dashboard access, AI Security Assistant operations, protected document management, audit log viewing, and user logout. This class manages the interactions between the remaining system modules throughout the document access process.

The **RequestParser** class is responsible for analysing user requests submitted through the AI Security Assistant. It identifies the requested document, validates the input, and forwards valid requests for further processing. Invalid or malicious requests are rejected before reaching the access control mechanism.

The **PolicyEngine** class implements deterministic Role-Based Access Control (RBAC) by evaluating the user's assigned role against the predefined security policies. Based on the evaluation results, the class determines whether the requested document should be allowed, redacted, or denied.

The **Redactor** class applies keyword-based redaction to sensitive document content before it is returned to authorised users. This allows partial access to confidential documents while preventing the disclosure of predefined sensitive information.

Finally, the **AuditLogger** class records every document access request together with relevant information such as the user identity, requested document, timestamp, and access decision. These audit records support accountability, security monitoring, and future forensic analysis.

Overall, the class diagram presents the structural organisation of the proposed AI Data Access Firewall and demonstrates how the principal software components collaborate to provide secure AI-to-document interaction through deterministic RBAC policy enforcement.

4.3 System Implementation

This section describes the implementation of the proposed AI Data Access Firewall based on the system design presented in the previous section. The prototype was developed as a web-based application using the Python Flask framework and incorporates deterministic Role-Based Access Control (RBAC) to regulate AI-assisted access to organisational documents. Each system module was implemented to perform a specific security function, including user authentication, request processing, policy evaluation, document retrieval, content redaction, and audit logging.

The implementation follows a modular architecture in which each component operates independently while interacting with other modules to process document requests securely. The following subsections describe the development environment, project structure, and implementation details of each core module.

4.3.1 Development Environment

Table 2: Development Environment of the Proposed AI Data Access Firewall

Component	**Description**
Programming Language	Python 3.x
Web Framework	Flask
Front-end Technologies	HTML5, CSS3, Bootstrap 5, JavaScript
Development Environment (IDE)	Visual Studio Code
Operating System	Windows 11
Data Storage	JSON Files
Document Repository	Plain Text Files
Authentication	Session-based Authentication (Flask Session)
Password Security	Werkzeug Security (Password Hashing)
Access Control	Deterministic Role-Based Access Control (RBAC)
Audit Logging	Text File (logs.txt)

The proposed AI Data Access Firewall was implemented using Python 3.x and the Flask web framework to develop a lightweight web-based prototype. HTML5, CSS3, Bootstrap 5, and JavaScript were used to develop the user interface, providing responsive web pages for user

authentication, document access, and system administration. User credentials and RBA Cpolicies were stored in JSON files, while organisational documents were maintained as plain text files organised according to their sensitivity classification. The system also incorporates session-based authentication, password hashing using the Werkzeug security library, deterministic Role-Based Access Control (RBAC), and audit logging to support secure AI-assisted document access. The selected development environment provided a simple and effective platform for implementing and evaluating the proposed AI Data Access Firewall.

4.3.2 Project Structure

The proposed AI Data Access Firewall was developed using a modular project structure to improve code organisation, maintainability, and scalability. Figure 8 illustrates the overall project directory structure, showing the organisation of the application's source code, templates, static resources, configuration files, and classified document repository. Each component of the system was implemented as a separate module with a specific responsibility, allowing the application to process document requests securely while maintaining a clear separation of concerns. The project structure also simplifies future maintenance and enhancement by isolating individual functionalities such as request parsing, policy evaluation, content redaction, and audit logging. The main application logic is implemented in the app.py file, which serves as the central controller of the system. Supporting modules, including the request parser, RBAC policy engine, redaction module, and audit logger, are implemented as separate Python files. User information and access control policies are stored in JSON files, while protected documents are organised into folders according to their assigned sensitivity levels. The user interface is implemented using HTML templates, CSS stylesheets, and JavaScript files, providing a structured and responsive web application. As shown in Figure 8 below, the modular organisation separates system components according to their functions, making the application easier to develop, maintain, and extend in future work.

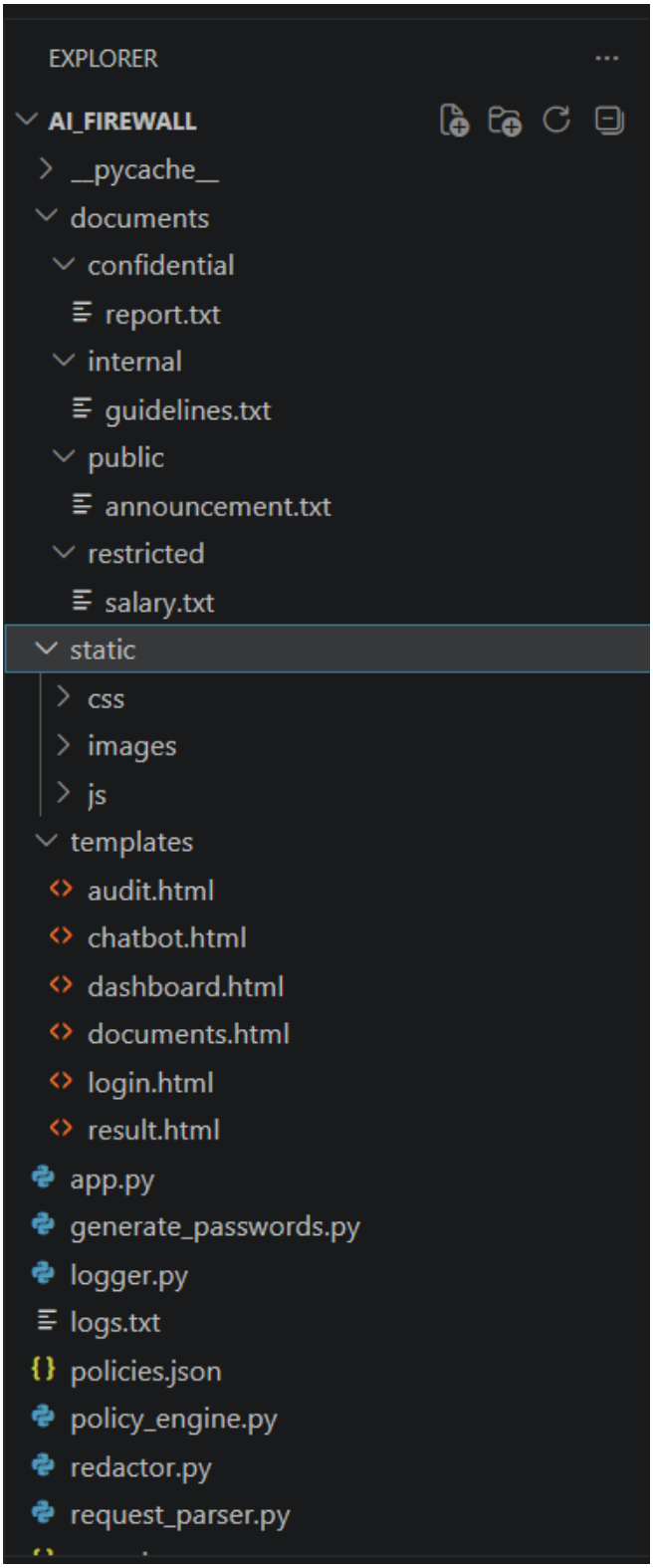


Figure 8: Project Structure of the Proposed AI Data Access Firewall

4.3.3 User Authentication Module

The **User Authentication Module** was implemented to ensure that only authorised users can access the AI Data Access Firewall. The module validates user credentials before granting access to the system and assigns the appropriate role for enforcing Role-Based Access Control (RBAC). User accounts are maintained in a JSON file containing the username, hashed password, and assigned role.

When a user submits valid login credentials through the login interface, the system retrieves the corresponding user information from the **users.json** file and verifies the password using the Werkzeug password hashing mechanism. If the authentication process is successful, a secure session is created using Flask session management. The session stores the authenticated user's username, assigned role, and login time, allowing authorised users to access the protected system modules.

To improve security, the authentication module incorporates several session protection mechanisms. Passwords are stored as hashed values rather than plain text, preventing the disclosure of user credentials. In addition, the system uses HTTPOnly cookies and SameSite cookie protection to reduce the risk of client-side attacks. User sessions automatically expire after a predefined period of inactivity, requiring users to authenticate again before accessing protected resources.

If invalid credentials are entered, the system denies access and redirects the user back to the login page without creating an authenticated session. This authentication process serves as the first layer of security within the proposed AI Data Access Firewall before any document request is processed.

The User Authentication Module contributes to the project's objective of preventing unauthorised AI access by ensuring that only authenticated users can access the system. By verifying user credentials and assigning the appropriate role, the module establishes the foundation for secure Role-Based Access Control (RBAC) throughout the application.

The User Authentication Module is the first security layer of the AI Data Access Firewall. It verifies user credentials before granting access to the system and assigns the appropriate role for enforcing Role-Based Access Control (RBAC). Figure 9 shows the secure login interface used to authenticate users before they can access the system.

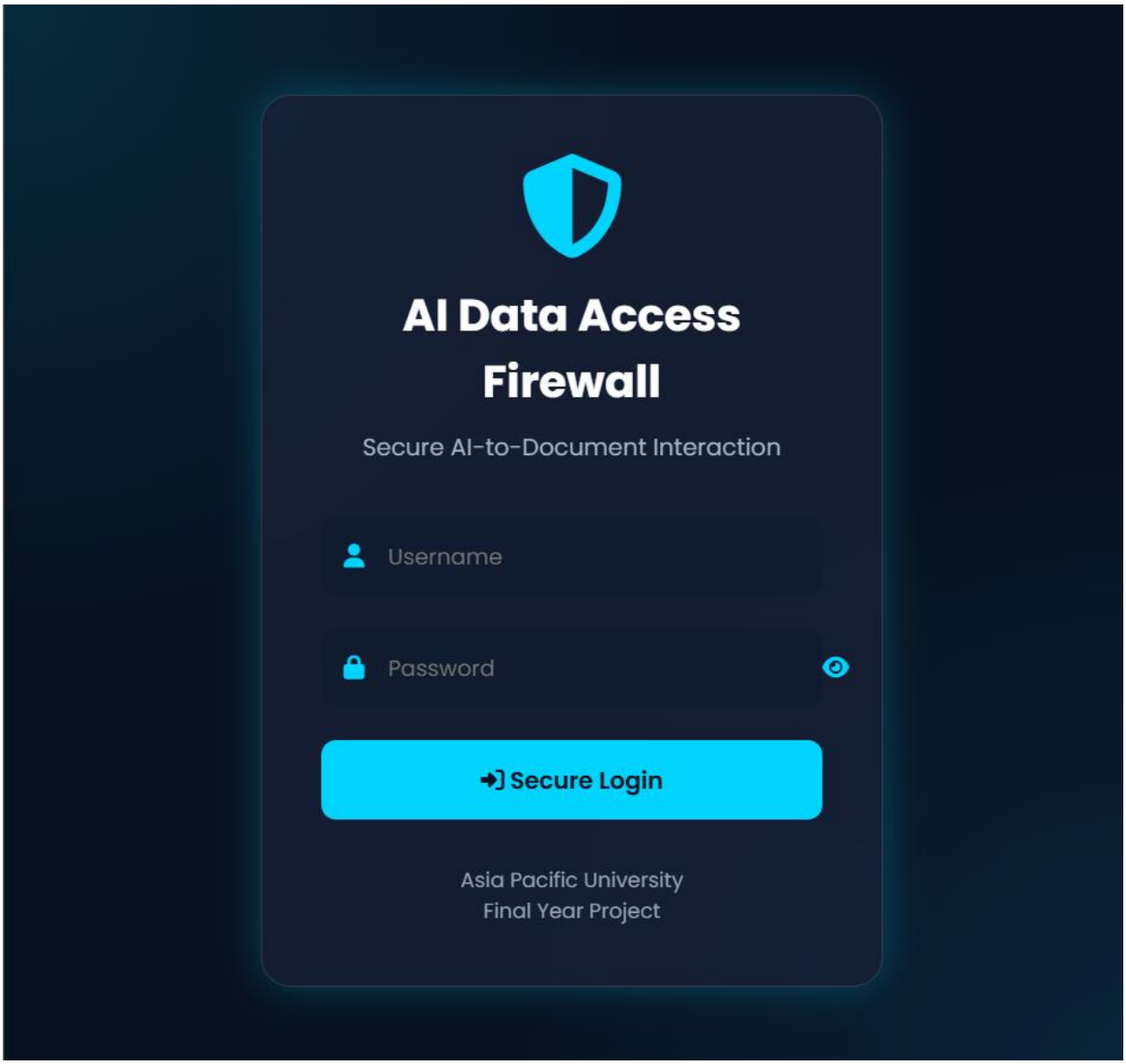


Figure 9: Login Interface of the AI Data Access Firewall

As shown in Figure 9, users are required to enter their username and password through the secure login interface. Upon successful authentication, the system establishes a user

session and grants access according to the assigned role, ensuring that only authorised users can interact with protected corporate documents.

User account information is stored in the users.json file, which contains the usernames, encrypted passwords, and assigned roles for each authorised user. This configuration enables the system to authenticate users securely while enforcing Role-Based Access Control (RBAC). Figure 10 presents the user account configuration used by the authentication module.

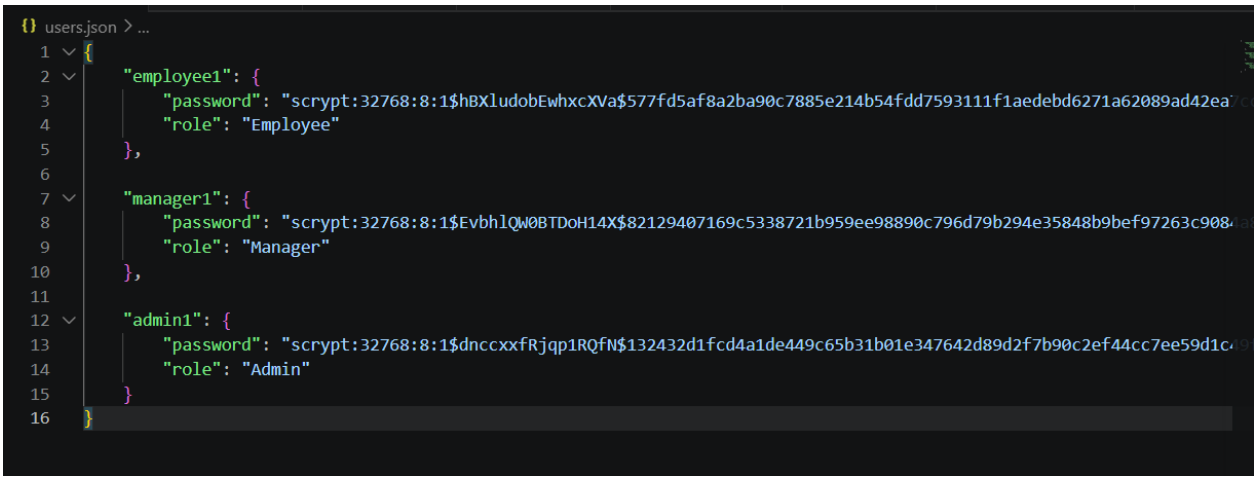
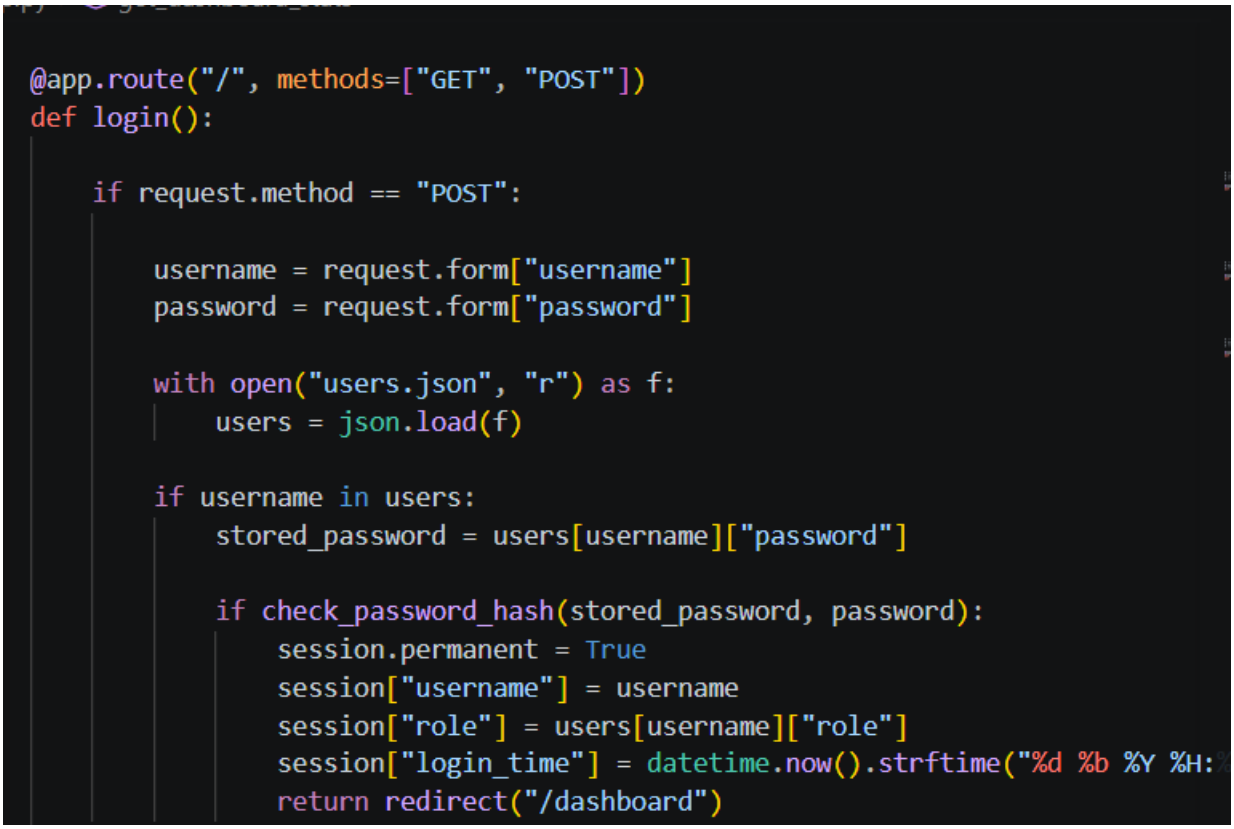


Figure 10: User Credentials Stored in users.json

As shown in Figure 10, each user is assigned a predefined role, such as Employee, Manager, or Admin, together with a securely hashed password. During login, the system validates the user's credentials and retrieves the assigned role, which is subsequently used by the RBAC Policy Engine to determine the appropriate access permissions for protected documents.

After the user submits the login credentials, the authentication module processes the request by validating the provided username and password against the stored user records. Figure 11 illustrates the implementation of the login function responsible for authenticating users and establishing secure user sessions.



```python
@app.route("/", methods=["GET", "POST"])
def login():

    if request.method == "POST":

        username = request.form["username"]
        password = request.form["password"]

        with open("users.json", "r") as f:
            users = json.load(f)

        if username in users:
            stored_password = users[username]["password"]

            if check_password_hash(stored_password, password):
                session.permanent = True
                session["username"] = username
                session["role"] = users[username]["role"]
                session["login_time"] = datetime.now().strftime("%d %b %Y %H:
                return redirect("/dashboard")
```

Figure 11: User Authentication Implementation in app.py

As shown in Figure 11, the login function retrieves user information from the users.json file and verifies the entered password using a secure password hashing mechanism. Upon successful authentication, the system creates a session containing the user's username, assigned role, and login time before redirecting the user to the dashboard. This process ensures that only authenticated users can access the AI Data Access Firewall and that subsequent document requests are evaluated according to the user's assigned role.

4.3.4 AI Security Assistant Module

The AI Security Assistant Module provides the primary interface through which users interact with the proposed AI Data Access Firewall. It enables authenticated users to submit natural language requests for organisational documents while ensuring that every request is processed through the system's security mechanisms before a response is returned. Rather than directly accessing the document repository, all user requests are routed through the AI Security Assistant, allowing the system to enforce access control and document protection policies.

When a user submits a request, the AI Security Assistant forwards the input to the Request Parser for analysis. The Request Parser identifies the requested document, validates the input, and detects invalid or potentially malicious requests, such as path traversal attempts. Requests that fail validation are immediately rejected, preventing unauthorised access to system resources. Valid requests are forwarded to the RBAC Policy Engine for access control evaluation.

After the RBAC Policy Engine determines the appropriate security decision, the AI Security Assistant displays the processed result to the user. Depending on the user's assigned role and the requested document's sensitivity level, the returned response may contain the original document, a redacted version of the document, or an access denied message. Every request processed through The AI Security Assistant is also recorded by the Audit Logging Module to maintain accountability and support future security analysis.

The AI Security Assistant interface was designed to provide simple and user-friendly interaction process. The interface includes a document request input field, suggested document requests, and a structured response panel displaying the requested file, policy decision, returned content, and security summary. This design enables users to understand the outcome of each request while demonstrating the enforcement of deterministic RBAC policies.

The AI Security Assistant Module contributes to the project's objective by providing a secure interface through which users can request protected corporate documents. Every request submitted through the interface is processed by the AI Data Access Firewall, ensuring that access control policies are enforced before any information is returned to the user.

The AI Security Assistant serves as the primary interface through which authenticated users submit requests to access protected corporate documents. It provides a simple conversational interface while ensuring that every request is processed through the AI Data Access Firewall before any document is returned. Figure 12 illustrates the AI Security Assistant interface implemented in the proposed system.

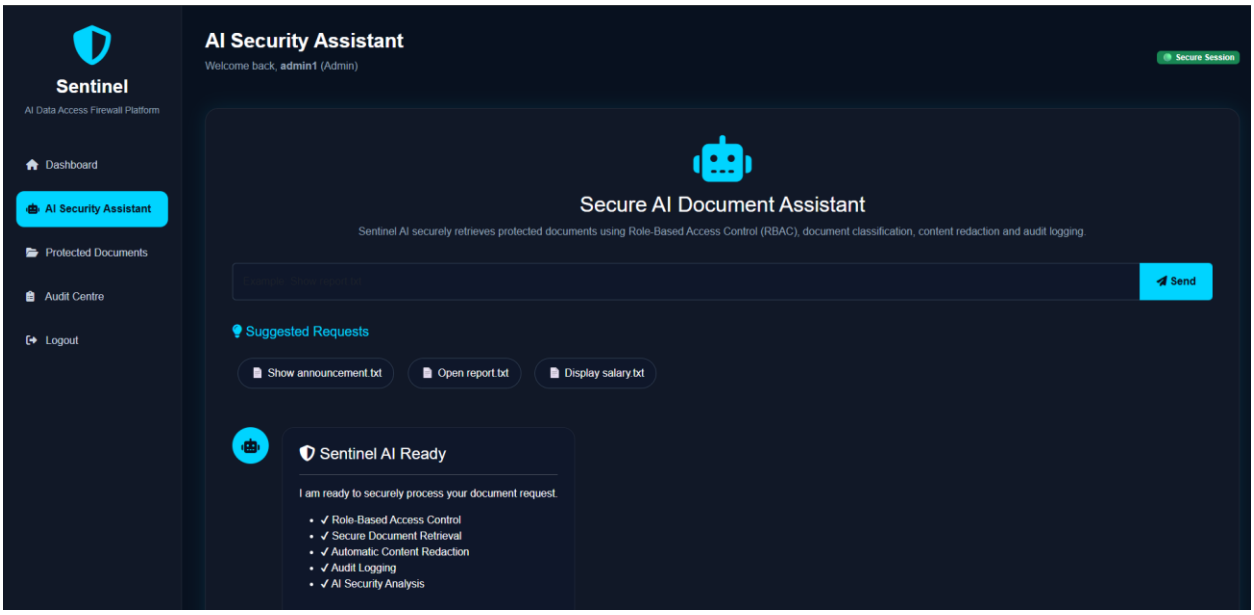


Figure 12: AI Security Assistant Interface

As shown in Figure 12, the AI Security Assistant allows users to submit document requests through a chat-based interface and provides suggested requests to improve usability. Every request is forwarded to the request parser, where the requested document is identified before being evaluated by the RBAC Policy Engine. This design ensures that document access decisions are enforced consistently while providing an intuitive interface for users to interact with protected corporate data.

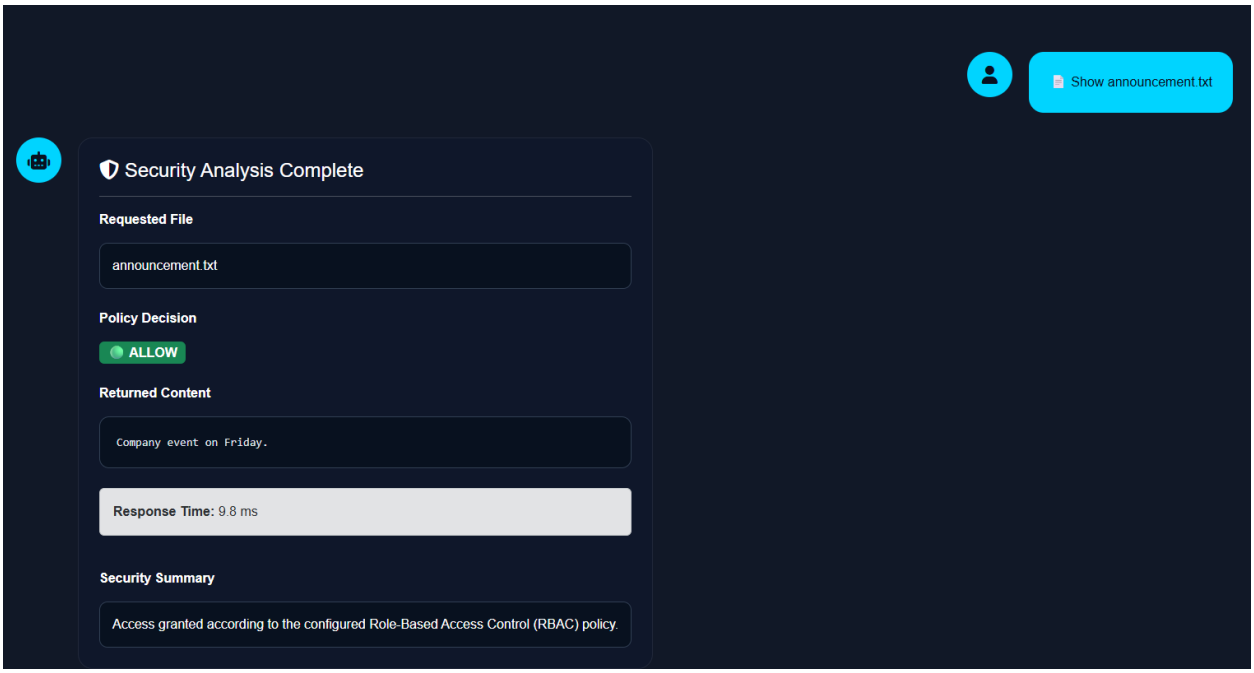


Figure 13: Document Request Processed by the AI Security Assistant

As shown in Figure 13, the system successfully processed the user's request for the public document announcement.txt and returned an ALLOW decision based on the predefined Role-Based Access Control (RBAC) policy. The requested document content is displayed together with the access decision, response time, and security summary. This demonstrates that authorised users can access public documents while the firewall enforces security policies before returning the requested information.



Figure 14: AI Security Assistant Request Processing in app.py

As shown in Figure 14, the chatbot module invokes the RBAC Policy Engine to evaluate the user's role against the requested document's sensitivity level before granting access. The system then verifies the existence of the requested document, records unsuccessful requests in the audit log when necessary, and calculates the response latency before returning the appropriate result to the

user. This implementation ensures that every document request is validated and processed securely while maintaining accurate audit records and system performance monitoring.

4.3.5 RBAC Policy Engine

The Role-Based Access Control (RBAC) Policy Engine is the core security component of the proposed AI Data Access Firewall. It is responsible for evaluating every document request by comparing the authenticated user's assigned role with the predefined access control policies. Based on the evaluation results, the Policy Engine determines whether the requested document should be fully accessible, partially accessible through redaction, or completely denied.

The RBAC policies are defined in the **policies.json** file, where document sensitivity levels are mapped to the permissions assigned to each user role. During request processing, the AI Security Assistant forwards the requested document's sensitivity level together with the authenticated user's role to the Policy Engine. The engine evaluates the request against the configured RBAC rules and returns one of three possible decisions: **ALLOW**, **REDACT**, or **DENY**.

An **ALLOW** decision grants the user unrestricted access to the requested document. A **REDACT** decision permits partial access by forwarding the document to the keyword-based redaction module before it is displayed to the user. A **DENY** decision blocks unauthorised access and returns an access denied message without exposing the document contents. This deterministic decision-making process ensures that access permission remains consistent and predictable for every document request.

The implementation of the RBAC Policy Engine separates access control logic from the remaining application modules, improving maintainability and simplifying future policy updates. By enforcing predefined role permissions before document retrieval, the module provides the primary security mechanism of the proposed AI Data Access Firewall.

The RBAC Policy Engine directly supports the project's objective of preventing unauthorised access by evaluating every document request against predefined access control policies. This ensures that users can only access documents permitted by their assigned roles while preventing the disclosure of restricted information.

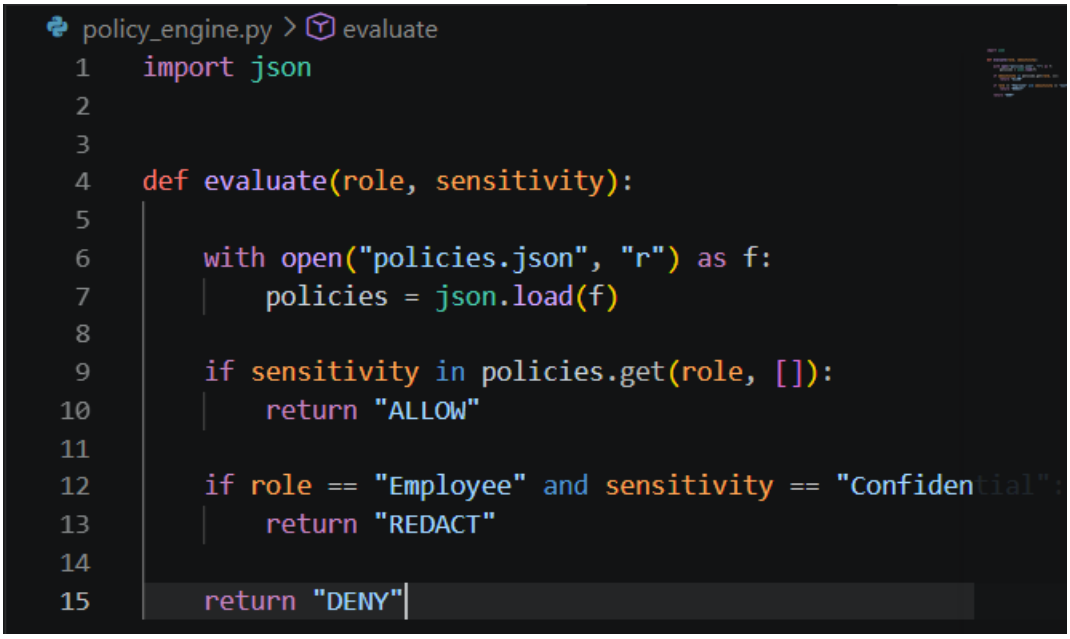


Figure 15: RBAC Policy Evaluation Implementation

As shown in Figure 15, the RBAC Policy Engine evaluates the user's role against the requested document's sensitivity level by comparing the request with the predefined access control policies stored in the policies.json file. Based on the evaluation, the module returns an ALLOW, REDACT, or DENY decision. This ensures that document access is enforced consistently according to the configured security policies, preventing unauthorised access while allowing controlled disclosure of sensitive information where appropriate.



Figure 16: RBAC Policy Definitions Stored in policies.json

As shown in Figure 16, the access control policies are defined in the policies.json configuration file, where each user role is assigned the document sensitivity levels it is authorised to access. Employees are permitted to access Public and Internal documents, Managers can additionally access Confidential documents, while Administrators have unrestricted access to all document classifications. These predefined policies provide the basis for the RBAC Policy Engine to make consistent access decisions and enforce secure document access throughout the system.

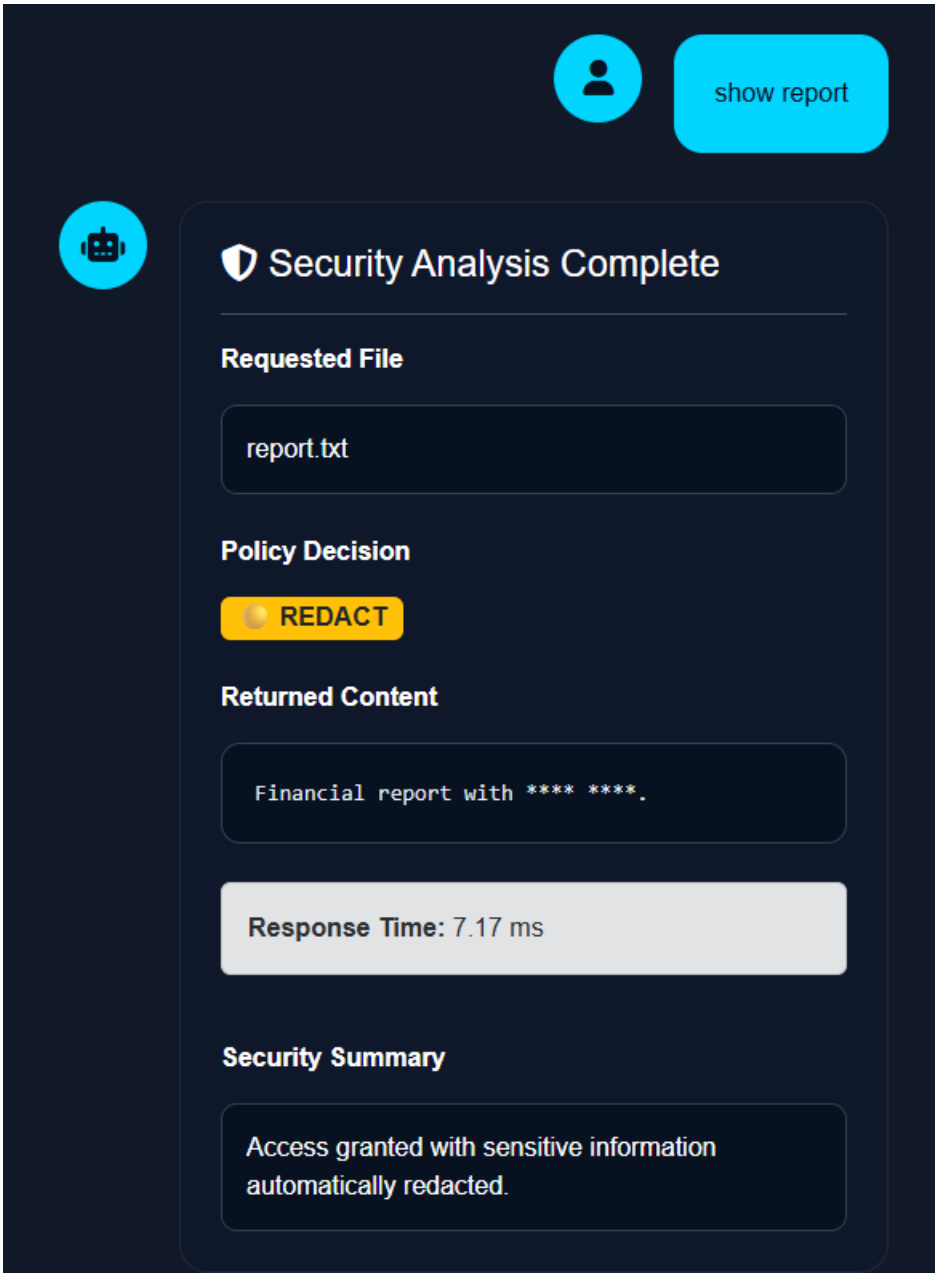


Figure 17: Example of an RBAC Policy Decision

As shown in Figure 17, when an Employee requests a Confidential document, the RBAC Policy Engine returns a REDACT decision instead of granting full access. The system automatically masks sensitive information before displaying the document while preserving the remaining content for the authorised user. This controlled disclosure mechanism reduces the risk of sensitive information leakage while still allowing users to access non-

confidential portions of the document in accordance with the predefined access control policies.

4.3.6 Document Repository and Sensitivity Classification

The Document Repository and Sensitivity Classification module is responsible for storing organisational documents and organising them according to their assigned sensitivity levels. This classification enables the Role-Based Access Control (RBAC) Policy Engine to enforce different access permissions based on both the user's role and the classification of the requested document.

To simplify document management, the repository is divided into four categories: **Public**, **Internal**, **Confidential**, and **Restricted**. Each category is represented by a separate directory containing documents with the corresponding sensitivity level. This directory structure enables the system to locate and retrieve the requested document efficiently while maintaining a clear separation between different categories of protected information.

After the Request Parser identifies the requested document and the RBAC Policy Engine determines the appropriate access decision, the system constructs the document path dynamically using the document's sensitivity level and filename. Before retrieving the document, the system verifies that the requested file exists within the repository. If the file cannot be found, the request is rejected and an appropriate notification is returned to the user. This validation helps prevent invalid document access and improves the reliability of the system.

The sensitivity classification mechanism forms an important part of the proposed AI Data Access Firewall because it provides the basis for enforcing deterministic RBAC policies. By organising documents according to their classification levels, the system ensures that different user roles receive only the level of access permitted by predefined security policies.

The Document Repository and Classification Module contribute to the project by organising documents according to their sensitivity levels. This structured classification enables the RBAC Policy Engine to enforce access decisions consistently and supports the secure management of corporate information.

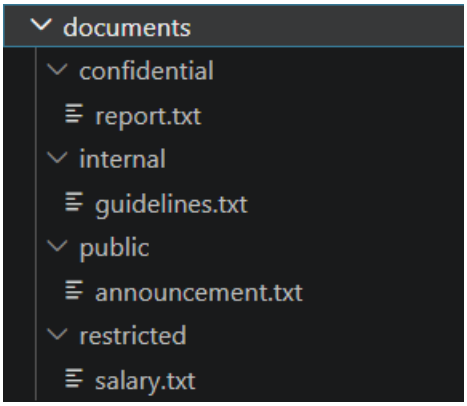


Figure 18: Document Repository Organised by Sensitivity Classification

As shown in Figure 18, protected documents are organised into separate directories according to their assigned sensitivity levels, namely Public, Internal, Confidential, and Restricted. This structured repository enables the AI Data Access Firewall to locate requested documents efficiently while allowing the RBAC Policy Engine to apply the appropriate access control policy based on the document classification. Organising documents in this manner simplifies repository management and supports secure handling of corporate information.

```
path = f"documents/{sensitivity.lower()}/{filename}"

# ---------------------------------
# Check if File Exists
# ---------------------------------

if not os.path.exists(path):
```

Figure 19: Document Retrieval and Validation in app.py

As shown in Figure 19, the system verifies whether the requested document exists in the appropriate repository before attempting to retrieve its contents. If the file cannot be located, the request is recorded in the audit log, and an appropriate response is returned to the user. This validation step improves the reliability of the AI Data Access Firewall by preventing invalid document requests from causing system errors while maintaining a complete audit trail of unsuccessful access attempts.

4.3.7 Audit Logging Module

The Audit Logging Module records every document access request processed by the AI Data Access Firewall. Its primary purpose is to maintain a complete record of system activities, enabling administrators to monitor user interactions, review access decisions, and support security auditing and forensic analysis. By logging all document requests, the system provides accountability and ensures that every access attempt can be traced.

Whenever a document request is processed, the system automatically invokes the audit logging module after the RBAC policy evaluation has been completed. Regardless of whether the request is **ALLOW**, **REDACT**, or **DENY**, an audit record is generated and stored in the **logs.txt** file. Each record contains the timestamp, username, user role, requested document, and the final access decision. This information enables administrators to review historical access activities and identify potential security incidents or unauthorised access attempts.

To maintain the integrity of audit records, the Audit Centre provides a **read-only interface** that allows administrators to view log entries without modifying or deleting them. This design ensures that audit information remains reliable and supports future security monitoring and forensic investigations.

The Audit Logging Module complements the deterministic RBAC mechanism by recording every access decision made by the system. Together, these components improve accountability, strengthen security monitoring, and provide evidence of policy enforcement throughout the document access process.

The Audit Logging Module contributes to the project's objective by maintaining a complete record of document access requests and security decisions. This improves accountability, supports security monitoring, and enables administrators to investigate unauthorised access attempts or other security-related events.

logger.py > log_request

```python
from datetime import datetime

def log_request(username,
                role,
                filename,
                decision):

    timestamp = datetime.now().strftime("%d-%m-%Y %H:%M:%S")

    entry = (
        f"{timestamp} | "
        f"{username} | "
        f"{role} | "
        f"{filename} | "
        f"{decision}\n"
    )

    with open("logs.txt", "a") as f:
        f.write(entry)
```

Figure 20: Audit Logging Implementation in logger.py

As shown in Figure 20, the audit logging module records every document access request by storing the timestamp, username, user role, requested file, and access decision in the system log. Each request is appended to the logs.txt file, creating a complete audit trail of user activities. This enables administrators to monitor document access, investigate security incidents, and maintain accountability by providing a record of all access decisions made by the AI Data Access Firewall.

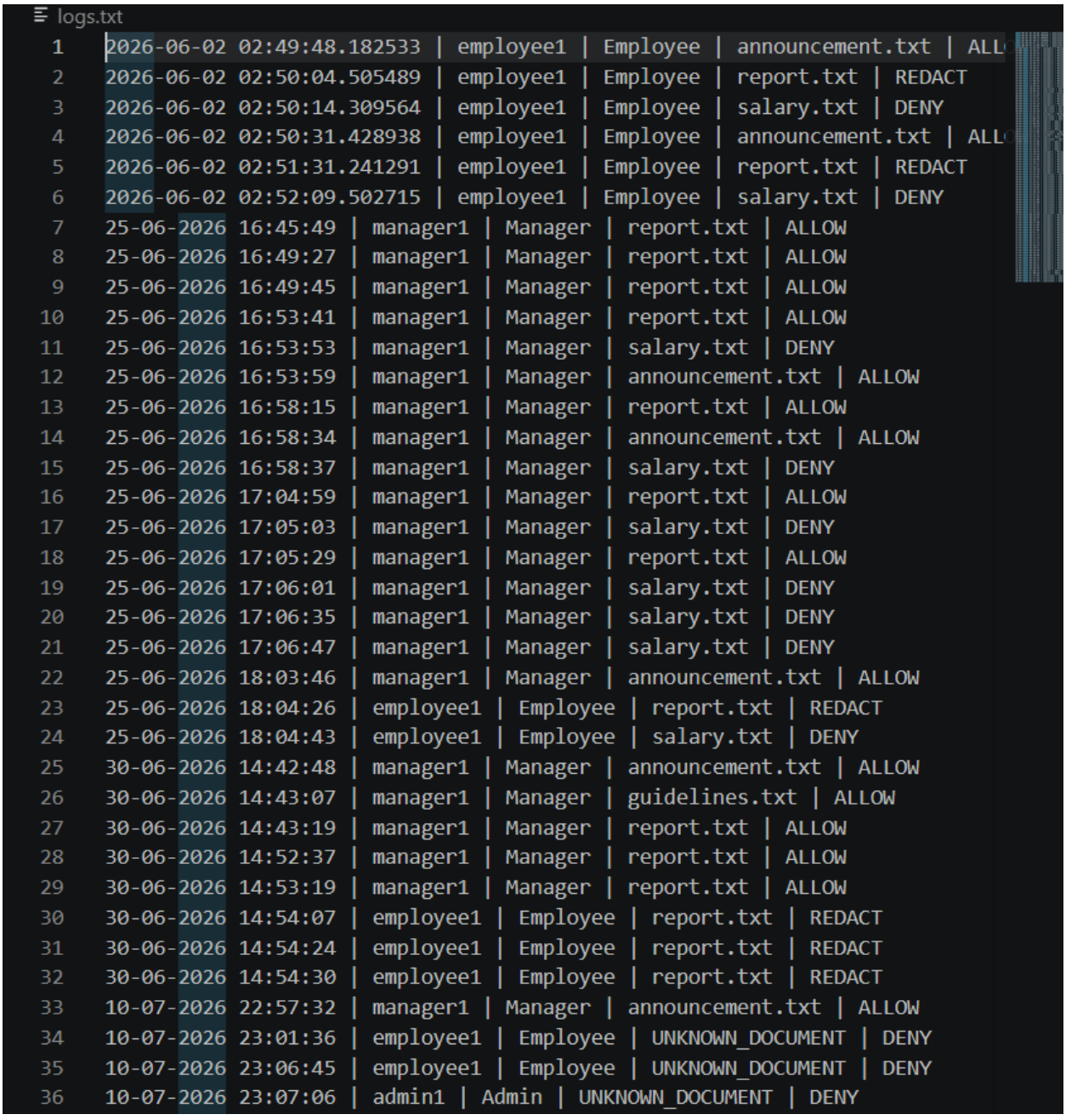


Figure 21: Sample Audit Log Entries

As shown in Figure 21, the logs.txt file maintains a chronological record of all document access requests processed by the AI Data Access Firewall. Each log entry contains the timestamp, username, user role, requested document, and the corresponding access decision, such as ALLOW, REDACT, or DENY. This audit trail enables administrators to monitor user activities, verify policy enforcement, and investigate potential security

incidents, thereby improving accountability and supporting the overall security objectives of the system.

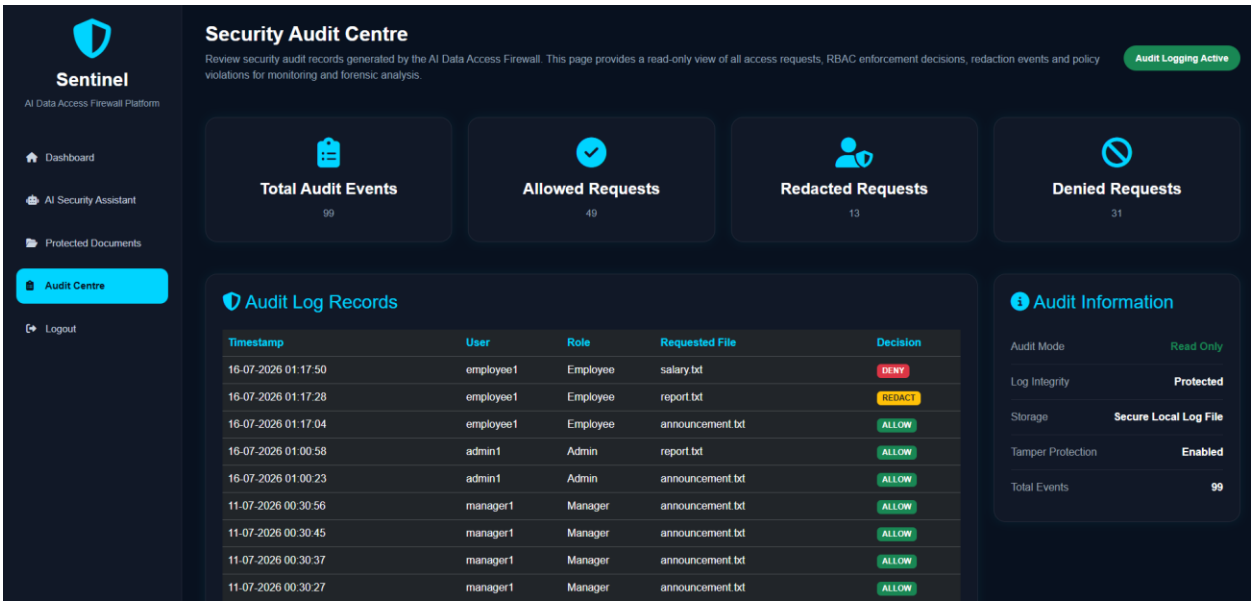


Figure 22: Audit Centre Interface

As shown in Figure 22, the Audit Centre provides administrators with a centralised interface for monitoring document access activities and security events generated by the AI Data Access Firewall. The dashboard presents summary statistics, including the total number of audit events, allowed requests, redacted requests, and denied requests, together with a detailed audit log of user activities. This enables administrators to review access decisions, verify RBAC policy enforcement, and investigate potential security incidents, thereby improving system accountability and supporting effective security monitoring.

4.3.8 Admin Dashboard

The Admin Dashboard serves as the central monitoring interface of the proposed AI Data Access Firewall. It provides administrators with an overview of the system's operational status and security activities, enabling continuous monitoring of document access requests and policy enforcement. The dashboard was designed to present essential security information in a clear and organised manner, allowing administrators to quickly assess the current state of the system.

Upon successful authentication, the dashboard displays several security indicators, including the firewall status, total number of protected documents, total audit events, policy violations, and the

number of configured RBAC policies. In addition, the dashboard presents a summary of recent audit log entries, allowing administrators to review the latest document access requests together with the corresponding users, roles, requested documents, and access decisions.

The dashboard retrieves statistical information dynamically from the document repository, RBAC policy configuration, and audit log records. These statistics are processed by the application before being displayed through the web interface, providing administrators with an up-to-date summary of system activities. This implementation supports continuous security monitoring and enables administrators to identify unusual access patterns or policy violations efficiently.

The Admin Dashboard contributes to the project by providing administrators with a centralised view of system status, security metrics, and audit information. This enables efficient monitoring of firewall operations, supports administrative decision-making, and helps ensure that access control policies are operating as intended.

Overall, the Admin Dashboard improves system usability by providing a centralised view of operational information while supporting the management and monitoring requirements of the proposed AI Data Access Firewall.

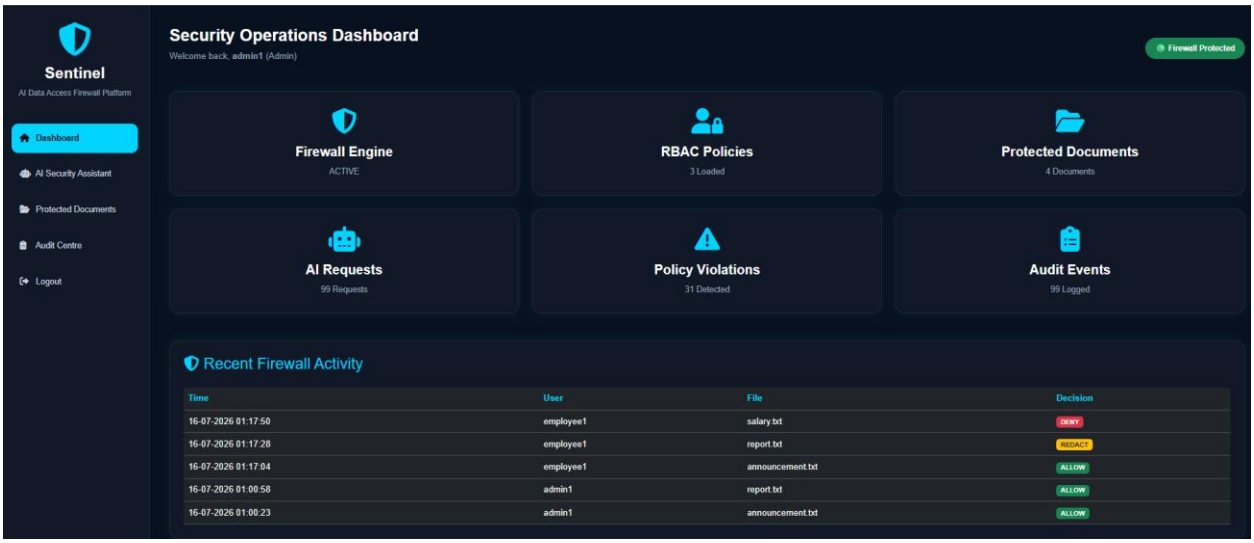


Figure 23: Admin Dashboard Interface 1

As shown in Figure 23, the Security Operations Dashboard provides administrators with a real-time overview of the AI Data Access Firewall's operational status and security metrics.

The dashboard displays key information, including the firewall status, loaded RBAC policies, protected documents, AI requests, policy violations, and recent firewall activity. This centralised interface enables administrators to monitor system performance, review security events, and quickly identify potential policy violations, thereby supporting effective management and continuous monitoring of the document access control system.

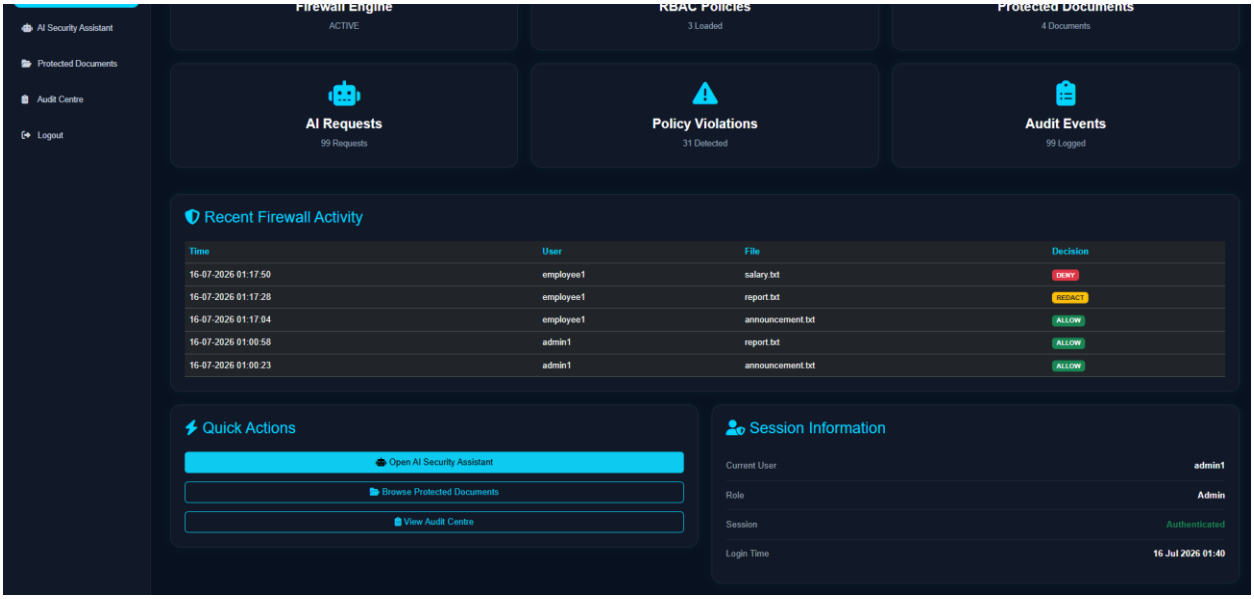


Figure 24: Admin Dashboard Interface 2

As shown in Figure 24, the lower section of the Security Operations Dashboard provides administrators with quick access to the system's core functions and displays information about the current authenticated session. The Quick Actions panel allows administrators to navigate directly to the AI Security Assistant, Protected Documents, and Audit Centre, while the Session Information panel displays the current user's identity, assigned role, authentication status, and login time. These features improve system usability by providing efficient navigation and enabling administrators to verify the current session before performing security-related operations.

```
    document_count = 0

    for folder in folders:
        if os.path.exists(folder):
            document_count += len(os.listdir(folder))

    audit_events = 0
```

Figure 25: Dashboard Statistics Generation in app.py

As shown in Figure 25, the dashboard automatically calculates the total number of protected documents by scanning each document classification folder during system initialisation. The system verifies the existence of each directory before counting the available files, ensuring that the displayed statistics accurately reflect the current state of the document repository. This information is used to provide administrators with an up-to-date overview of the protected documents managed by the AI Data Access Firewall.

4.4 User Interface Design

The User Interface (UI) Design of the proposed AI Data Access Firewall was developed to provide a secure, intuitive, and user-friendly environment for interacting with the system. The interfaces enable users to perform authentication, request protected documents, monitor access activities, and review security information through a consistent and responsive web-based design. Bootstrap 5, HTML5, CSS3, and JavaScript were used to develop the interfaces, ensuring a modern layout and improved usability across different system modules.

The following subsections present the key user interfaces implemented in the proposed system, together with a description of their functionality and role in supporting secure AI-to-document interaction.

4.4.1 Login Interface

The Login Interface serves as the entry point to the proposed AI Data Access Firewall. It authenticates users before granting access to protected system resources and ensures that only authorised users can access the application. The interface requires users to enter their username and password, which are verified against the stored user credentials before a secure session is established.

The interface was intentionally designed with a simple and uncluttered layout to improve usability while maintaining security. Upon successful authentication, users are redirected to the system dashboard according to their assigned role. Invalid login attempts are rejected, preventing unauthorised access to the application.

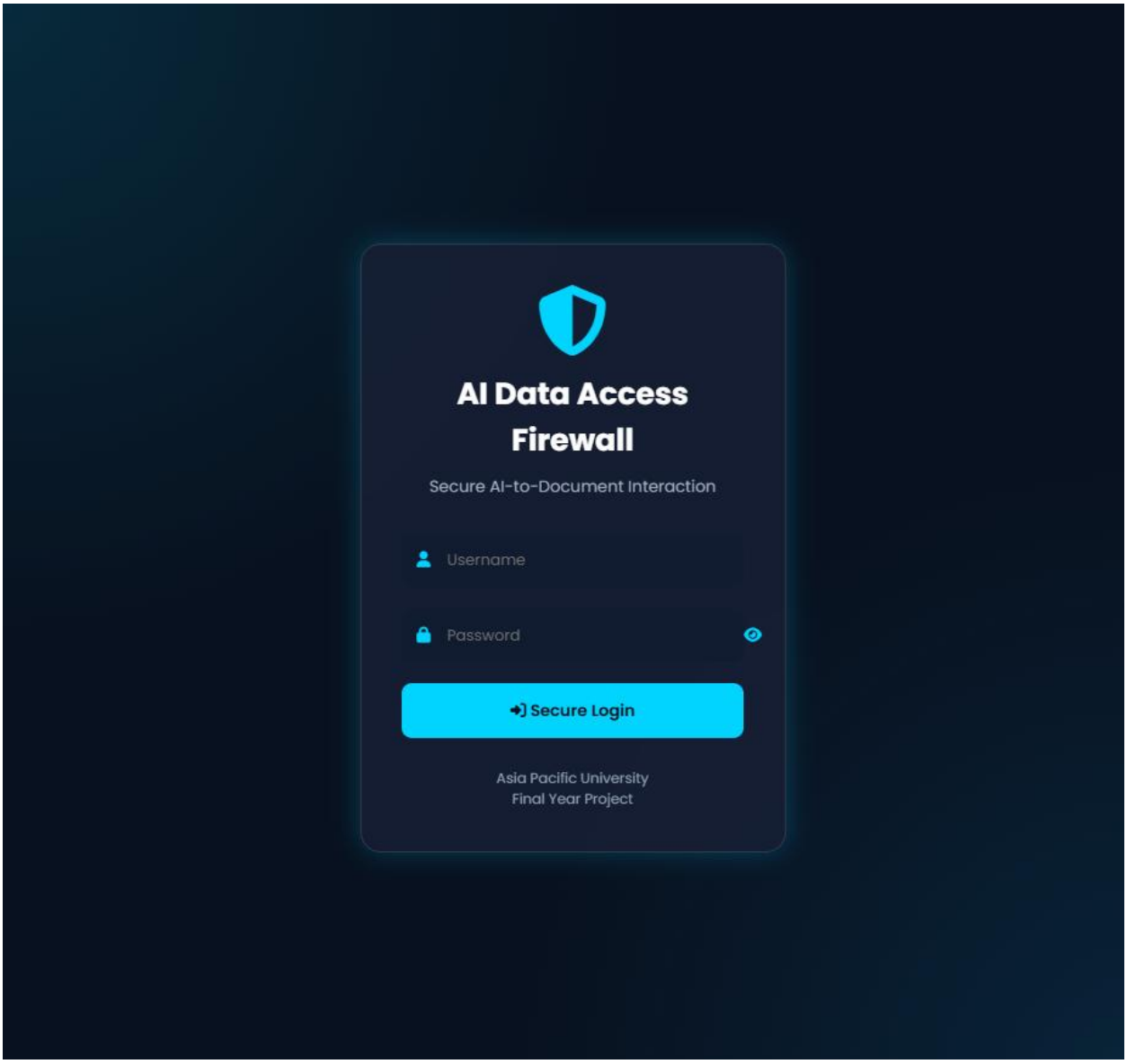


Figure 26: Login Interface

As shown in Figure 26, the Login Interface provides a secure entry point to the AI Data Access Firewall by requiring users to authenticate using their assigned username and password. The interface is designed with a simple and user-friendly layout to facilitate secure access while preventing unauthorised users from interacting with the system. Upon successful authentication, the user is redirected to the dashboard, where subsequent document requests are processed according to the assigned Role-Based Access Control (RBAC) permissions.

4.4.2 Dashboard Interface

The Dashboard Interface provides users with an overview of the current status of the AI Data Access Firewall after successful authentication. The dashboard displays key system information, including firewall status, document statistics, audit events, policy information, and recent access activities. These statistics provide users and administrators with a quick summary of system operations.

The dashboard also serves as the primary navigation page, allowing users to access the AI Security Assistant, Protected Documents, Audit Centre, and other available system functions. Its organised layout improves usability by presenting important security information in a clear and accessible manner.

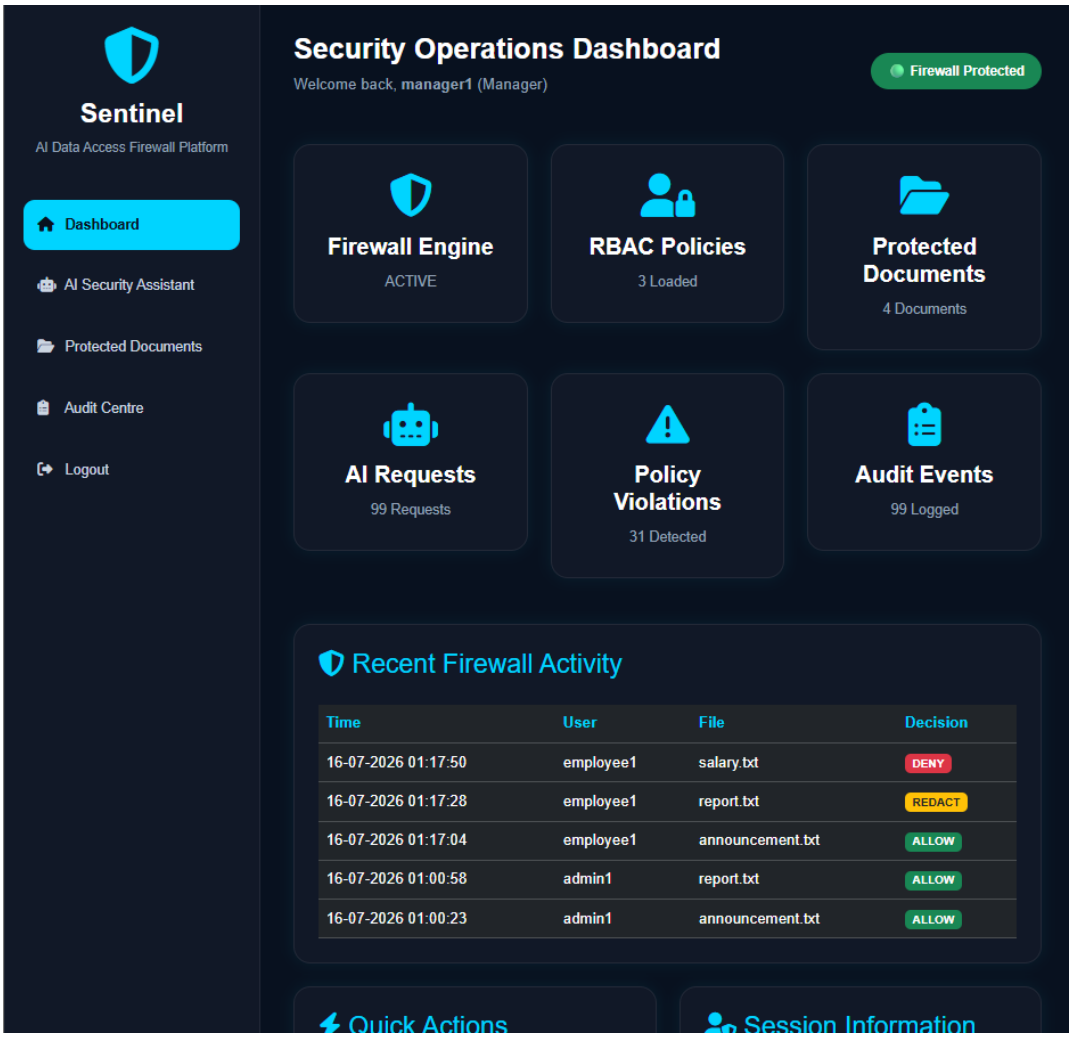


Figure 27: Dashboard Interface

As shown in Figure 27, the Security Operations Dashboard provides users with an overview of the AI Data Access Firewall after successful authentication. The interface displays key system information, including the firewall status, available RBAC policies, protected documents, AI requests, policy violations, and audit events. In addition, the dashboard provides quick access to the system's main functions and presents recent security information to support monitoring and efficient navigation. This interface improves usability by enabling users to access the system's core features through a centralised and organised dashboard.

4.4.3 AI Security Assistant Interface

The AI Security Assistant Interface enables authenticated users to submit document requests using natural language. The interface includes a request input field, suggested document requests, and a structured response panel displaying the requested document, policy decision, returned content, and security summary.

Depending on the RBAC policy evaluation, the interface presents one of three outcomes: full document access, a redacted version of the requested document, or an access denied message. This interface demonstrates the secure interaction between users and protected organisational documents while ensuring that all requests are processed according to the configured security policies.

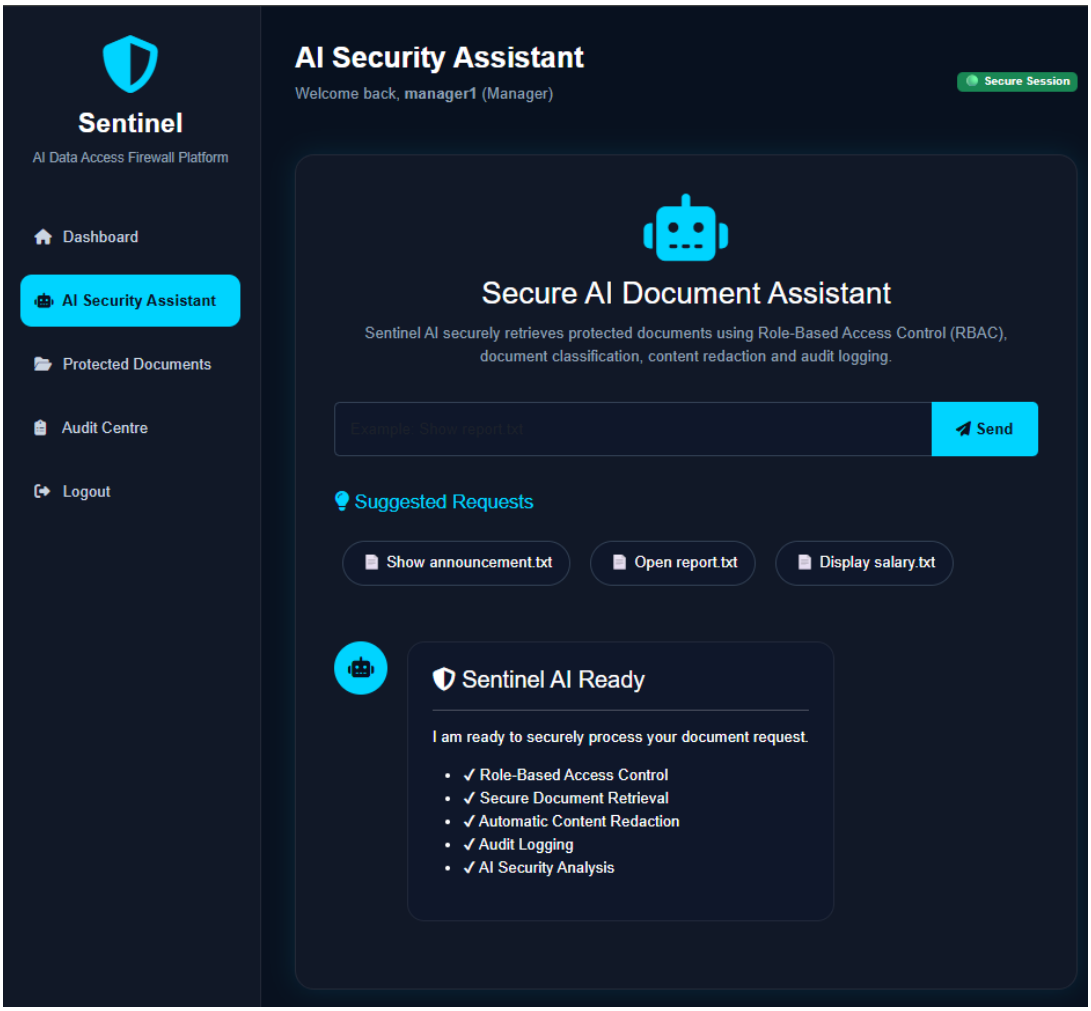


Figure 28: AI Security Assistant Interface

As shown in Figure 28, the AI Security Assistant provides a user-friendly interface through which authenticated users can securely request access to protected corporate documents. The interface includes a request input field, suggested document requests, and a conversation panel that displays the system's responses. All user requests submitted through this interface are processed by the AI Data Access Firewall, where RBAC policy evaluation, document classification, content redaction, and audit logging are applied before the requested information is returned, ensuring secure AI-to-document interaction.

4.4.4 Audit Log Interface

The Audit Log Interface provides administrators with a comprehensive view of the security events recorded by the proposed AI Data Access Firewall. The interface enables administrators to monitor document access requests and review the decisions generated by the Role-Based Access Control (RBAC) Policy Engine. By presenting audit information in a structured and organised manner, the interface supports continuous security monitoring and system accountability.

The interface displays summary statistics, including the total number of audit events, allowed requests, redacted requests, and denied requests. These statistics provide administrators with an overview of system activity and allow them to identify the distribution of document access decisions. In addition, a detailed audit log table presents information such as the timestamp, username, assigned role, requested document, and access decision for each processed request.

To preserve the integrity of audit records, the Audit Log Interface operates in **read-only mode**, preventing users from modifying or deleting logged information through the application. An additional information panel provides administrators with details regarding the current audit status, log integrity, storage method, tamper protection, and the total number of recorded events. This interface supports security monitoring, accountability, and forensic analysis by providing a reliable record of all document access activities performed within the system.

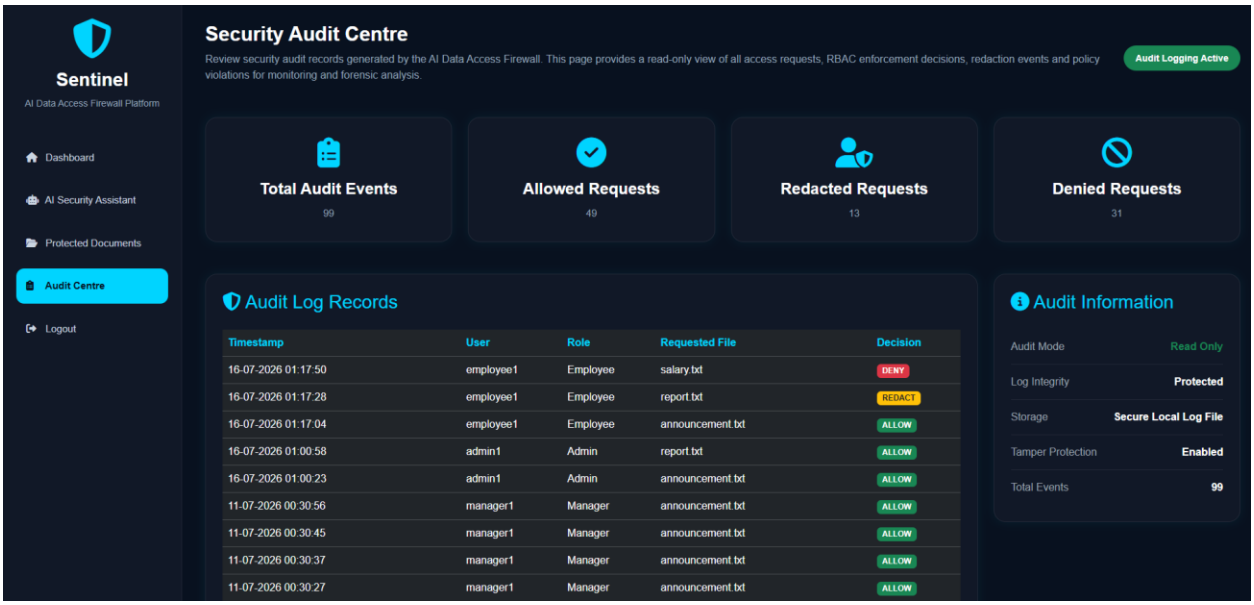


Figure 29: Audit Log Interface

As shown in Figure 29, the Audit Centre provides administrators with a dedicated interface for monitoring document access activities and reviewing security events generated by the AI Data Access Firewall. The interface presents summary statistics of audit events together with a detailed log containing the timestamp, user, role, requested document, and access decision for each request. This enables administrators to verify RBAC policy enforcement, monitor system activity, and investigate potential security incidents, thereby supporting accountability and maintaining the security of the protected document repository.

4.5 Chapter Summary

This chapter presented the design and implementation of the proposed AI Data Access Firewall for Secure AI-to-Document Interaction using Deterministic Role-Based Access Control (RBAC) Policies. It first described the system design through the overall system architecture and a set of Unified Modelling Language (UML) diagrams, including the use case, activity, sequence, and class diagrams. These design artefacts illustrated the structure, workflow, and interactions between the major system components before implementation.

The chapter then discussed the implementation of the proposed system by describing the development environment, project structure, user authentication module, AI Security Assistant, RBAC Policy Engine, document repository and sensitivity classification, audit logging module, and dashboard. Each module contributes to the secure processing of document requests by enforcing deterministic RBAC policies, protecting sensitive information through keyword-based redaction, and maintaining comprehensive audit records for accountability and security monitoring.

Finally, the chapter presented the user interface design of the implemented prototype, including the login interface, dashboard, AI Security Assistant, and Audit Log Interface. These interfaces demonstrate how users securely interact with the system while providing administrators with the necessary tools to monitor document access activities and review security events.

Overall, the completed prototype demonstrates the feasibility of implementing an AI Data Access Firewall that securely mediates AI-assisted document access through deterministic RBAC policy enforcement, document sensitivity classification, content redaction, and audit logging. The next

chapter evaluates the implemented system through functional testing, performance analysis, and security assessment to determine whether the proposed objectives have been successfully achieved.

Chapter 5: System Testing and Evaluation

5.1 Introduction

This chapter presents the testing and evaluation of the proposed AI Data Access Firewall for Secure AI-to-Document Interaction using Deterministic Role-Based Access Control (RBAC) Policies. The purpose of this evaluation is to determine whether the implemented prototype satisfies the functional and security objectives defined in the earlier chapters. A series of test cases were conducted to verify the correctness of the implemented modules and to assess the system's ability to enforce secure document access.

The evaluation includes functional testing of the major system components, including user authentication, AI Security Assistant, RBAC policy enforcement, document repository and sensitivity classification, request validation, and audit logging. Each module was tested using predefined scenarios to verify that the implemented functionality operates as intended under different access conditions.

In addition to functional testing, the system was evaluated using several performance and security metrics. These include the confusion matrix (True Positive, True Negative, False Positive, and False Negative), Block Rate, Leakage Prevention Rate, Redaction Accuracy, and Response Latency. These metrics provide quantitative evidence of the effectiveness of the proposed AI Data Access Firewall in preventing unauthorised document access while allowing legitimate users to access authorised information according to deterministic RBAC policies.

Finally, this chapter discusses the evaluation results by analysing the strengths and limitations of the implemented prototype. The discussion highlights the effectiveness of the proposed approach in enforcing secure AI-to-document interaction while also identifying

the limitations of the keyword-based redaction mechanism and potential areas for future improvement.

5.2 Testing Methodology

The testing methodology defines the approach used to evaluate the functionality, security, and performance of the proposed AI Data Access Firewall. The evaluation was conducted after the implementation phase to verify that the system satisfies the functional and security requirements identified during the analysis and design stages. A combination of functional testing and performance evaluation was performed to assess the correctness and effectiveness of the implemented prototype.

Functional testing was carried out using predefined test cases that represent typical user interactions and potential security threats. These test cases evaluated the behaviour of the major system modules, including user authentication, AI Security Assistant, Role-Based Access Control (RBAC) policy enforcement, document repository and sensitivity classification, request validation, and audit logging. Each test case compared the expected system behaviour with the actual outcome to determine whether the implemented functionality operated correctly.

Performance and security evaluation were then conducted using quantitative metrics to measure the effectiveness of the proposed system. The evaluation included the confusion matrix consisting of True Positive (TP), True Negative (TN), False Positive (FP), and False Negative (FN), together with Block Rate, Leakage Prevention Rate, Redaction Accuracy, and Response Latency. These metrics provide objective evidence of the system's capability to prevent unauthorised document access while maintaining efficient processing of legitimate user requests.

The following sections describe the testing environment, test cases, evaluation metrics, experimental results, and discussion of the findings obtained during the system evaluation.

5.2.1 Testing Environment

The proposed AI Data Access Firewall prototype was tested in a local development environment after the implementation phase. The purpose of the testing environment was to verify that the implemented modules functioned correctly and that the system could securely process AI document access requests according to the predefined Role-Based Access Control (RBAC) policies.

The prototype was developed using Python with the Flask web framework and executed on a Windows 11 operating system. The system was run locally using the Flask development server and accessed through the Google Chrome web browser. Visual Studio Code was used as the integrated development environment (IDE) for coding, debugging, and testing the application. User information, RBAC policies, and document classifications were stored in JSON and text files, reflecting the file-based architecture adopted for the prototype.

Table 3: Testing environment specifications

Component	**Specification**
Operating System	Windows 11
Processor	13th Gen Intel® Core™ i7-13620H @ 2.40 GHz
Memory (RAM)	32 GB
Development Environment	Visual Studio Code
Programming Language	Python 3.x
Web Framework	Flask
Front-end Technologies	HTML, CSS, JavaScript, Bootstrap
Web Browser	Google Chrome
Data Storage	JSON files and Text (.txt) files
Testing Environment	Localhost (Flask Development Server)

5.2.2 Test Cases

The functionality of the proposed AI Data Access Firewall was verified using a set of predefined test cases based on the system requirements and implemented features. The test cases were designed to simulate common user interactions and security-related scenarios to determine whether the system behaved according to the predefined Role-Based Access Control (RBAC) policies.

The testing covered the major functional modules of the prototype, including user authentication, AI document request processing, RBAC policy enforcement, document retrieval, keyword-based redaction, access denial, and audit logging. Each test case specified the test objective, input conditions, expected outcome, actual outcome, and testing status. The expected results were then compared with the actual system behaviour to verify the correctness of the implementation.

The selected test cases include both authorised and unauthorised access requests to ensure that the system correctly allows legitimate document access while preventing unauthorised disclosure of sensitive information. The successful completion of these test cases demonstrates that the implemented prototype satisfies its intended functional and security requirements.

Table 4: Functional test cases conducted during the system evaluation

Test Case	Scenario	Expected Result	Actual Result	Status
TC1	Employee requests for a Public document	Access granted (ALLOW)	Access granted successfully	Pass
TC2	Employee requests an Internal document	Sensitive content redacted (REDACT)	Sensitive content redacted successfully	Pass

	containing sensitive keywords			
TC3	Employee requests a Restricted document	Access denied (DENY)	Access denied successfully	Pass
TC4	Manager requests a Confidential document	Access granted (ALLOW)	Access granted successfully	Pass
TC5	Admin requests a Restricted document	Access granted (ALLOW)	Access granted successfully	Pass
TC6	User enters invalid login credentials	Login rejected	Login rejected successfully	Pass
TC7	Successful document request recorded in audit log	Audit log entry created	Audit log entry created successfully	Pass
TC8	Unauthorised access attempt recorded in audit log	Audit log entry created	Audit log entry created successfully	Pass

5.2.3 Evaluation Metrics

The effectiveness of the proposed AI Data Access Firewall was evaluated using both security and performance metrics. These metrics provide quantitative evidence of the system's ability to enforce deterministic Role-Based Access Control (RBAC) policies, prevent unauthorised document access, and process user requests efficiently. The selected evaluation metrics include the confusion matrix, Block Rate, Leakage Prevention Rate, Redaction Accuracy, and Response Latency.

Confusion Matrix

The confusion matrix was used to evaluate the correctness of the access control decisions made by the proposed system. It consists of four outcomes:

- **True Positive (TP):** The system correctly denied or redacted an unauthorised request involving sensitive information.
- **True Negative (TN):** The system correctly allowed an authorised request according to the RBAC policy.
- **False Positive (FP):** The system incorrectly denied or redacted an authorised request.
- **False Negative (FN):** The system incorrectly allowed unauthorised access to sensitive information.

These values were used to analyse the e

effectiveness of the implemented access control mechanism.

Block Rate

The Block Rate measures the percentage of requests that resulted in either **DENY** or **REDACT** decisions. A higher Block Rate indicates that the system actively prevented or restricted access to sensitive information when required by the predefined RBAC policies.

Leakage Prevention Rate

The Leakage Prevention Rate measures the system's effectiveness in preventing unauthorised disclosure of sensitive information. It evaluates how successfully the implemented RBAC policy enforcement and keyword-based redaction mechanisms protected confidential documents from unauthorised access.

Redaction Accuracy

Redaction Accuracy measures how accurately the system masks predefined sensitive keywords in documents before displaying them to authorised users with restricted access permissions. A higher percentage indicates that the keyword-based redaction mechanism consistently identified and concealed sensitive information.

Response Latency

Response Latency measures the time required for the system to process a document request from submission to the display of the final response. This metric evaluates the efficiency of the implemented prototype and demonstrates whether the additional security checks introduce significant processing delays.

5.3 Evaluation Results

This section presents the results obtained from the functional and performance evaluation of the proposed AI Data Access Firewall. The evaluation was conducted using the predefined test cases and security metrics described in the previous section. The results were analysed to determine whether the implemented prototype successfully enforced deterministic Role-Based Access Control (RBAC) policies, protected sensitive information, and processed document requests efficiently.

The evaluation focuses on both functional correctness and system performance. Functional testing verifies that each system module operates according to its intended behaviour, while the performance evaluation measures the effectiveness of the implemented security mechanisms using quantitative metrics. The findings presented in this section demonstrate how the proposed system responds to authorised and unauthorised document access requests and assesses its overall effectiveness in preventing unauthorised disclosure of sensitive information.

5.3.1 Functional Testing Results

The functional testing results demonstrate that the proposed AI Data Access Firewall operated according to the predefined system requirements and deterministic Role-Based Access Control (RBAC) policies. As presented in Table 4, all predefined test cases produced the expected

outcomes, indicating that the implemented prototype correctly enforced document access permissions and responded appropriately to different user requests.

The results show that authorised users were granted access only to documents permitted by their assigned roles, while unauthorised requests were either denied or subjected to keyword-based redaction where applicable. The system also successfully validated user authentication, processed AI document requests, enforced RBAC policies, retrieved the appropriate documents, and generated audit log entries for both authorised and unauthorised access attempts.

Furthermore, the testing confirmed that the audit logging module consistently recorded all document access requests, including the username, user role, requested document, access decision, and timestamp. This provides traceability and supports security monitoring by maintaining a complete record of user activities.

Overall, the successful completion of all functional test cases demonstrates that the implemented prototype satisfies its intended functional and security requirements. The results indicate that the proposed AI Data Access Firewall effectively controls AI-to-document interaction by enforcing deterministic RBAC policies while maintaining accurate logging and secure document handling.

Table 5: Evaluation Scenarios and Results

Scenario	**User Role**	**Document**	**Expected Decision**	**Actual Decision**	**Result**
ES1	Employee	announcement.txt (Public)	ALLOW	ALLOW	Pass
ES2	Employee	report.txt (Internal)	REDACT	REDACT	Pass
ES3	Employee	salary.txt (Restricted)	DENY	DENY	Pass
ES4	Manager	announcement.txt (Public)	ALLOW	ALLOW	Pass

ES5	Manager	report.txt (Internal)	ALLOW	ALLOW	Pass
ES6	Manager	salary.txt (Restricted)	DENY	DENY	Pass
ES7	Admin	announcement.txt (Public)	ALLOW	ALLOW	Pass
ES8	Admin	report.txt (Internal)	ALLOW	ALLOW	Pass
ES9	Admin	salary.txt (Restricted)	ALLOW	ALLOW	Pass
ES10	Employee	reporrrt.txt (Invalid filename)	DENY	DENY	Pass

As shown in the table above, all evaluation scenarios produced the expected access control decisions. The system granted access to authorised users, applied keyword-based redaction where required, and denied unauthorised access according to the predefined RBAC policies. These evaluation results were subsequently used to calculate the security and performance metrics presented in the following sections.

An additional evaluation scenario was conducted using an invalid document name (reporrrt.txt) to verify the system's request validation mechanism. The system correctly denied the request, demonstrating its ability to reject invalid document requests and prevent access to non-existent resources.

5.3.2 Confusion Matrix Analysis

The confusion matrix was used to evaluate the accuracy of the access control decisions made by the proposed AI Data Access Firewall. Based on the evaluation scenarios presented in Table 5., the system's decisions were classified into True Positive (TP), True Negative (TN), False Positive (FP), and False Negative (FN). These values indicate whether the implemented Role-Based Access Control (RBAC) policy correctly allowed authorised requests and prevented unauthorised access to sensitive documents.

Table 6: Confusion Matrix Results

Actual Condition	Predicted Authorised	Predicted Unauthorised
Authorised Request	TN = 6	FP = 0
Unauthorised/Sensitive Request	FN = 0	TP = 3

The evaluation results show that the proposed system achieved **3 True Positives (TP)** and **6 True Negatives (TN)**, indicating that all unauthorised or sensitive document requests were handled correctly while all authorised requests were successfully permitted according to the predefined RBAC policies. Furthermore, no **False Positives (FP)** or **False Negatives (FN)** were recorded during the evaluation.

The **True Positives (TP)** demonstrate that the firewall correctly denied unauthorised requests or applied keyword-based redaction when sensitive information required protection. The **True Negatives (TN)** confirm that authorised users were able to access permitted documents without unnecessary restrictions. The absence of **False Positives (FP)** indicates that no legitimate requests were incorrectly denied, while the absence of **False Negatives (FN)** demonstrates that no unauthorised requests were incorrectly granted access. These results confirm that the deterministic RBAC policy engine consistently enforced the predefined access control rules and effectively protected sensitive corporate information throughout the evaluation.

5.3.3 Block Rate Analysis

The Block Rate was calculated to determine the percentage of evaluation scenarios in which the proposed AI Data Access Firewall prevented unauthorised access to sensitive information through either DENY or REDACT decisions. This metric reflects the effectiveness of the implemented Role-Based Access Control (RBAC) policy and keyword-based redaction mechanism in protecting sensitive corporate documents.

Table 7: Block Rate Calculation

Metric	Value
Total Evaluation Scenarios	9
Protected Requests (DENY or REDACT)	3
Block Rate	33.3%

The evaluation results show that 3 out of 9 document access requests required security enforcement through either access denial or keyword-based redaction, resulting in a Block Rate of 33.3%. The remaining requests were authorised and processed according to the predefined RBAC policies.

This result demonstrates that the proposed AI Data Access Firewall successfully identified and protected requests involving sensitive information while allowing legitimate users to access documents within their assigned permissions. Rather than blocking every request, the system selectively applied security controls only when required, maintaining an appropriate balance between security and usability.

5.3.4 Leakage Prevention Rate Analysis

The Leakage Prevention Rate was used to evaluate the effectiveness of the proposed AI Data Access Firewall in preventing the unauthorised disclosure of sensitive information. A request was considered successfully protected when the system either denied access to an unauthorised user or applied keyword-based redaction to sensitive information before displaying the requested document. This metric measures the system's ability to prevent data leakage during the evaluation scenarios.

Table 8: Leakage Prevention Rate Calculation

Metric	Value
Total Sensitive Requests	3
Successfully Protected Requests	3
Leakage Prevention Rate	100%

The evaluation results show that all three sensitive document requests were successfully protected by the implemented security mechanisms, resulting in a Leakage Prevention Rate of 100%. For unauthorised access attempts, the system correctly denied access, while authorised requests involving sensitive information were protected through keyword-based redaction. These results demonstrate that the implemented deterministic RBAC policy and redaction mechanism effectively prevented unauthorised disclosure of sensitive information during the evaluation.

Although the evaluation achieved a 100% Leakage Prevention Rate for the tested scenarios, the implemented keyword-based redaction mechanism relies on predefined keywords. Consequently,

sensitive information expressed using alternative wording or phrases that are not included in the predefined keyword list may not be detected. This limitation is discussed further in Section 5.4 Discussion.

5.3.5 Redaction Accuracy Analysis

Redaction Accuracy was used to evaluate the effectiveness of the keyword-based redaction mechanism in identifying and masking predefined sensitive information before displaying documents to authorised users with restricted access. This metric measures the percentage of sensitive keywords that were correctly detected and replaced with placeholder characters (****) during document retrieval.

Table 9: Redaction Accuracy Calculation

Metric	Value
Total Sensitive Keywords Tested	3
Correctly Redacted Keywords	3
Redaction Accuracy	100%

The evaluation results indicate that all predefined sensitive keywords included in the evaluation were successfully identified and replaced with placeholder characters before the document was displayed. This resulted in a Redaction Accuracy of 100%, demonstrating that the implemented redaction mechanism operated correctly for all tested scenarios.

The successful redaction of sensitive keywords helps reduce the risk of exposing confidential information while still allowing authorised users to access the remaining document content. However, the implemented mechanism relies on predefined keywords and exact text matching. Consequently, sensitive information expressed using different wording, abbreviations, or synonyms may not be detected or redacted. This limitation is discussed further in Section 5.4 Discussion.

5.3.6 Response Latency Analysis

Response Latency was measured to evaluate the efficiency of the proposed AI Data Access Firewall in processing document access requests. The response time was recorded from the moment a user submitted a document request until the final access decision and response were displayed. This metric assesses whether the implemented security mechanisms introduce significant delays during request processing.

Table 10: Response Latency Results

Metric	Value
Number of Evaluation Scenarios	9
Average Response Latency	4.11 ms
Minimum Response Latency	3.00 ms
Maximum Response Latency	9.07 ms

The evaluation results show that the proposed system achieved an average response latency of 4.11 ms across the nine evaluation scenarios. The minimum recorded response time was 3.00 ms, while the maximum response time was 9.07 ms. Despite variations in processing time, all requests were completed within a few milliseconds.

These results indicate that the deterministic RBAC policy evaluation, document retrieval, keyword-based redaction, and audit logging mechanisms introduced minimal processing overhead. Consequently, the proposed AI Data Access Firewall was able to provide secure document access while maintaining efficient response times for the evaluated scenarios.

5.4 Discussion

The evaluation results demonstrate that the proposed AI Data Access Firewall successfully achieved its primary objective of controlling AI-to-document interaction using deterministic Role-Based Access Control (RBAC) policies. Throughout the evaluation, the system consistently enforced predefined access permissions, applied keyword-based redaction where required, and denied unauthorised access to restricted documents. These findings indicate that the implemented prototype effectively protected sensitive information while allowing authorised users to access documents appropriate to their assigned roles.

The confusion matrix analysis showed that the system achieved 3 True Positives (TP) and 6 True Negatives (TN), with no False Positives (FP) or False Negatives (FN) recorded during the evaluation. This indicates that all authorised requests were correctly permitted, while all unauthorised or sensitive requests were appropriately protected through either access denial or keyword-based redaction. The absence of False Positives prevented unnecessary restrictions on legitimate users, while the absence of False Negatives ensured that unauthorised users were not granted access to protected information within the evaluated scenarios.

The Block Rate of 33.3% demonstrates that the proposed system did not unnecessarily restrict user requests. Security controls were applied only when required by the predefined RBAC policies, allowing authorised requests to proceed while protecting sensitive information through DENY or REDACT decisions. This behaviour reflects an appropriate balance between security and usability, ensuring that legitimate users can continue their work without unnecessary interruptions.

Similarly, the Leakage Prevention Rate of 100% indicates that all sensitive requests included in the evaluation were successfully protected. Unauthorised requests were denied, while authorised users requesting documents containing predefined sensitive information received redacted versions of the documents. This demonstrates that the combination of deterministic RBAC policies and keyword-based redaction effectively reduced the risk of unauthorised information disclosure during the evaluation.

The Redaction Accuracy of 100% further confirms that the implemented keyword-based redaction mechanism correctly detected and masked all predefined sensitive keywords included in the evaluation scenarios. By replacing sensitive terms with placeholder characters before displaying document content, the system reduced the exposure of confidential information while preserving the readability of the remaining document. However, the implemented redaction mechanism relies on predefined keywords and exact text matching. As a result, sensitive information expressed using synonyms, abbreviations, alternative spellings, or different sentence structures may not be detected and therefore may remain visible. Consequently, although the implemented approach performed successfully during the evaluation, more advanced Natural Language Processing (NLP) or

machine learning techniques could further improve the robustness of the redaction mechanism in future implementations.

The average response latency of 4.11 ms demonstrates that the implemented security mechanisms introduced only minimal processing overhead. Despite performing user authentication, RBAC policy evaluation, document retrieval, keyword-based redaction where necessary, and audit logging, the system responded to user requests within a few milliseconds. This indicates that the proposed approach is capable of providing secure document access without significantly affecting system responsiveness.

In addition to the predefined evaluation scenarios, an additional validation test was conducted using an invalid document name (reporrrt.txt). The system correctly rejected the request by denying access, demonstrating that the request validation mechanism can handle invalid or non-existent document requests safely. Although this scenario was not included in the confusion matrix analysis because it evaluates input validation rather than RBAC policy enforcement, it further demonstrates the robustness of the implemented prototype against invalid user inputs.

Overall, the evaluation demonstrates that the proposed AI Data Access Firewall successfully fulfilled its intended objectives within the scope of this project. The deterministic RBAC policy engine, keyword-based redaction mechanism, and audit logging module collectively provided effective protection against unauthorised document access while maintaining efficient system performance. Nevertheless, future enhancements could incorporate semantic analysis, Natural Language Processing techniques, or integration with real Large Language Models (LLMs) to improve the detection of sensitive information and support more advanced access control capabilities.

5.5 Chapter Summary

This chapter presented the testing and evaluation of the proposed AI Data Access Firewall to determine whether the implemented prototype satisfied the project objectives. A series of functional tests and evaluation scenarios were conducted to verify the correctness of the implemented modules, including user authentication, document request processing, Role-Based Access Control (RBAC) policy enforcement, keyword-based redaction, and audit logging.

The evaluation results demonstrated that the proposed system successfully enforced deterministic RBAC policies by granting authorised access, denying unauthorised requests, and applying keyword-based redaction where required. The security and performance metrics, including the confusion matrix, Block Rate, Leakage Prevention Rate, Redaction Accuracy, and Response Latency, provided quantitative evidence of the system's effectiveness in protecting sensitive information while maintaining efficient request processing.

The discussion further highlighted the strengths of the implemented prototype, particularly its accurate access control decisions and low response latency, while also acknowledging the limitations of the keyword-based redaction mechanism and identifying potential improvements for future work. Overall, the evaluation confirms that the proposed AI Data Access Firewall achieved the objectives defined for this project within the scope of the implemented prototype.

Chapter 6: Conclusion

6.1 Introduction

This chapter concludes the dissertation by summarising the overall outcomes of the proposed AI Data Access Firewall project. It evaluates the extent to which the project objectives have been achieved based on the design, implementation, and evaluation presented in the previous chapters. In addition, this chapter highlights the key contributions of the developed prototype, discusses its current limitations, and proposes several recommendations for future improvements. These reflections provide an overall assessment of the project while identifying opportunities for further development beyond the scope of this study.

6.2 Achievement of Project Objectives

The primary objective of this project was to develop an AI Data Access Firewall capable of preventing unauthorised AI access to corporate documents through deterministic Role-Based Access Control (RBAC) policies. Based on the system implementation and evaluation presented in Chapters 4 and 5, the proposed objectives were successfully achieved.

The first objective was to design an AI Data Access Firewall architecture that controls AI access to corporate documents based on predefined user roles and document sensitivity levels. This objective was achieved through the development of a modular system architecture consisting of user authentication, an AI security assistant interface, an RBAC policy engine, a document repository, a keyword-based redaction module, and an audit logging component. Together, these modules provide a structured approach to enforcing secure AI-to-document interaction.

The second objective was to develop a prototype implementing deterministic RBAC policies to regulate document access. This objective was successfully accomplished by implementing role-based access rules for Employee, Manager, and Administrator users. The system evaluated each document request against predefined access policies before allowing, denying, or redacting the requested document. This ensured that users could only access information permitted by their assigned roles.

The third objective was to evaluate the effectiveness of the proposed AI Data Access Firewall. This objective was achieved through functional testing and performance evaluation using predefined test cases and security metrics. The evaluation demonstrated that the system correctly enforced access control decisions, achieved a Leakage Prevention Rate of 100%, a Redaction Accuracy of 100% for the evaluated scenarios, and maintained an average response latency of 4.11 ms. These results indicate that the developed prototype effectively protected sensitive information while maintaining efficient system performance within the defined project scope.

Overall, the implementation and evaluation confirm that the proposed AI Data Access Firewall successfully achieved the objectives established for this project. The developed prototype demonstrates that deterministic RBAC policies, combined with keyword-based redaction and audit logging, can provide an effective approach for securing AI access to corporate documents.

6.3 Project Contributions

The proposed AI Data Access Firewall contributes a practical approach for securing AI-to-document interaction through deterministic Role-Based Access Control (RBAC) policies. Unlike traditional document access systems that only verify user authentication, the developed prototype evaluates every document request against predefined access policies before permitting AI access. This approach helps reduce the risk of unauthorised disclosure of sensitive corporate information.

Another contribution of this project is the integration of keyword-based redaction into the access control process. Instead of simply denying access to all sensitive documents, the system selectively masks predefined confidential information when appropriate, allowing authorised users to obtain useful document content while protecting sensitive data. This demonstrates an additional layer of information protection beyond conventional access control mechanisms.

The implementation of an audit logging module further contributes to system accountability by recording every document request together with the user role, requested document, access decision, and timestamp. These audit records support security monitoring, access tracking, and future investigations of system activities.

Finally, this project provides a functional proof-of-concept demonstrating how deterministic RBAC policies can be integrated into an AI access control framework without requiring complex machine learning models or external Large Language Model (LLM) integration. The developed prototype establishes a foundation that can be extended with more advanced security mechanisms in future research and practical implementations.

6.4 Limitations

Although the proposed AI Data Access Firewall successfully achieved its intended objectives, the developed prototype has several limitations due to the scope and constraints of this project.

Firstly, the system uses deterministic Role-Based Access Control (RBAC) with predefined access policies stored in configuration files. While this approach provides consistent and predictable access control decisions, it does not support dynamic policy generation, or context-aware access decisions based on user behaviour, environmental conditions, or organisational risk levels.

Secondly, the implemented keyword-based redaction mechanism relies on predefined keywords and exact text matching to identify sensitive information. As a result, sensitive content expressed using synonyms, abbreviations, alternative spellings, or different sentence structures may not be detected. This limitation reduces the effectiveness of the redaction process when handling more complex or unstructured documents.

In addition, the prototype was developed using text-based documents stored locally within the system. Consequently, it does not support other commonly used document formats such as PDF, Microsoft Word, or spreadsheet files, which are widely used in real-world organisations.

Furthermore, the system operates as a simulated AI environment and does not integrate with a real Large Language Model (LLM) or external AI services. Therefore, the evaluation focused on validating the access control mechanism rather than assessing interactions with production AI systems.

Finally, the evaluation was conducted using a limited number of predefined test scenarios within a controlled environment. Although the results demonstrate the effectiveness of the proposed

approach, additional testing using larger datasets, more diverse user roles, and real organisational environments would provide a more comprehensive assessment of the system's performance and scalability.

6.5 Future Work

Several enhancements can be considered to further improve the capabilities of the proposed AI Data Access Firewall beyond the scope of this project.

Firstly, future work could replace the current keyword-based redaction mechanism with Natural Language Processing (NLP) techniques to improve the identification of sensitive information. Unlike exact keyword matching, NLP-based approaches can recognise contextual meaning, synonyms, and different sentence structures, enabling more accurate protection of confidential information.

Secondly, the system could be integrated with real Large Language Models (LLMs) and enterprise AI platforms to evaluate the effectiveness of the proposed firewall in practical AI-assisted environments. Such integration would enable the access control mechanism to operate as a security layer between AI applications and organisational data sources.

Another possible enhancement is the implementation of Attribute-Based Access Control (ABAC) or other context-aware access control models. Unlike deterministic RBAC, these approaches consider additional factors such as user department, location, device, time of access, or risk level, providing more flexible and fine-grained access control decisions.

Future versions of the system could also support additional document formats, including PDF, Microsoft Word, and spreadsheet files, allowing the firewall to protect a wider range of organisational documents commonly used in business environments.

Finally, the system could be evaluated using larger datasets and real organisational environments involving more users, roles, and document types. Conducting large-scale testing would provide a more comprehensive assessment of the firewall's scalability, reliability, and effectiveness under practical operating conditions.

6.6 Chapter Summary

This chapter concluded the development of the proposed AI Data Access Firewall by reviewing the overall outcomes of the project. It demonstrated that the project objectives were successfully achieved through the design, implementation, and evaluation of a deterministic Role-Based Access Control (RBAC) system for securing AI access to corporate documents.

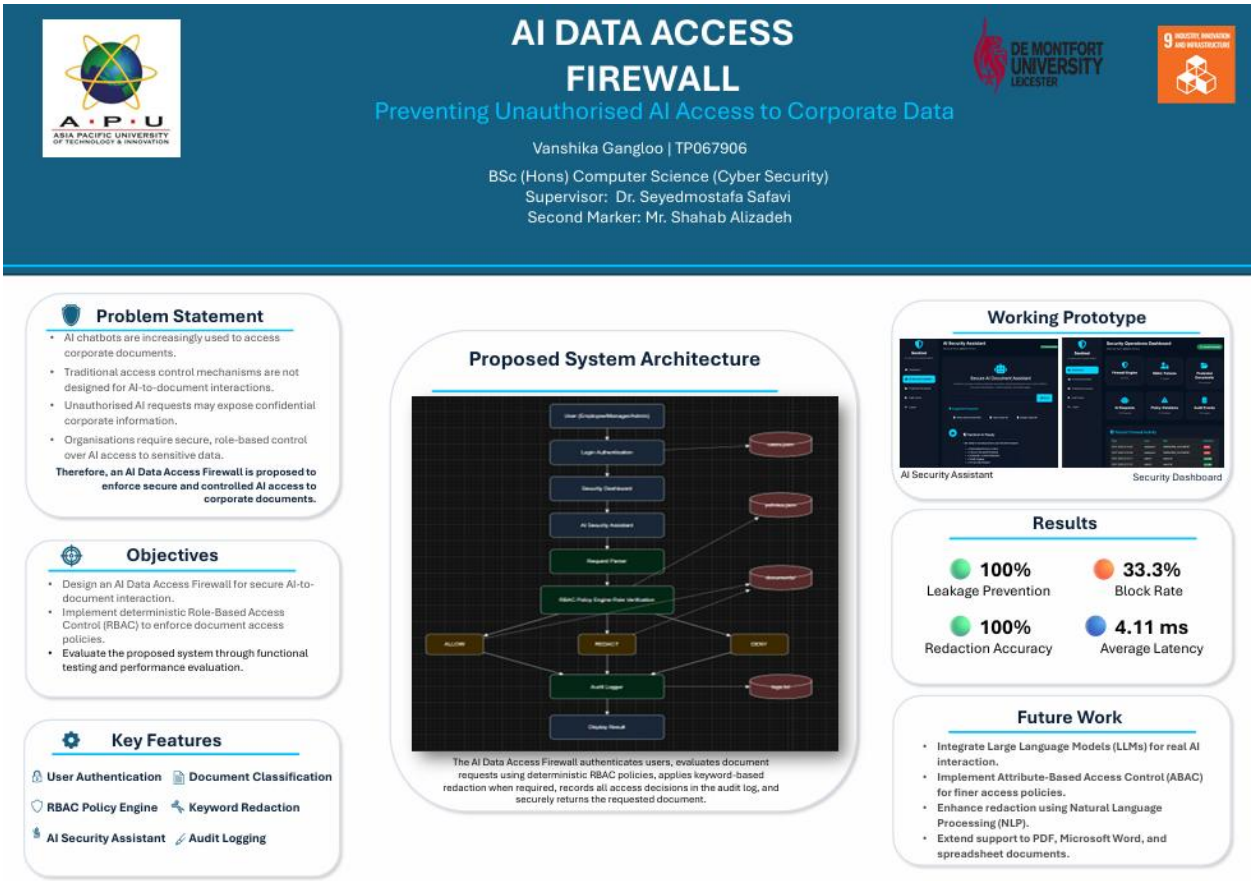
The chapter also summarised the key contributions of the developed prototype, discussed its current limitations, and identified several recommendations for future enhancements, including the adoption of Natural Language Processing (NLP), integration with real Large Language Models (LLMs), support for additional document formats, and more advanced access control mechanisms. Overall, the proposed AI Data Access Firewall provides practical proof-of-concept for protecting sensitive organisational information during AI-to-document interactions and establishes a foundation for further research and development in secure AI access control.

Appendix

Appendix A

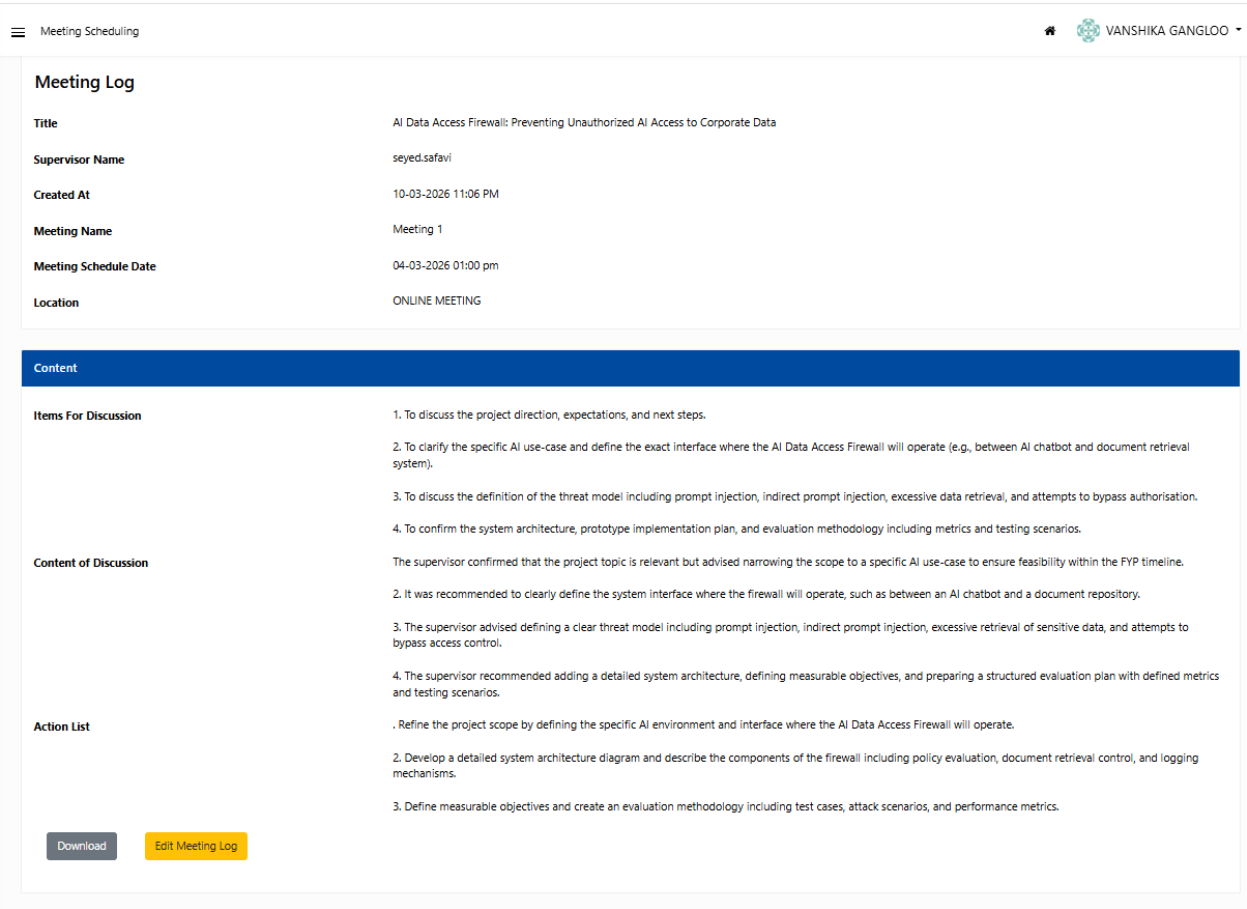
FYP Poster

FYP Poster.pdf

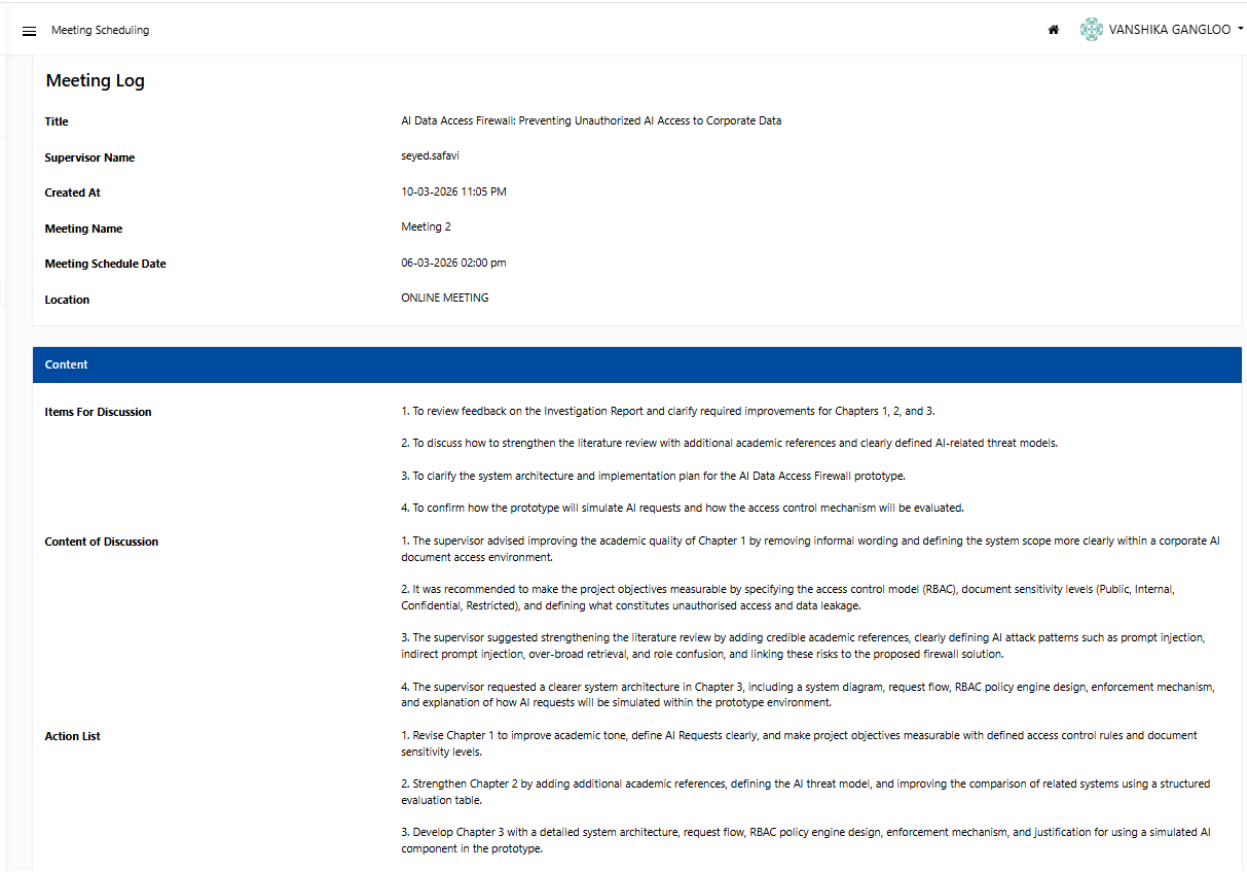


Appendix B

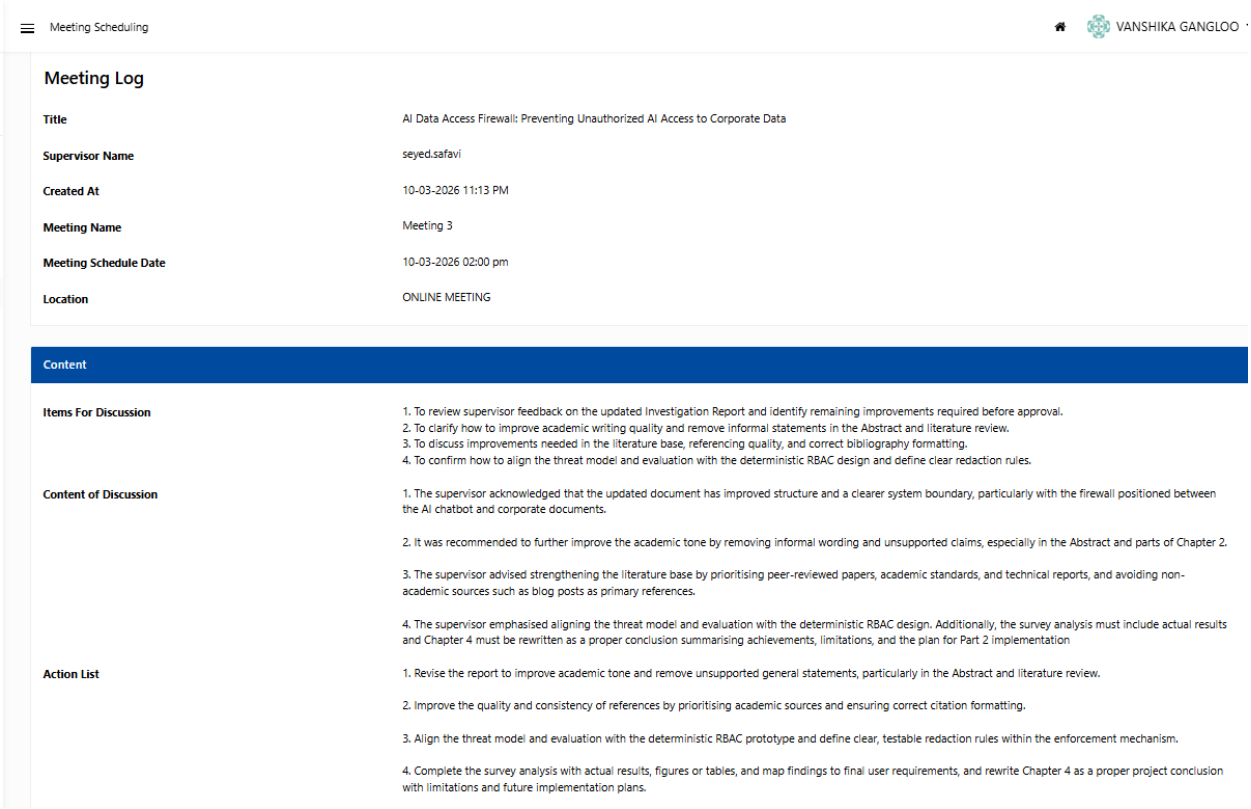
Meeting Logs



FYPPGBank _ My Meeting Logs 1.pdf



FYPPGBank _ My Meeting Logs 2.pdf



Meeting Scheduling

VANSHIKA GANGLOO

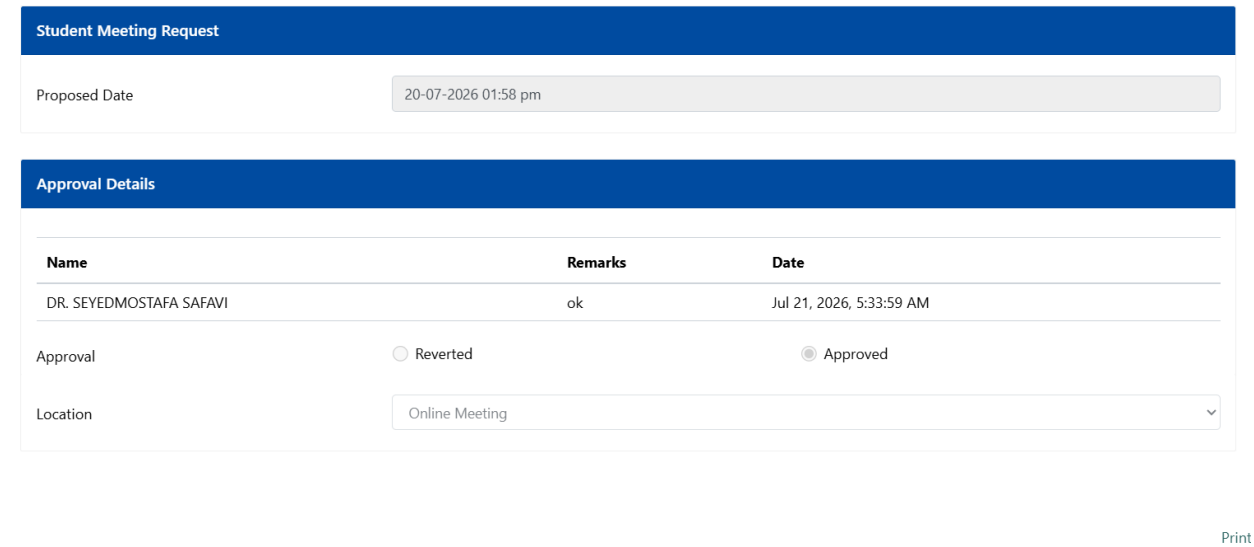
Meeting Log

Title	AI Data Access Firewall: Preventing Unauthorized AI Access to Corporate Data
Supervisor Name	seyed.safavi
Created At	10-03-2026 11:13 PM
Meeting Name	Meeting 3
Meeting Schedule Date	10-03-2026 02:00 pm
Location	ONLINE MEETING

Content

Items For Discussion	1. To review supervisor feedback on the updated Investigation Report and identify remaining improvements required before approval. 2. To clarify how to improve academic writing quality and remove informal statements in the Abstract and literature review. 3. To discuss improvements needed in the literature base, referencing quality, and correct bibliography formatting. 4. To confirm how to align the threat model and evaluation with the deterministic RBAC design and define clear redaction rules.
Content of Discussion	1. The supervisor acknowledged that the updated document has improved structure and a clearer system boundary, particularly with the firewall positioned between the AI chatbot and corporate documents. 2. It was recommended to further improve the academic tone by removing informal wording and unsupported claims, especially in the Abstract and parts of Chapter 2. 3. The supervisor advised strengthening the literature base by prioritising peer-reviewed papers, academic standards, and technical reports, and avoiding non-academic sources such as blog posts as primary references. 4. The supervisor emphasised aligning the threat model and evaluation with the deterministic RBAC design. Additionally, the survey analysis must include actual results and Chapter 4 must be rewritten as a proper conclusion summarising achievements, limitations, and the plan for Part 2 implementation
Action List	1. Revise the report to improve academic tone and remove unsupported general statements, particularly in the Abstract and literature review. 2. Improve the quality and consistency of references by prioritising academic sources and ensuring correct citation formatting. 3. Align the threat model and evaluation with the deterministic RBAC prototype and define clear, testable redaction rules within the enforcement mechanism. 4. Complete the survey analysis with actual results, figures or tables, and map findings to final user requirements, and rewrite Chapter 4 as a proper project conclusion with limitations and future implementation plans.

FYPPGBank _ My Meeting Logs 3.pdf



Student Meeting Request

Proposed Date: 20-07-2026 01:58 pm

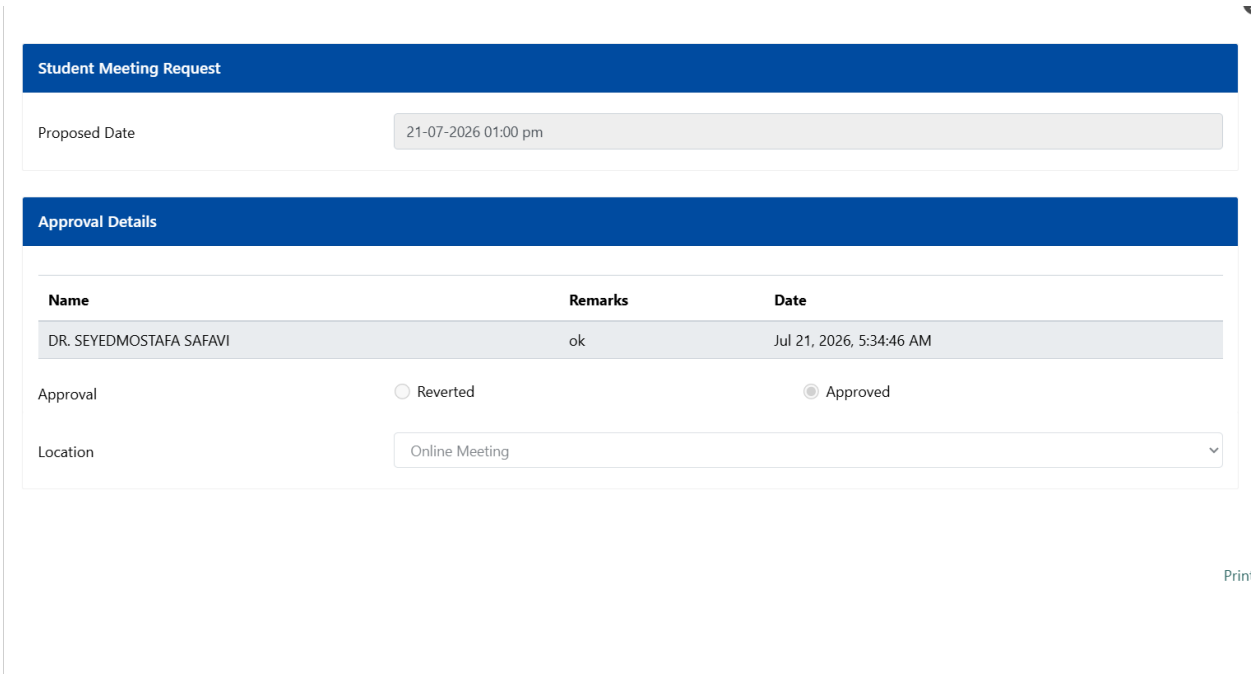
Approval Details

Name	Remarks	Date
DR. SEYEDMOSTAFA SAFAVI	ok	Jul 21, 2026, 5:33:59 AM

Approval: Reverted / Approved

Location: Online Meeting

Print



Student Meeting Request

Proposed Date: 21-07-2026 01:00 pm

Approval Details

Name	Remarks	Date
DR. SEYEDMOSTAFA SAFAVI	ok	Jul 21, 2026, 5:34:46 AM

Approval: Reverted / Approved

Location: Online Meeting

Print

Student Meeting Request

Proposed Date: 22-07-2026 01:00 pm

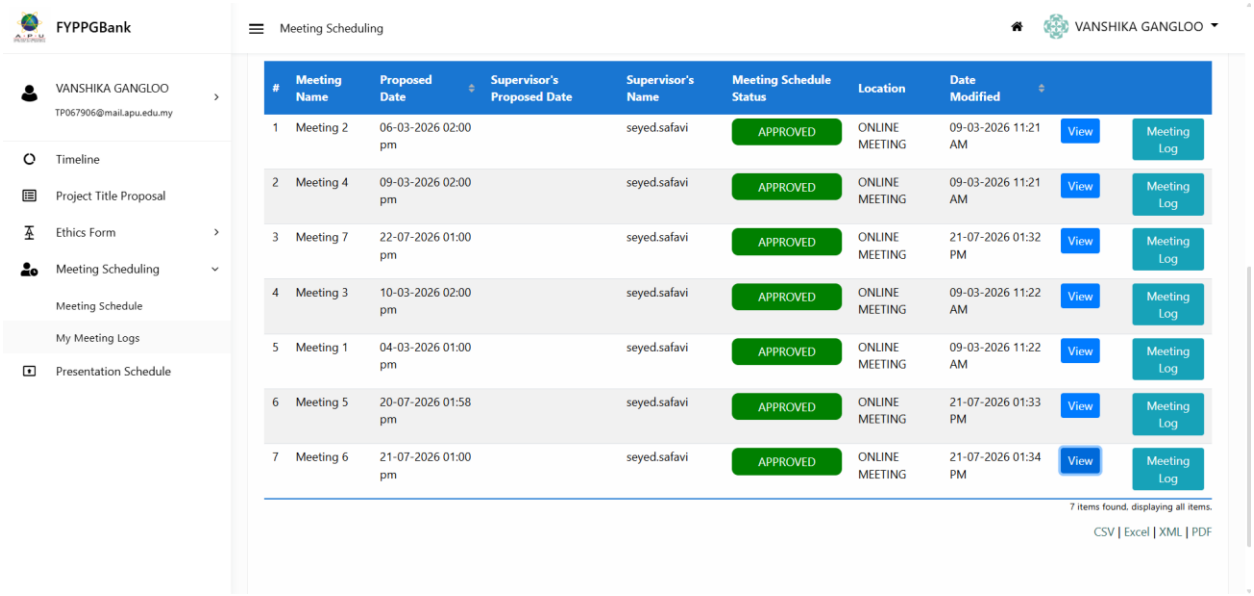
Approval Details

Name	Remarks	Date
DR. SEYEDMOSTAFA SAFAVI	ok	Jul 21, 2026, 5:32:51 AM

Approval: ○ Reverted ◉ Approved

Location: Online Meeting

Print



Appendix C

Title Submission

Project Title Proposal

Project Title: AI Data Access Firewall: Preventing Unauthorized AI Access to Corporate Data **Status** APPROVED

Proposed By VANSHIKA GANGLOO

Description

Introduction
Artificial Intelligence (AI) systems are increasingly used by organisations to analyse data, generate reports, assist decision-making, and improve productivity. Many companies now allow AI tools to access internal databases, documents, and records to automate tasks that were previously done by humans. While this provides efficiency and convenience, it also introduces serious security risks. If AI systems are given unrestricted or poorly controlled access to corporate data, sensitive information such as employee records, financial details, or confidential business documents may be exposed.

One of the major challenges in AI adoption is that AI systems do not understand security boundaries in the same way humans do. AI models respond based on prompts and available data, and they can be manipulated through carefully crafted inputs. Techniques such as prompt injection, privilege escalation, and indirect data access can cause AI systems to reveal or process information that they should not be allowed to access. These risks are particularly dangerous in corporate environments where large volumes of sensitive data are stored.

Existing security solutions such as traditional firewalls and access control systems are designed mainly for users and network traffic, not for AI systems. While they can restrict user access or network connections, they do not inspect or control how AI interacts with data internally. Many current AI security solutions are either too complex, expensive, or designed for large enterprises, making them unsuitable for smaller organisations or educational environments. Additionally, most existing systems lack transparency, making it difficult for non-technical users to understand how AI access decisions are made.

There is therefore a growing need for a dedicated security layer that monitors and controls AI access to corporate data. Such a system should act as an intermediary between AI models and data sources, ensuring that only authorised data is processed and that suspicious access attempts are detected. A simplified and understandable system would help organisations improve AI governance while also supporting learning and awareness of AI-related security risks.

This project proposes the development of an AI Data Access Firewall that prevents unauthorised AI access to corporate data. The system functions as a protective layer that analyses AI requests before they reach sensitive data sources. By applying access rules, data sensitivity classification, and request monitoring, the firewall ensures that AI systems operate within defined security boundaries. The solution is designed to be lightweight, transparent, and easy to understand, making it suitable for educational use and small to medium-scale corporate environments.
Aim
To design and develop an AI data access firewall that monitors and controls AI interactions with corporate data in order to prevent unauthorised access and potential data leakage.
Objectives
1. To identify different categories of corporate data based on sensitivity and access requirements.
2. To process AI data requests and analyse them against predefined access control rules.
3. To evaluate AI requests for signs of unauthorised access or policy violations.
4. To track and record AI access attempts for monitoring and auditing purposes.
5. To test the effectiveness of the firewall in preventing unauthorised data exposure.
Targeted User
1. Small and Medium-Sized Enterprises (SMEs)
2. Corporate IT and Security Teams
3. Cybersecurity Students and Researchers
4. Software Developers Working with AI Systems
5. Educational Institutions

SDG SDG9

Keywords Tampering Detection, Information security, Risk Assessment, Artificial Intelligence, Cybersecurity, Cybersecurity, Cybersecurity

Preferred Supervisor(s) SHAHAB ALIZADEH, ZAILAN ARABEE BIN ABDUL SALAM, ASSOC. PROF. DR. IMRAN MEDI, DR. SEYEDMOSTAFA SAFAVI, TAN LI JUNE

Assigned Supervisor seyed.safavi

Assigned Second Marker shahab.alizadeh

Remarks

Name	Remarks	Date
TS. UMAPATHY EAGANATHAN	Good.	Jan 2, 2026, 9:28:24 AM

Appendix D

Ethics Form

Supervisor Remarks

Name	Remarks	Date
DR. SEYEDMOSTAFA SAFAVI	Ok	Feb 24, 2026, 6:47:01 AM

Ethics Form (Fast-Track)

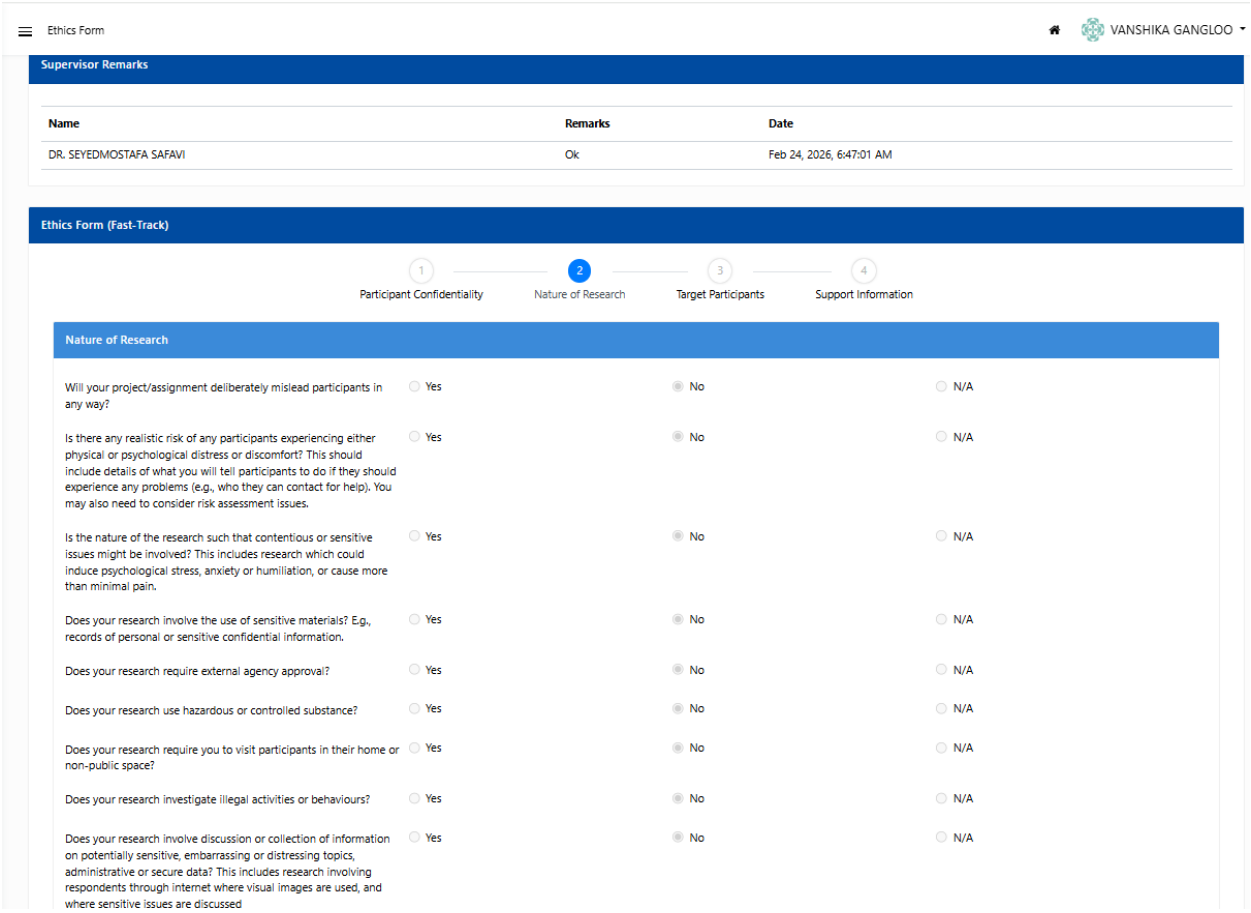
1 Participant Confidentiality — 2 Nature of Research — 3 Target Participants — 4 Support Information

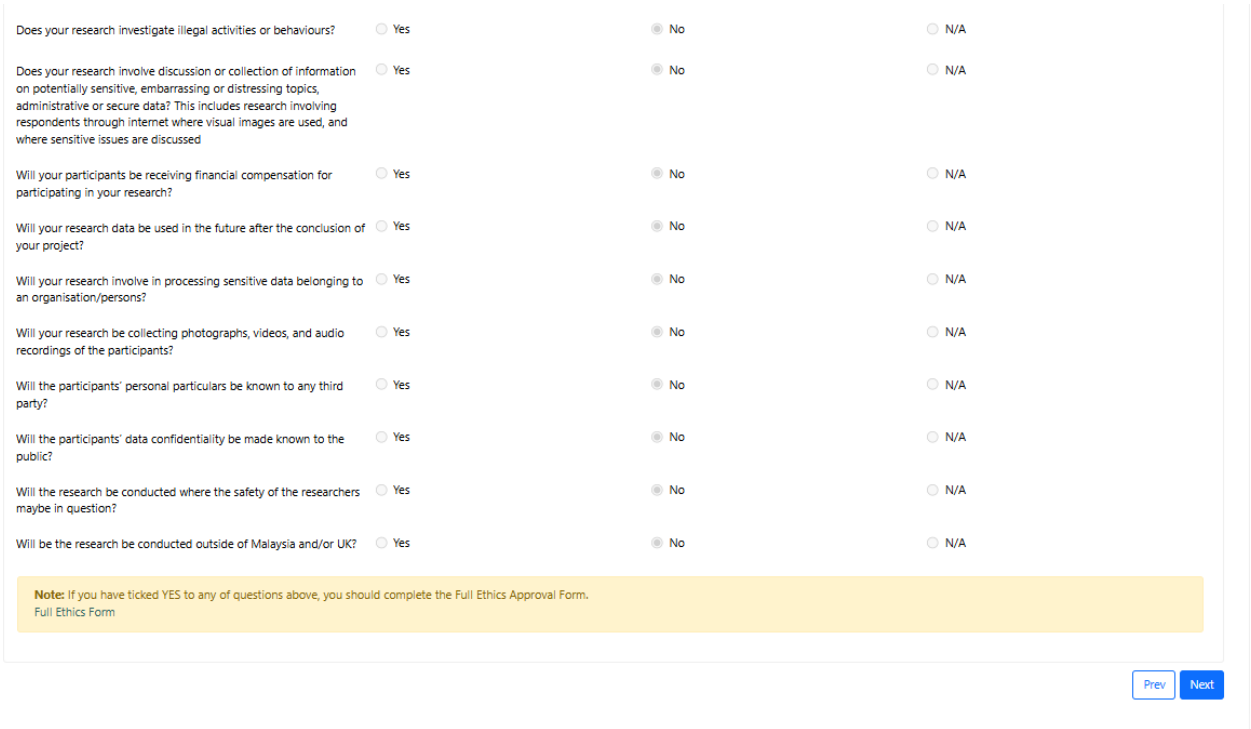
Participant Confidentiality

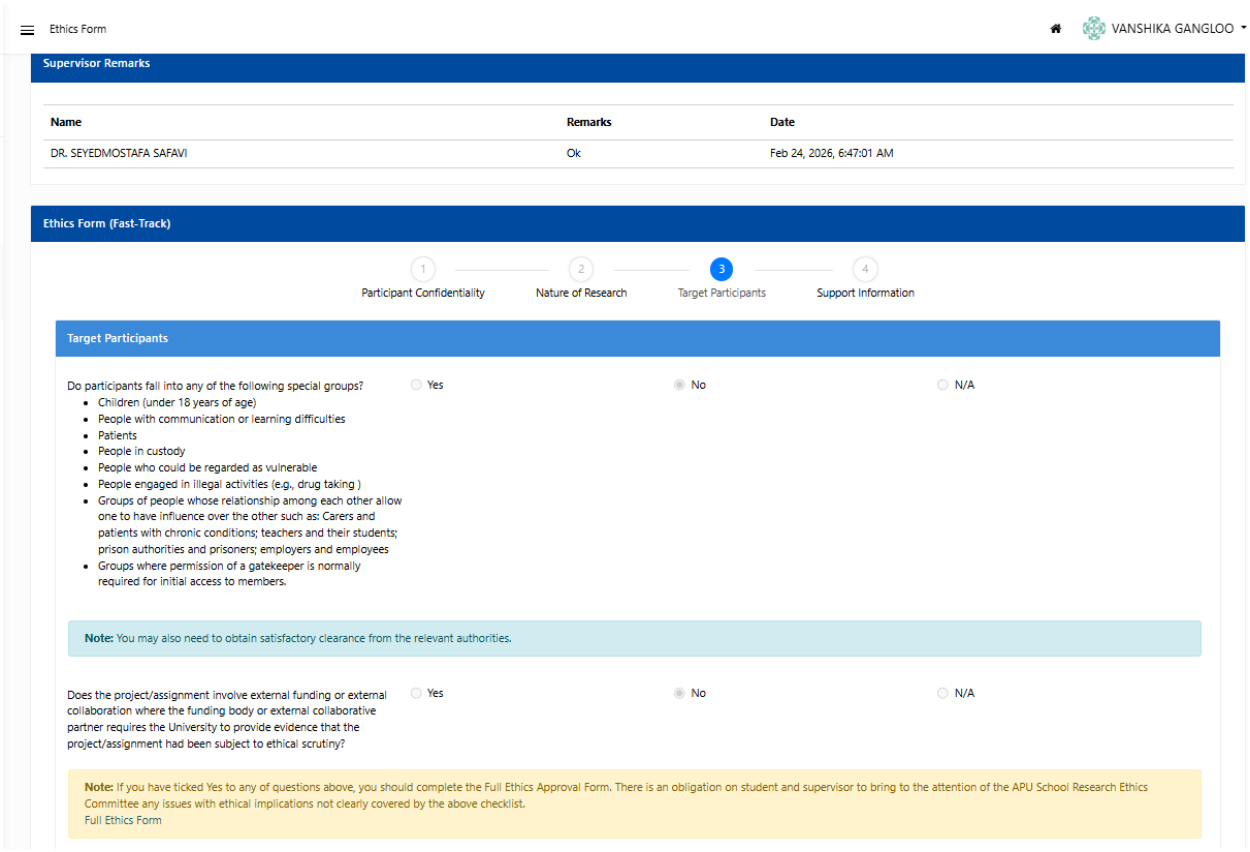
Will you describe the main procedures to participants in advance, so that they are informed about what to expect?	Yes	No	N/A
Will you tell participants that their participation is voluntary?	Yes	No	N/A
Will you obtain written consent for participation?	Yes	No	N/A
If the research is observational, will you ask participants for their consent to being observed?	Yes	No	N/A
Will you tell participants that they may withdraw from the research at any time and for any reason?	Yes	No	N/A
With questionnaires and interviews will you give participants the option of omitting questions they do not want to answer?	Yes	No	N/A
Will you tell participants that their data will be treated with full confidentiality and that, if published, it will not be identifiable as theirs?	Yes	No	N/A
Will you give participants the opportunity to be debriefed i.e. to find out more about the study and its results?	Yes	No	N/A

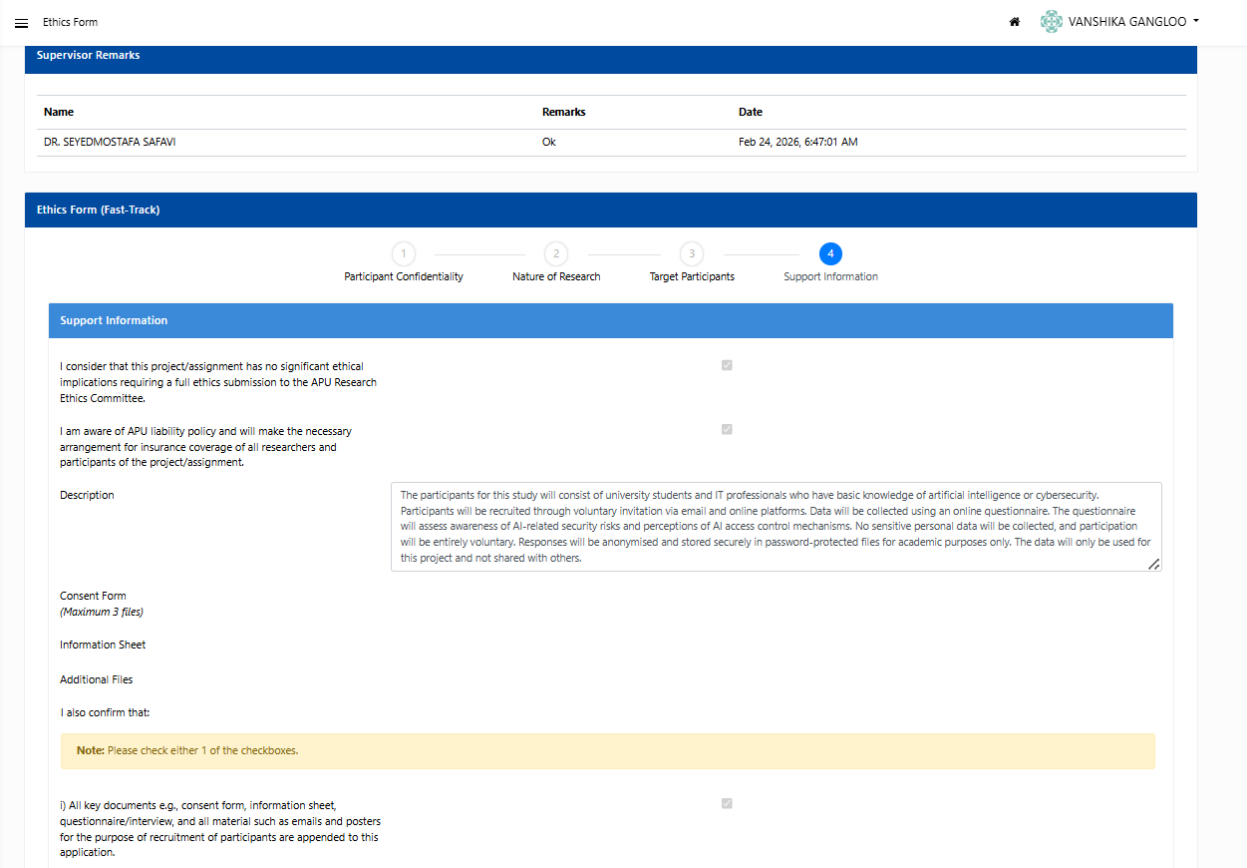
Note: If you have ticked No to any of questions above, you should complete the Full Ethics Approval Form.
Full Ethics Form

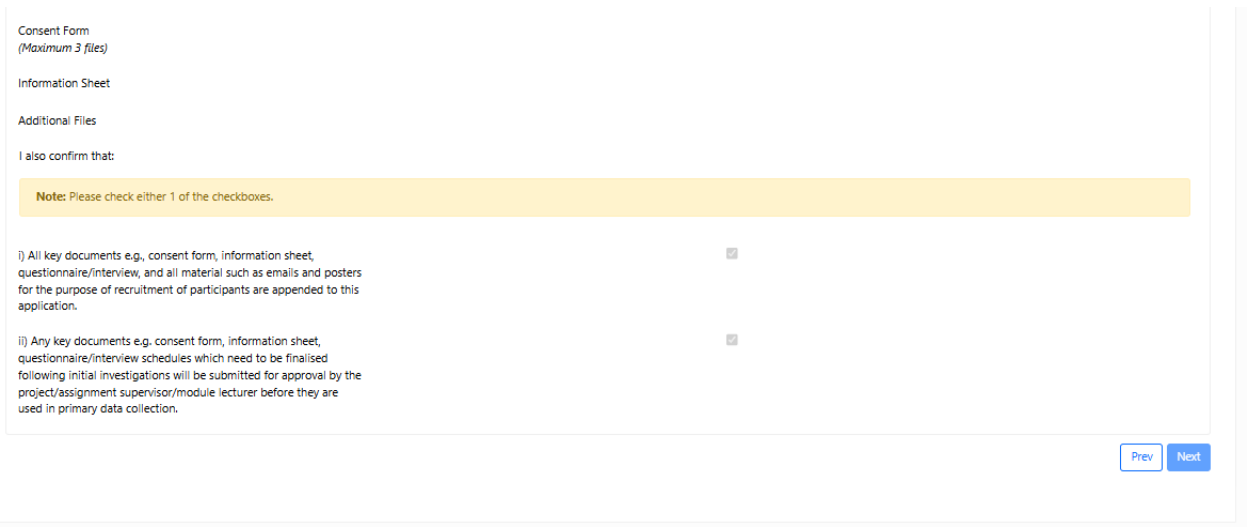
Prev Next


Ethics Form
VANSHIKA GANGLOO
Supervisor Remarks
Name
Remarks
Date
DR. SEYEDMOSTAFA SAFAVI
Ok
Feb 24, 2026, 6:47:01 AM
Ethics Form (Fast-Track)
1 Participant Confidentiality
2 Nature of Research
3 Target Participants
4 Support Information
Nature of Research
Will your project/assignment deliberately mislead participants in any way?
Is there any realistic risk of any participants experiencing either physical or psychological distress or discomfort? This should include details of what you will tell participants to do if they should experience any problems (e.g., who they can contact for help). You may also need to consider risk assessment issues.
Is the nature of the research such that contentious or sensitive issues might be involved? This includes research which could induce psychological stress, anxiety or humiliation, or cause more than minimal pain.
Does your research involve the use of sensitive materials? E.g., records of personal or sensitive confidential information.
Does your research require external agency approval?
Does your research use hazardous or controlled substance?
Does your research require you to visit participants in their home or non-public space?
Does your research investigate illegal activities or behaviours?
Does your research involve discussion or collection of information on potentially sensitive, embarrassing or distressing topics, administrative or secure data? This includes research involving respondents through internet where visual images are used, and where sensitive issues are discussed
Yes
No
N/A


Does your research investigate illegal activities or behaviours?
Does your research involve discussion or collection of information on potentially sensitive, embarrassing or distressing topics, administrative or secure data? This includes research involving respondents through internet where visual images are used, and where sensitive issues are discussed
Will your participants be receiving financial compensation for participating in your research?
Will your research data be used in the future after the conclusion of your project?
Will your research involve in processing sensitive data belonging to an organisation/persons?
Will your research be collecting photographs, videos, and audio recordings of the participants?
Will the participants' personal particulars be known to any third party?
Will the participants' data confidentiality be made known to the public?
Will the research be conducted where the safety of the researchers maybe in question?
Will be the research be conducted outside of Malaysia and/or UK?
Yes
No
N/A
Note: If you have ticked YES to any of questions above, you should complete the Full Ethics Approval Form.
Full Ethics Form
Prev
Next

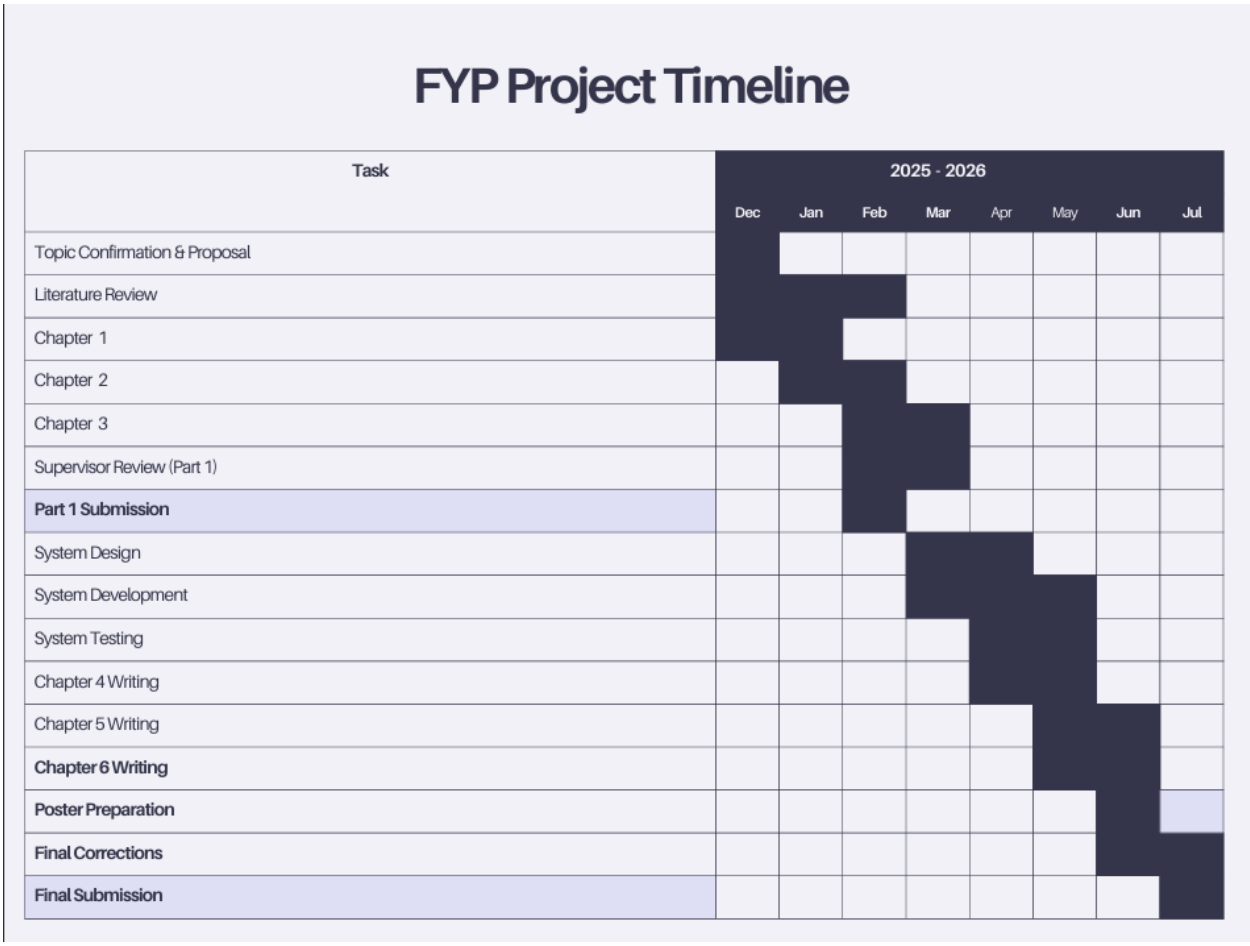

Ethics Form
VANSHIKA GANGLOO
Supervisor Remarks
Name
Remarks
Date
DR. SEYEDMOSTAFA SAFAVI
Ok
Feb 24, 2026, 6:47:01 AM
Ethics Form (Fast-Track)
1 Participant Confidentiality
2 Nature of Research
3 Target Participants
4 Support Information
Target Participants
Do participants fall into any of the following special groups?
Children (under 18 years of age)
People with communication or learning difficulties
Patients
People in custody
People who could be regarded as vulnerable
People engaged in illegal activities (e.g., drug taking)
Groups of people whose relationship among each other allow one to have influence over the other such as: Carers and patients with chronic conditions; teachers and their students; prison authorities and prisoners; employers and employees
Groups where permission of a gatekeeper is normally required for initial access to members.
Yes
No
N/A
Note: You may also need to obtain satisfactory clearance from the relevant authorities.
Does the project/assignment involve external funding or external collaboration where the funding body or external collaborative partner requires the University to provide evidence that the project/assignment had been subject to ethical scrutiny?
Yes
No
N/A
Note: If you have ticked Yes to any of questions above, you should complete the Full Ethics Approval Form. There is an obligation on student and supervisor to bring to the attention of the APU School Research Ethics Committee any issues with ethical implications not clearly covered by the above checklist.
Full Ethics Form


Ethics Form
VANSHIKA GANGLOO
Supervisor Remarks
Name
Remarks
Date
DR. SEYEDMOSTAFA SAFAVI
Ok
Feb 24, 2026, 6:47:01 AM
Ethics Form (Fast-Track)
1 Participant Confidentiality
2 Nature of Research
3 Target Participants
4 Support Information
Support Information
I consider that this project/assignment has no significant ethical implications requiring a full ethics submission to the APU Research Ethics Committee.
I am aware of APU liability policy and will make the necessary arrangement for insurance coverage of all researchers and participants of the project/assignment.
Description
The participants for this study will consist of university students and IT professionals who have basic knowledge of artificial intelligence or cybersecurity. Participants will be recruited through voluntary invitation via email and online platforms. Data will be collected using an online questionnaire. The questionnaire will assess awareness of AI-related security risks and perceptions of AI access control mechanisms. No sensitive personal data will be collected, and participation will be entirely voluntary. Responses will be anonymised and stored securely in password-protected files for academic purposes only. The data will only be used for this project and not shared with others.
Consent Form
(Maximum 3 files)
Information Sheet
Additional Files
I also confirm that:
Note: Please check either 1 of the checkboxes.
i) All key documents e.g., consent form, information sheet, questionnaire/interview, and all material such as emails and posters for the purpose of recruitment of participants are appended to this application.


Consent Form
(Maximum 3 files)
Information Sheet
Additional Files
I also confirm that:
Note: Please check either 1 of the checkboxes.
i) All key documents e.g., consent form, information sheet, questionnaire/interview, and all material such as emails and posters for the purpose of recruitment of participants are appended to this application.
ii) Any key documents e.g. consent form, information sheet, questionnaire/interview schedules which need to be finalised following initial investigations will be submitted for approval by the project/assignment supervisor/module lecturer before they are used in primary data collection.
Prev
Next

Appendix E

Gantt Chart



PDF
FYP Final Gantt Chart.pdf

Appendix F

Source Codes

```
@app.route("/", methods=["GET", "POST"])
def login():

    if request.method == "POST":

        username = request.form["username"]
        password = request.form["password"]

        with open("users.json", "r") as f:
            users = json.load(f)

        if username in users:
            stored_password = users[username]["password"]

            if check_password_hash(stored_password, password):
                session.permanent = True
                session["username"] = username
                session["role"] = users[username]["role"]
                session["login_time"] = datetime.now().strftime("%d %b %Y %H:%M")
                return redirect("/dashboard")

    return render_template("login.html")
```

app.py > ...

```
from flask import Flask, render_template, request, redirect, session
import json
import os
import time
from datetime import datetime

from werkzeug.security import check_password_hash

from request_parser import parse_request
from policy_engine import evaluate
from redactor import redact_content
from logger import log_request


# ------------------------------------------------
# Flask App Configuration
# ------------------------------------------------

app = Flask(__name__)
app.secret_key = "firewall_secret_key"

# ------------------------------------------------
# Secure Session Configuration
# ------------------------------------------------
```

Figure F.1: Main Flask Application Initialization

The code shown in Figure F.1 presents the initialization of the AI Data Access Firewall using the Flask web framework. It begins by importing the required Python libraries for web application development, session management, JSON processing, time handling, and password verification. In addition, the application imports the core modules developed for the system, including the

request parser, RBAC policy engine, keyword-based redaction module, and audit logger. These modules work together to process user requests, enforce access control policies, protect sensitive information, and maintain audit records. Finally, the Flask application instance is created and configured with a secret key to enable secure session management throughout the system.

```
@app.route("/documents")
def documents():

    if "username" not in session:
        return redirect("/")

    documents = []

    folders = {
        "Public": "documents/public",
        "Internal": "documents/internal",
        "Confidential": "documents/confidential",
        "Restricted": "documents/restricted"
    }

    access_policy = {
        "Public": "All Users",
        "Internal": "Employee and Above",
        "Confidential": "Manager (Employee receives Redacted)",
        "Restricted": "Admin Only"
    }

    stats = {
        "total": 0,
        "public": 0,
        "internal": 0,
        "confidential": 0,
        "restricted": 0
```

Figure F.2: Document Repository and Access Policy Configuration

The code shown above implements the document repository configuration within the AI Data Access Firewall. It first verifies that a user has successfully authenticated before allowing access to the document page. The system then defines the available document classifications, namely **Public**, **Internal**, **Confidential**, and **Restricted**, together with their corresponding storage locations. In addition, an access policy is configured to specify which user roles are authorised to access each classification level. The module also initializes statistical variables that are later used

to display document information on the dashboard. This configuration serves as the foundation for enforcing deterministic Role-Based Access Control (RBAC) policies during document retrieval.

```
    # ---------------------------------
    # Evaluate RBAC Policy
    # ---------------------------------

    decision = evaluate(
        session["role"],
        sensitivity
    )

    path = f"documents/{sensitivity.lower()}/{filename}"

    # ---------------------------------
    # Check if File Exists
    # ---------------------------------

    if not os.path.exists(path):

        log_request(
            session["username"],
            session["role"],
            filename,
            "FILE_NOT_FOUND"
        )

        latency = round((time.perf_counter() - start_time) * 1000, 2)

        return render_template(
```

Figure F.3: RBAC Policy Evaluation and File Validation

The code above demonstrates the implementation of the Role-Based Access Control (RBAC) policy evaluation during document retrieval. The system first determines the appropriate access decision by evaluating the authenticated user's role against the requested document sensitivity level. It then constructs the document path based on the document classification and verifies whether the requested file exists in the repository. If the file cannot be found, the request is recorded in the audit log, the processing latency is calculated, and an appropriate response is returned to the user. This process ensures that every document request is validated and logged before access is granted or denied.

```
        )

        latency = round((time.perf_counter() - start_time) * 1000, 2)

        return render_template(

            "chatbot.html",

            username=session["username"],
            role=session["role"],

            message=message,
            filename=filename,
            decision=decision,
            content="Requested document is unavailable.",
            latency=latency

        )
```

Figure F.4: Request Response and User Interface Rendering

The code above demonstrates how the AI Data Access Firewall generates a response after processing a document request. Once the request has been evaluated, the system calculates the processing latency and returns the chatbot interface together with the relevant information, including the authenticated user's details, access decision, requested filename, response message, and execution time. In situations where the requested document is unavailable, an appropriate notification is displayed to the user while maintaining a consistent interface. This implementation ensures that users receive clear feedback regarding the outcome of each document access request while preserving the system's security workflow.

```
# ---------------------------------
# Read File
# ---------------------------------

if decision == "ALLOW":

    with open(path, "r") as f:
        content = f.read()

elif decision == "REDACT":

    with open(path, "r") as f:
        content = redact_content(
            f.read()
        )

else:

    content = "Access Denied"
```

Figure F.5: Document Access Decision and Content Retrieval

The code above implements the document retrieval process based on the access decision generated by the Role-Based Access Control (RBAC) policy engine. When the decision is **ALLOW**, the requested document is opened, and its content is returned to the user without modification. If the decision is **REDACT**, the document content is processed by the keyword-based redaction module before being displayed, ensuring that sensitive information is protected. For requests that do not satisfy the access control policy, the system returns an **"Access Denied"** message without exposing any document content. This implementation ensures that document access is enforced according to the defined security policies while preventing unauthorised disclosure of sensitive information.

redactor.py > redact_content

```python
def redact_content(text):

    sensitive_keywords = [
        "salary",
        "bank",
        "details"
    ]

    for word in sensitive_keywords:
        text = text.replace(word, "****")

    return text
```

Figure F.6: Keyword-Based Content Redaction Module

The code above implements the keyword-based content redaction module of the AI Data Access Firewall. The module maintains a predefined list of sensitive keywords that should not be disclosed to unauthorised users. When a document requires partial access, the system scans the document content and replaces each matching sensitive keyword with masked characters before returning the document to the user. This approach enables controlled information sharing while preventing the direct exposure of confidential data. The redaction module works together with the Role-Based Access Control (RBAC) policy engine to enforce secure document access according to the defined security policies.

```
# ------------------------------------------------
# Audit Centre
# ------------------------------------------------

@app.route("/audit")
def audit():

    if "username" not in session:
        return redirect("/")

    logs = []

    total_logs = 0
    allow_count = 0
    redact_count = 0
    deny_count = 0

    if os.path.exists("logs.txt"):

        with open("logs.txt", "r") as f:

            lines = f.readlines()

            for line in reversed(lines):

                parts = line.strip().split(" | ")

                if len(parts) == 5:
```

Figure F.7: Audit Logging and Monitoring Module

The code above implements the Audit Logging and Monitoring module of the AI Data Access Firewall. Before accessing the audit records, the system verifies that the user has an active authenticated session to prevent unauthorised access. The module then reads the audit log file, extracts each recorded access event, and calculates summary statistics, including the total number of requests as well as the number of allowed, redacted, and denied requests. These audit records are displayed in reverse chronological order, enabling administrators to review recent document access activities efficiently. This module enhances accountability by maintaining a comprehensive record of user actions for security monitoring and auditing purposes.

```
            if len(parts) == 5:

                log = {

                    "time": parts[0],
                    "user": parts[1],
                    "role": parts[2],
                    "file": parts[3],
                    "decision": parts[4]

                }

                logs.append(log)

                total_logs += 1

                if log["decision"] == "ALLOW":
                    allow_count += 1

                elif log["decision"] == "REDACT":
                    redact_count += 1

                elif log["decision"] == "DENY":
                    deny_count += 1
```

Figure F.8: Audit Log Processing and Statistical Analysis

The code above processes the audit log entries recorded by the AI Data Access Firewall. Each log entry is parsed to extract essential information, including the timestamp, username, user role, requested file, and access decision. The extracted records are then stored in a structured list for display within the Audit Centre. In addition, the system updates statistical counters for **ALLOW**, **REDACT**, and **DENY** decisions, enabling administrators to

monitor document access activities and evaluate security enforcement. This implementation supports accountability by providing a clear overview of user interactions and policy enforcement outcomes within the system.

```
return render_template(
    "audit.html",
    username=session["username"],
    role=session["role"],
    login_time=session.get("login_time", "Unknown"),
    logs=logs,
    total_logs=total_logs,
    allow_count=allow_count,
    redact_count=redact_count,
    deny_count=deny_count
)
```

FigureF.9: Audit Centre Interface Rendering

The code above renders the Audit Centre interface after the audit records have been processed. It passes the authenticated user's information, including the username, role, and login time, together with the processed audit log records and statistical summaries to the HTML template. These statistics include the total number of audit events as well as the number of **ALLOW**, **REDACT**, and **DENY** decisions. By presenting this information through a dedicated interface, the system enables administrators to review document access activities, monitor policy enforcement, and analyse security events in an organised and user-friendly manner.

REFERENCES

Biggio, B., & Roli, F. (2018). Wild patterns: Ten years after the rise of adversarial machine learning. *Pattern Recognition, 84*, 317–331. https://doi.org/10.1016/j.patcog.2018.07.023

European Union Agency for Cybersecurity. (2023a). *Threat landscape for artificial intelligence systems*. Publications Office of the European Union.

European Union Agency for Cybersecurity. (2023b). *Cybersecurity of artificial intelligence and standardisation*. Publications Office of the European Union.

Ferraiolo, D. F., & Kuhn, D. R. (1992). Role-based access controls. In *Proceedings of the 15th National Computer Security Conference* (pp. 554–563). National Institute of Standards and Technology.

Floridi, L., & Cowls, J. (2019). A unified framework of five principles for AI in society. *Harvard Data Science Review, 1*(1). https://doi.org/10.1162/99608f92.8cd550d1

Greshake, K., et al. (2023). More than you've asked for: A comprehensive analysis of novel prompt injection threats to application-integrated large language models. *arXiv preprint*. https://arxiv.org/abs/2302.12173

Li, Y., & Xue, Y. (2023). Security risks and mitigation strategies for large language model applications. *IEEE Access, 11*, 112345–112359.

MITRE. (2023). *MITRE ATLAS: Adversarial Threat Landscape for Artificial Intelligence Systems*. https://atlas.mitre.org/

National Institute of Standards and Technology. (2020). *Security and privacy controls for information systems and organizations (SP 800-53 Rev. 5)*. U.S. Department of Commerce.

National Institute of Standards and Technology. (2023). *Artificial intelligence risk management framework (AI RMF 1.0)*. U.S. Department of Commerce. https://doi.org/10.6028/NIST.AI.100-1

OASIS. (2013). *eXtensible Access Control Markup Language (XACML) Version 3.0*. OASIS Standard.

OECD. (2019). *OECD principles on artificial intelligence*. Organisation for Economic Co-operation and Development.

OWASP Foundation. (2023). *OWASP Top 10 for Large Language Model Applications*.

Sandhu, R., Coyne, E. J., Feinstein, H. L., & Youman, C. E. (1996). Role-based access control models. *IEEE Computer, 29*(2), 38–47. https://doi.org/10.1109/2.485845

Shin, D., & Park, Y. J. (2019). Role of fairness, accountability, and transparency in algorithmic affordance. *Computers in Human Behavior, 98*, 277–284.

Zhang, C., et al. (2023). Prompt injection attacks against large language models. In *Proceedings of the IEEE Symposium on Security and Privacy Workshops*.